

DOCUMENTO DE ARQUITECTURA DE SOLUCIONES

Arquitectura de la Plataforma de Banca por Internet

Entidad financiera BP · Ejercicio práctico de arquitectura de soluciones

AUTOR

Henry Cadena Herrera

Versión 1.0 · 27 de septiembre de 2026

Ficha del documento

Título	Arquitectura de la Plataforma de Banca por Internet
Entidad	BP · entidad financiera
Autor	Henry Cadena Herrera
Versión y fecha	1.0 · 27 de septiembre de 2026
Alcance	12 capítulos organizados en 7 partes
Figuras	18, vectoriales, con fuente editable en formato <code>.drawio</code> como anexo
Decisiones registradas	52 decisiones de arquitectura, cada una con sus alternativas evaluadas y un mínimo de dos justificaciones; 143 en total
Escenarios de calidad	19 escenarios medibles, con su métrica y su umbral
Trazabilidad	Matriz de los requisitos del enunciado → decisión que lo cubre → forma de verificación (capítulo 11, sección 11)

PRELIMINARES

Resumen ejecutivo

I · ANÁLISIS DEL ENUNCIADO

Capítulo 1 · Interpretación del encargo: requisitos, ambigüedades y supuestos

1. Qué pide el ejercicio, en una frase
2. Descomposición de requisitos (trazabilidad)
3. Hallazgos del análisis: ambigüedades, contradicciones y trampas
4. Supuestos propuestos (a validar)
5. Mejoras incorporadas sobre el diseño convencional
6. Decisiones de alcance adoptadas

II · CONTEXTO Y ESCENARIOS DE CALIDAD

Capítulo 2 · Contexto, drivers y escenarios de calidad

1. Contexto de negocio
2. Alcance
3. Supuestos dimensionales con memoria de cálculo
4. Drivers arquitectónicos
5. Atributos de calidad: escenarios medibles
- 5.bis Política de retención de información
6. Restricciones
7. Mapa de capacidades de negocio y alcance (BIAN)
8. Riesgos iniciales del proyecto
9. Trazabilidad de esta fase

III · DECISIONES DE ARQUITECTURA

Capítulo 3 · Decisiones de plataforma y de canal (ADR-01 a ADR-13)

- ADR-01 · Modelo de despliegue
 - ADR-02 · Proveedor de nube
 - ADR-03 · Selección de región y residencia de datos
 - ADR-04 · Estilo arquitectónico
 - ADR-05 · Criterio de descomposición en servicios
 - ADR-06 · Plataforma de ejecución
 - ADR-07 · Tecnología de la aplicación web
 - ADR-08 · Tecnología de la aplicación móvil
 - ADR-09 · Patrón de backend por canal
 - ADR-10 · Custodia de credenciales de sesión en el canal web
 - ADR-11 · Interfaz dirigida desde el servidor en la aplicación móvil
 - ADR-12 · Estrategia de datos en el dispositivo y respuesta optimista
 - ADR-13 · Protección de la aplicación móvil
- Resumen de los bloques A y B

Capítulo 4 · Decisiones de identidad e integración (ADR-14 a ADR-27)

- ADR-14 · Flujo de autorización OAuth 2.0
- ADR-15 · Integración con el producto de identidad
- ADR-16 · Método de autenticación posterior al onboarding
- ADR-17 · Integración con la plataforma de onboarding
- ADR-18 · Verificación de identidad con reconocimiento facial
- ADR-19 · Autenticación reforzada por operación y propagación del nivel de aseguramiento
- ADR-20 · Propagación de identidad entre servicios
- ADR-21 · Puerta de enlace de interfaces
- ADR-22 · Protocolos de comunicación y su protección
- ADR-23 · Estrategia de integración con el Core
- ADR-24 · Bus de eventos y publicación fiable
- ADR-25 · Comunicación entre servicios y malla de servicios
- ADR-26 · Contratos de interfaz y versionado
- ADR-27 · Resiliencia frente a sistemas externos

Resumen de los bloques C y D

Capítulo 5 · Decisiones de datos, auditoría y operación monetaria (ADR-28 a ADR-39)

ADR-28 · Estrategia de acceso a datos
ADR-29 · Caché y persistencia para clientes frecuentes
ADR-30 · Persistencia por servicio
ADR-31 · Arquitectura de auditoría
ADR-32 · Ciclo de vida y niveles de almacenamiento
ADR-33 · Coordinación de la transferencia
ADR-34 · Idempotencia extremo a extremo
ADR-35 · Enrutamiento por tipo de operación y controles previos
ADR-36 · Arquitectura de notificaciones
ADR-37 · Evidencia probatoria de la notificación
ADR-38 · Catálogo de servicios de dominio
ADR-39 · Composición de la información de cliente

Resumen de los bloques E, E', F y G

Capítulo 6 · Decisiones de resiliencia, seguridad, cumplimiento y costo (ADR-40 a ADR-52)

ADR-40 · Modelo de alta disponibilidad
ADR-41 · Arquitectura celular en el camino transaccional
ADR-42 · Estrategia de recuperación ante desastres
ADR-43 · Catálogo de modos degradados
ADR-44 · Observabilidad
ADR-45 · Estrategia de despliegue y auto-recuperación
ADR-46 · Gestión del servicio: objetivos, alertas y respuesta
ADR-47 · Marco normativo aplicable y su traducción a controles
ADR-48 · Defensa en profundidad y segmentación
ADR-49 · Gestión de claves y secretos
ADR-50 · Cumplimiento expresado como código
ADR-51 · Modelo de costos y optimización
ADR-52 · Eficiencia del rendimiento

Resumen de los bloques H, I, J y K

IV · VISTAS DEL MODELO C4

Capítulo 7 · Nivel 1 · Diagrama de contexto

1. Propósito y audiencia de este nivel
2. Cómo leer el diagrama
3. Actores
4. El sistema en alcance
5. Sistemas relacionados y justificación de cada relación
6. Dos decisiones que este diagrama hace visibles
7. Trazabilidad
8. Qué se responde en el siguiente nivel

Capítulo 8 · Nivel 2 · Diagrama de contenedores

1. Propósito de este nivel
2. Organización en capas
3. Contenedores del canal
4. Borde y experiencia
5. Los siete servicios de dominio
6. Integración y almacenes
7. Lo que el diagrama demuestra
8. Trazabilidad
9. Qué se responde en el siguiente nivel

Capítulo 9 · Nivel 3 · Diagramas de componentes

1. Por qué cuatro diagramas y no uno
2. Cómo leer estos diagramas
3. Servicio de Transferencias (Figura 3)
4. Backend de canal web (Figura 4)
5. Servicio de Auditoría (Figura 5)
6. Servicio de Notificaciones (Figura 6)
7. Protocolos y su protección

8. Catálogo de patrones utilizados
9. Trazabilidad
10. Qué se responde en la siguiente fase

V · DIAGRAMAS COMPLEMENTARIOS

Capítulo 10 · Secuencias, despliegue, seguridad, datos, capacidades y plan

1. Por qué existen estos diagramas
2. Cómo leer los diagramas de secuencia
3. Figura 7 · Vinculación del cliente
4. Figura 8 · Autenticación y elevación por operación
5. Figura 9 · Transferencia interbancaria
6. Figura 10 · Notificación de un movimiento
7. Figura 11 · Despliegue en AWS
8. Figura 12 · Zonas de seguridad
9. Figura 13 · Recuperación ante desastres
10. Figura 14 · Mapa de datos
11. Figura 15 · Observabilidad
12. Figura 16 · Mapa de capacidades BIAN
13. Figura 17 · Hoja de ruta
- 13 bis. Figura 18 · Patrones para caché y clientes frecuentes
14. Protocolos: consolidado de esta fase
15. Trazabilidad
16. Qué falta

VI · CAPÍTULOS TRANSVERSALES

Capítulo 11 · Seguridad, normativa, disponibilidad, monitoreo, rendimiento, costos y gobierno

1. Por qué esta fase existe
2. Capítulo A · Seguridad
3. Capítulo B · Marco normativo y su traducción a controles
4. Capítulo C · Fiabilidad: alta disponibilidad, tolerancia a fallos y recuperación
5. Capítulo D · Excelencia operativa
6. Capítulo E · Monitoreo y gestión del servicio
7. Capítulo F · Eficiencia del rendimiento
8. Capítulo G · Manejo de costos
9. Capítulo H · Sostenibilidad
10. Capítulo I · Gobierno de la arquitectura
11. Capítulo J · Matriz de trazabilidad
12. Capítulo K · Riesgos residuales aceptados
13. Qué queda

VII · CIERRE

Capítulo 12 · Autoevaluación, glosario y anexos

2. Autoevaluación contra los quince criterios de calificación
3. Los catorce riesgos de evaluación, uno a uno
4. Glosario de siglas y términos
5. Control de versiones
6. Anexos
7. Cierre

Índice de figuras

- Figura 1 · Diagrama de contexto · quiénes usan el sistema y con qué sistemas se relaciona
- Figura 2 · Diagrama de contenedores · aplicaciones, servicios, mensajería y almacenes
- Figura 3 · Componentes del Servicio de Transferencias · patrones y protocolos con su protección
- Figura 4 · Componentes del backend de canal web · custodia de la credencial y composición
- Figura 5 · Componentes del Servicio de Auditoría · registro bitemporal, inmutable y verificable
- Figura 6 · Componentes del Servicio de Notificaciones · conmutación y carga probatoria
- Figura 7 · Secuencia · vinculación del cliente con reconocimiento facial
- Figura 8 · Secuencia · autenticación del canal web y elevación por operación
- Figura 9 · Secuencia · transferencia interbancaria con compensación
- Figura 10 · Secuencia · notificación de un movimiento originado en el Core
- Figura 11 · Despliegue en nube · tres zonas, región secundaria y enlace privado
- Figura 12 · Zonas de seguridad y defensa en profundidad
- Figura 13 · Recuperación ante desastres · piloto encendido entre regiones
- Figura 14 · Mapa de datos · propiedad, carácter autoritativo y retención
- Figura 15 · Observabilidad · de la señal a la decisión
- Figura 16 · Mapa de capacidades BIAN · dominios de servicio y su realización
- Figura 17 · Hoja de ruta · secuencia de entrega en dieciocho meses
- Figura 18 · Patrones de diseño · cachés, clientes frecuentes y niveles de auditoría

Cada figura se entrega además en formato editable `.drawio`, ábrible en diagrams.net sin necesidad de instalar nada.

Resumen ejecutivo

Esta sección está escrita para un lector no técnico. El resto del documento desarrolla y justifica cada punto.

1.1 Qué se ha diseñado

Una **plataforma de banca por internet** para la entidad BP, con aplicación web y aplicación móvil, que permite al cliente consultar sus movimientos, transferir y pagar —a cuentas propias, a terceros del mismo banco y a otras entidades—, ser avisado de todos sus movimientos conforme exige la norma, y cuya actividad queda registrada de forma que la entidad pueda acreditarla ante un requerimiento.

El sistema **no sustituye** al núcleo bancario ni a los sistemas que ya existen: se integra con ellos. El núcleo sigue siendo el dueño del dinero; la plataforma es el canal por el que el cliente lo gestiona.

1.2 Las cinco decisiones que definen el diseño

1. Consultar no toca el núcleo bancario. El 80 % de lo que hace un cliente es mirar sus movimientos. Si cada consulta llegara al núcleo, habría que ampliarlo —un sistema caro y poco elástico— y la disponibilidad del canal quedaría atada a la suya. En su lugar, el núcleo publica sus cambios y la plataforma mantiene una copia para consulta, **declarada expresamente como copia y no como original**. Es, a la vez, la principal decisión de rendimiento y la principal decisión de coste del proyecto.

2. El aviso al cliente nace en el núcleo, no en la aplicación. La norma obliga a notificar *los movimientos realizados*, no *los realizados desde el canal digital*. Un movimiento puede originarse en un cajero, en un comercio o en una transferencia entrante. Si el disparador fuese la aplicación, quedaría sin avisar la mayoría de los casos.

3. El dinero no se mueve antes de los controles. Validar la operación, evaluar el riesgo y contrastar al beneficiario contra listas restrictivas ocurre **siempre antes** de reservar fondos. Hacerlo después dejaría a la entidad habiendo ejecutado la operación que debía impedir.

4. La credencial de acceso nunca llega al navegador. La custodia el servidor y el navegador recibe solo una cookie que el código de la página no puede leer. Un ataque que consiga ejecutar código en la página no obtiene la credencial, porque allí no hay ninguna.

5. El banco no guarda el rostro del cliente. En la vinculación, la imagen va directamente de la aplicación al proveedor especializado; el banco recibe el veredicto, no el dato biométrico. Una contraseña comprometida se cambia; un rostro, no.

1.3 Qué se compromete

Compromiso	Valor	Qué significa para el cliente
Disponibilidad al consultar	99,95 % mensual	Menos de 22 minutos al mes sin servicio de consulta
Disponibilidad al transferir	99,5 % mensual	Limitada por el núcleo bancario, que no se modifica
Tiempo de consulta	≤ 0,5 s en el 95 % de los casos	La pantalla de movimientos aparece de inmediato
Tiempo de una transferencia	≤ 2 s en el 95 % de los casos	La orden se admite sin espera perceptible
Aviso de un movimiento	≤ 2 min en el 95 % de los casos	Se entera casi al instante de cualquier cargo
Recuperación ante un desastre	Servicio restablecido en < 1 h, con < 5 min de datos en riesgo	Una catástrofe en un centro de datos no deja al banco sin canal
Coste	≤ 0,06 USD por usuario activo al mes	El canal es económicamente sostenible al crecer

1.4 Qué se ha dejado fuera, y por qué

- **El núcleo bancario no se modifica:** es una restricción del enunciado y condiciona el techo de disponibilidad del camino de transferencia.
- **La plataforma de onboarding es corporativa,** no del canal: también se usa en oficina y en web. Lo que aquí se diseña es su **integración**.

- **El producto de identidad ya existe** y solo se configura: la plataforma se integra por estándar para que pueda sustituirse.
- **No hay tarjetas ni crédito** en el alcance, de modo que la normativa de medios de pago con tarjeta no aplica hoy; se declara la previsión por si se incorporan.

1.5 Cómo está organizado el documento

Parte	Contenido	Para quién
I · Análisis	Lo que el enunciado dice, lo que no dice y las contradicciones encontradas	Arquitecto, evaluador
II · Contexto y escenarios	Requisitos convertidos en objetivos medibles	Arquitecto, gestor
III · Decisiones	52 decisiones con sus alternativas y su justificación	Arquitecto, comité técnico
IV · Vistas C4	Los tres niveles del modelo	Del negocio al desarrollador
V · Diagramas complementarios	Secuencias, despliegue, seguridad, datos, BIAN, plan	Técnico y de operación
VI · Capítulos transversales	Seguridad, norma, disponibilidad, monitoreo, costos	Riesgos, cumplimiento, dirección
VII · Cierre	Autoevaluación, glosario y anexos	Evaluador

El enunciado exige que *"el documento esté bien organizado y sea fácil de leer"*. Se trató como **requisito con entregables propios** (H-16), no como una cortesía de presentación: portada, índice navegable, numeración de figuras con índice propio, resumen ejecutivo para lector no técnico, glosario de siglas, control de versiones y matriz de trazabilidad requisito → decisión → verificación, y cada figura con su fuente editable.

Capítulo 1 · Interpretación del encargo: requisitos, ambigüedades y supuestos

Documento de trabajo previo al desarrollo. Objetivo: entender el enunciado en su totalidad, detectar ambigüedades y contradicciones, fijar supuestos y acordar el plan antes de producir el entregable.

Fecha: 2026-09-26 · Estado: **pendiente de validación con el cliente (tú)**

1. Qué pide el ejercicio, en una frase

Diseñar la arquitectura de una plataforma de **banca por internet** (web + móvil) para la entidad financiera "BP", que permita **consultar movimientos, transferir y pagar** (cuentas propias, terceros del mismo banco e interbancarias), integrándose con un **core bancario**, un **sistema complementario de cliente**, **≥2 proveedores de notificación**, un **IdP OAuth2 existente** y un **onboarding con reconocimiento facial**; con **auditoría completa, caché para clientes frecuentes, capa de integración con API Gateway**, y cumpliendo **HA, tolerancia a fallos, DR, seguridad, monitoreo, excelencia operativa y auto-healing** sobre nube (AWS o Azure). Entregable: **PDF** con los **tres niveles de C4** más diagramas complementarios, y **cada decisión justificada con un mínimo de 2 argumentos y las alternativas evaluadas**.

2. Descomposición de requisitos (trazabilidad)

2.1 Requisitos funcionales

ID	Requisito	Frase del enunciado
RF-01	Consulta de histórico de movimientos	"acceder al histórico de sus movimientos"
RF-02	Transferencias entre cuentas propias	"transferencias y pagos entre cuentas propias"
RF-03	Transferencias/pagos interbancarios	"e interbancarias"
RF-04	Consulta de datos básicos del cliente	"consulta de datos básicos" (servicio 1)
RF-05	Enriquecimiento de datos de cliente bajo demanda	"un sistema independiente que complementa la información del cliente cuando los datos se requieren en detalle"
RF-06	Notificación de movimientos por norma	"la norma exige que los usuarios sean notificados sobre los movimientos realizados"
RF-07	Onboarding digital móvil con reconocimiento facial	"el sistema de Onboarding para nuevos clientes en la aplicación móvil usa reconocimiento facial"
RF-08	Autenticación posterior con usuario/clave y/o huella	"a partir del Onboarding el nuevo usuario podrá ingresar mediante usuario y clave, huella o algún otro método"
RF-09	Auditoría de todas las acciones del cliente	"una base de datos de auditoría que registra todas las acciones del cliente"
RF-10	Persistencia/caché para clientes frecuentes	"cuenta con un mecanismo de persistencia de información para clientes frecuentes"
RF-11	Front SPA	"una SPA"
RF-12	Front móvil multiplataforma	"una Aplicación móvil desarrollada en un Framework multiplataforma"

2.2 Requisitos no funcionales y restricciones

ID	Requisito	Origen
RNF-01	Alta disponibilidad (HA)	"Garantice en su arquitectura, alta disponibilidad"
RNF-02	Tolerancia a fallos	ídem
RNF-03	Recuperación ante desastres (DR)	ídem
RNF-04	Seguridad	ídem
RNF-05	Monitoreo / observabilidad	ídem
RNF-06	Excelencia operativa	ídem
RNF-07	Auto-healing	ídem
RNF-08	Baja latencia	"garantice baja latencia"
RNF-09	Desacoplamiento, reutilización, cohesión, extensibilidad	"arquitectura desacoplada con elementos reusables y cohesionados para otros componentes que pueden adicionarse en el futuro"
RNF-10	Cumplimiento normativo financiero	"mencione aquellos elementos normativos"
RNF-11	Control de costos	Criterio de calificación 9 ("Manejo de costos")
RC-01	El IdP OAuth2 ya existe y solo se configura	"no requiere implementar toda la lógica"
RC-02	Capa de integración con API Gateway obligatoria	"pasa por una capa de integración compuesta por una api Gateway"
RC-03	Mínimo 2 sistemas de notificación	"mínimo 2"
RC-04	Mínimo 3 servicios (básicos, movimientos, transferencias), ampliables	"inicialmente usted cuenta con 3 servicios principales"
RC-05	Modelo C4 hasta componentes	"El modelo debe ser desarrollado bajo modelo c4"

2.3 Entregables exigidos

1. **PDF** bien organizado y fácil de leer.
2. **Imágenes** de los diagramas (se sugiere draw.io).
3. **C4 Nivel 1 – Contexto**: para no técnicos; sistemas internos y externos, actores, descripciones breves, conexiones explicativas.
4. **C4 Nivel 2 – Contenedores**: para técnicos; aplicaciones, servicios, BD y mensajería, componentes cloud sin mucho detalle, conexiones descritas.
5. **C4 Nivel 3 – Componentes**: microservicios, patrones arquitectónicos, protocolos de comunicación **con seguridad**, uso de componentes cloud.
6. **"Otros diagramas requeridos"** (no enumerados → ver hallazgo H-10).
7. **Texto explicativo y justificación de cada decisión, mínimo 2 razones + alternativas evaluadas.**

2.4 Los 15 criterios de calificación y dónde se responden

#	Criterio	Sección prevista del entregable
1	Requisitos cubiertos y justificados	Matriz de trazabilidad + ADRs
2	Calidad y profundidad de los C4	Cap. C4 (3 niveles)
3	Segmentación de responsabilidades y desacoplamiento	Contenedores + componentes + DDD
4	Uso de patrones de arquitectura	Catálogo de patrones aplicados
5	Integración con servicios externos	Capa de integración + resiliencia

#	Criterio	Sección prevista del entregable
6	Arquitectura front-end y móvil	Cap. Frontends
7	Arquitectura de acceso a datos	Cap. Datos (CQRS, caché, políticas)
8	Conocimientos de nube	Cap. Infraestructura cloud
9	Manejo de costos	Cap. Costos / FinOps
10	Arquitectura de autenticación	Cap. IAM (OAuth2/OIDC)
11	Integración con Onboarding	Cap. Onboarding e identidad
12	Diseño y solución de auditoría	Cap. Auditoría
13	Regulaciones y estándares de seguridad	Cap. Cumplimiento normativo
14	HA y tolerancia a fallos	Cap. Resiliencia + DR
15	Monitoreo	Cap. Observabilidad

Lectura de los criterios: 9 de los 15 no son "dibujar cajas" sino **capítulos de texto argumentado**. Un entregable que solo tenga diagramas suspende aunque los diagramas sean excelentes.

3. Hallazgos del análisis: ambigüedades, contradicciones y trampas

H-01 · "BP" no está identificado → el marco normativo queda indefinido

El enunciado exige mencionar "elementos normativos para entidades financieras", pero no dice el país. La normativa cambia por completo: Ecuador (Superintendencia de Bancos / JPRMF), Colombia (SFC, Circular Externa 007 de 2018), Perú (SBS, Res. 504-2021), España/UE (PSD2, DORA, EBA). **Resolución propuesta:** declarar el país como supuesto y estructurar el capítulo normativo en dos niveles: (a) **marco local** del país elegido, (b) **marco transversal internacional** (ISO 27001, PCI-DSS, NIST, OWASP, GDPR/ley local de datos personales). Así el entregable es correcto aunque el evaluador tenga otro país en mente.

H-02 · Contradicción aparente en autenticación: "no implementes la lógica" pero "recomienda el flujo"

No es una contradicción real, es una precisión de alcance: el IdP es un **producto configurable** (se parametriza, no se programa), pero el arquitecto **sí debe decidir el flujo OAuth2**. **Trampa asociada:** como el enunciado menciona "usuario y clave", la respuesta intuitiva es *Resource Owner Password Credentials*. **Es incorrecta:** está desaconsejada en OAuth 2.0 Security BCP y eliminada en OAuth 2.1. La respuesta correcta es **Authorization Code + PKCE** para ambos frontales, con el IdP alojando la pantalla de login. Este punto vale el criterio 10 completo.

H-03 · Relación entre verificación de identidad y autenticación (revisado)

El enunciado pide que el reconocimiento facial del onboarding se considere "como parte del flujo de autorización y autenticación". **No es una confusión de conceptos del enunciado**, como se interpretó en una primera lectura: existe una relación real que hay que modelar con precisión.

- **Verificación de identidad (identity proofing):** prueba de vida, verificación documental y cotejo biométrico. Ocurre **una vez**, en el onboarding, y determina el **nivel de aseguramiento de la identidad**.
- **Autenticación:** ocurre **en cada acceso**, mediante OAuth2/OIDC con las credenciales establecidas.

El vínculo entre ambas es lo que hay que diseñar: el nivel alcanzado en el onboarding se propaga como atributos del token (método de verificación, fecha, nivel), y los servicios de negocio lo usan para **autorizar** — límites operativos, operaciones permitidas y exigencia de autenticación reforzada. Un cliente con verificación biométrica completa opera con límites altos; uno con verificación parcial, con restricciones.

Formalización: se emplean los niveles del estándar **NIST SP 800-63** — IAL para el aseguramiento de la identidad y AAL para la robustez de la autenticación — de modo que la decisión quede anclada a un marco reconocido y auditable.

H-04 · "especifique alguno de los dos anteriores" → instrucción ambigua

"los dos anteriores" = *usuario y clave y huella*. Pide elegir al menos uno. **Resolución propuesta:** incluir **ambos**, pero con roles distintos y justificados: contraseña como credencial de respaldo/recuperación, y **biometría local del**

dispositivo (huella/Face ID) como método principal en móvil, implementada correctamente: la biometría **nunca viaja al servidor**; desbloquea una clave privada en el *secure enclave* del dispositivo (device binding). Esto se puede llevar a **FIDO2/passkeys** como evolución. **Trampa asociada**: proponer que la huella se envíe al backend para compararla. Sería un error grave de seguridad y privacidad.

H-05 · "Mecanismo de persistencia de información para clientes frecuentes": frase con dos lecturas

Gramaticalmente, "cuenta con" puede referirse al **sistema** o a la **base de datos de auditoría**. De ahí dos interpretaciones: - (a) **Caché/persistencia de datos de los clientes que más usan el canal**, para mejorar latencia y reducir carga sobre el core. - (b) **Tiering de la propia auditoría** (datos calientes consultables vs. fríos archivados) para los clientes con más actividad. También cabe (c): "frecuentes" referido a **beneficiarios/destinatarios frecuentes** de transferencias. **Resolución propuesta**: cubrir las tres como una **solución de tres capas** explícitamente etiquetada, y dejar claro en el documento que se interpreta así por la ambigüedad del enunciado. El ejercicio pide además "una alternativa basada en **patrones de diseño** que relacione los componentes": se entregará un **diagrama de patrones** (Interceptor/Decorator → Outbox → Publisher/Subscriber → Repository → Cache-Aside → CQRS/Materialized View → Hot/Cold tiering).

H-06 · Alcance real de las notificaciones: no basta con notificar lo que pasa en la app

"La norma exige que los usuarios sean notificados sobre **los movimientos realizados**" — no dice "los movimientos realizados desde el canal digital". Un movimiento puede originarse en un cajero, en un comercio o en una transferencia entrante desde otro banco. **Consecuencia arquitectónica importante**: el disparador de notificaciones **no puede ser únicamente la aplicación**; debe existir un flujo dirigido por **eventos del core** (CDC o publicación de eventos del core). Modelar las notificaciones solo desde la app sería funcionalmente incorrecto frente a la norma.

H-07 · "Transferencias que realiza llamados a servicios externos dependiendo del tipo"

Implica **enrutamiento por tipo de operación**: propia (solo core), a terceros del mismo banco (core), interbancaria (red de pagos externa: ACH/SPI/CCE según país). Cada ruta tiene SLA, horarios de corte y modos de fallo distintos. **Consecuencia**: patrón *Strategy/Router* + **Saga con compensación** para la interbancaria (reserva de fondos → envío → confirmación/devolución). **Trampa asociada**: proponer una transacción distribuida (2PC) con una red de pagos externa; es imposible en la práctica.

H-08 · Tensión entre "hay presupuesto" y el criterio "manejo de costos"

El enunciado autoriza gasto ("cuenta con presupuesto"), pero uno de los 15 criterios evalúa el manejo de costos. No es contradicción: se espera **conciencia económica**, no austeridad. Se resolverá con un capítulo de costos que incluya: estimación por servicio, dimensionamiento, estrategias (reservas/savings plans, autoescalado, tiering de almacenamiento, caché para reducir llamadas al core), y el coste evitado (p. ej., caché que reduce consultas al core).

H-09 · C4 nivel 3: el diagrama de componentes no es uno solo

En el modelo C4, el nivel 3 se dibuja **por contenedor**. El enunciado, al pedir "microservicios, patrones y protocolos con seguridad", sugiere desglosar varios. Un único diagrama gigante de componentes sería una aplicación incorrecta del modelo y penalizaría el criterio 2. **Resolución propuesta**: desglosar **4 contenedores** representativos: (1) BFF/API de experiencia, (2) Servicio de Transferencias (el más rico en patrones), (3) Servicio de Auditoría, (4) Servicio de Notificaciones. Opcionalmente (5) Servicio de Cliente/360.

H-10 · "Otros diagramas requeridos" no está enumerado

El enunciado los menciona pero no los lista. Se deducen de las consideraciones (HA, DR, monitoreo, seguridad, onboarding, auditoría, costos). **Propuesta de diagramas complementarios**: 1. Diagrama de **despliegue en nube** (multi-AZ, multi-región, red y seguridad). 2. **Secuencia**: onboarding con reconocimiento facial. 3. **Secuencia**: autenticación (Authorization Code + PKCE, web y móvil). 4. **Secuencia**: transferencia interbancaria con saga y compensación. 5. **Secuencia**: notificación de movimiento originado en el core. 6. **Diagrama de patrones de auditoría + clientes frecuentes** (lo pide explícitamente el enunciado). 7. **Modelo de datos** y estrategia de persistencia por servicio. 8. **Diagrama de DR** (estrategia, RTO/RPO, conmutación). 9. **Diagrama de observabilidad** (métricas, trazas, logs, alertas). 10. **Vista de seguridad/zonas de red** (defensa en profundidad). 11. **Mapa de capacidades de negocio** alineado al Service Landscape de BIAN (ver H-15). 12. **Roadmap de implantación** por fases.

H-11 · Datos no proporcionados que condicionan el diseño

No se indican: número de clientes, transacciones por segundo, SLA objetivo, ventanas de mantenimiento del core, si el core es mainframe o paquete, si ya existe un bus de eventos, ni el presupuesto concreto. **Resolución propuesta:** declarar un **cuadro de supuestos dimensionales** explícito (ver §4) y diseñar sobre él. Un diseño sin cifras no se puede dimensionar ni costear, y los criterios 8, 9 y 14 exigen ambas cosas.

H-12 · Tensión estructural: "baja latencia" + "desacoplamiento" + core legacy

El core bancario es, casi con seguridad, un sistema síncrono, con capacidad limitada y ventanas de cierre. Pedirle "baja latencia" a un canal digital que consulta el core en cada pantalla es incompatible a escala. **Resolución propuesta:** separar lecturas de escrituras (**CQRS**): las consultas se sirven de una **réplica de lectura/proyección** alimentada por eventos o CDC del core, más caché distribuida; las escrituras (transferencias) sí van al core de forma síncrona y controlada. Se documentará explícitamente el compromiso de **consistencia eventual** con su SLO ("el movimiento aparece en el histórico en menos de N segundos").

H-13 · "Pagos entre cuentas propias e interbancarias": redacción imprecisa

Se interpretará como tres tipos de operación: (1) entre cuentas propias del mismo titular, (2) a terceros dentro del mismo banco, (3) interbancarias hacia otras entidades. Se documentará como supuesto, porque afecta al enrutamiento y a los controles antifraude.

H-14 · Riesgos de evaluación (errores que hundien la nota aunque el diseño sea bueno)

1. Usar *password grant* para el login (H-02).
2. Enviar biometría al servidor o exigir reconocimiento facial en cada acceso (H-03/H-04).
3. Un único diagrama de componentes (H-09).
4. Mezclar niveles de abstracción C4 (poner tecnologías concretas en el diagrama de contexto).
5. Notificaciones disparadas solo desde la app (H-06).
6. Transacción distribuida con la red interbancaria (H-07).
7. Auditoría escrita de forma síncrona en el camino crítico de la transacción.
8. Decisiones sin las **dos justificaciones** ni las alternativas evaluadas (lo pide explícitamente y es "MUY valorado").
9. No cuantificar nada: sin RTO/RPO, sin SLO, sin costos.
10. Ignorar el "mínimo 2" de notificaciones o el "mínimo 3" de servicios.
11. Guardar tokens de sesión en el almacenamiento del navegador en la SPA (H-25).
12. Dar por supuesta la nube sin justificarla como decisión (H-23).
13. Introducir una proyección de lectura sin declararla como réplica no autoritativa (H-18).
14. Ignorar la residencia de datos al elegir la región de nube (H-24).

H-15 · BIAN no lo pide el enunciado, pero sí la oferta laboral

El ejercicio exige **C4** y no menciona BIAN. Sin embargo, la oferta a la que opta el candidato lo pide explícitamente, y es probable que evaluador y ejercicio pertenezcan al mismo proceso. **Resolución adoptada:** incluir BIAN de forma **complementaria y justificada**, no sustitutiva. BIAN responde *qué* capacidades de negocio existen; C4 responde *cómo* se implementan. Puntos de inserción: (1) mapa de capacidades antes del C4 de contexto, (2) etiquetado de contenedores con su Service Domain, (3) ADR sobre el criterio de descomposición en microservicios, (4) anexo de trazabilidad servicio ↔ Service Domain ↔ Control Record ↔ API, (5) capítulo de extensibilidad futura. **Riesgo controlado:** no se adopta la nomenclatura literal de las Semantic APIs (verbosa); BIAN se usa como criterio de fronteras y vocabulario, con diseño REST legible y trazabilidad en metadatos.

H-16 · La organización y legibilidad del documento es un requisito explícito

"El documento debe estar bien organizado y ser fácil de leer". En 60-70 páginas exige: portada, índice navegable, numeración de figuras y tablas, **resumen ejecutivo** para lector no técnico, glosario de siglas, control de versiones y matriz de trazabilidad requisito→sección. Es un entregable con requisitos propios, no una cortesía.

H-17 · "Protocolos" es una categoría de decisión nombrada literalmente

La recomendación MUY valorada enumera "patrones, tecnologías, componentes, **protocolos**", y el C4 de componentes exige "protocolos de comunicación **con seguridad**". **Resolución:** tabla dedicada de decisiones de protocolo (REST vs gRPC por tramo, TLS 1.3, mTLS este-oeste, OIDC, protocolo del bus de eventos, webhooks), cada una con dos justificaciones y alternativas. **Regla asociada:** "cada decisión arquitectónica" significa *cada una*. Catálogo numerado ADR-01..ADR-nn (estimadas 30-40) con verificación final de que ninguna queda sin sus dos justificaciones y sus alternativas.

H-18 · "TODA la información del cliente se tomará de 2 sistemas" es una restricción fuerte

Si se introduce una proyección de lectura (CQRS) o caché, un evaluador riguroso puede interpretar que se creó un tercer origen de datos, violando la restricción. **Resolución:** declarar explícitamente que proyección y caché son **réplicas derivadas y no autoritativas** del Core y del sistema complementario, con su mecanismo de invalidación, su origen y su SLO de frescura. Sin esa declaración, el diseño *parece* contradecir el enunciado.

H-19 · La notificación es obligación normativa, no una funcionalidad de conveniencia

Al derivar de una norma exige: **evidencia probatoria** (demostrar ante el regulador que se notificó, cuándo y por qué canal), garantía de entrega con reintentos, conmutación entre los ≥ 2 proveedores y política definida si fallan todos. "Sistemas externos **o propios**" permite combinación (push propio + SMS/email de terceros), opción que se adopta por resiliencia y coste.

H-20 · Onboarding: qué se diseña y qué se integra (revisado)

Formulación inicial descartada: se planteó como disyuntiva "¿se diseña o se consume?". Es una falsa dicotomía; el enunciado y los criterios contienen la respuesta.

Análisis literal: "Tenga en cuenta que el sistema de Onboarding ... usa reconocimiento facial, por tanto, su arquitectura deberá considerarlo". El presente de indicativo describe un hecho dado; "considerarlo" no es "construirlo"; y "puede recomendar herramientas de la industria que realicen estas tareas" repite el patrón del IdP (capacidad de terceros).

Evidencia decisiva: el criterio de calificación 11 se titula "**Arquitectura de Integración con Onboarding**", no "Arquitectura de Onboarding". Lo evaluado es la **integración**.

Argumento arquitectónico convergente: el onboarding no es exclusivo del canal digital (también ocurre en oficina y web). Incluirlo dentro del sistema de banca por internet acoplaría una capacidad corporativa a un canal, en contra del criterio 3 y del RNF-09. En BIAN mapea a capacidades de ciclo de vida de cliente y autenticación de parte, no a capacidades de canal.

Resolución adoptada — tres piezas separadas en el C4 de contexto:

Pieza	Ubicación	Motivo
Plataforma de Onboarding Digital	Sistema del banco, adyacente y fuera de la frontera del sistema en alcance	Capacidad corporativa reutilizable por todos los canales
Proveedor de verificación de identidad (prueba de vida, documento, cotejo facial)	Sistema externo	El enunciado invita a recomendar herramientas de industria
IdP corporativo	Sistema del banco, adyacente	Establecido por el enunciado

Se diseña **en detalle la integración**: invocación desde la app móvil, verificación contra el proveedor, **provisión de la identidad en el IdP** al completarse y notificación al Core para el alta del cliente.

Cobertura de la lectura alternativa: se incluirá además una **vista de componentes de la plataforma de onboarding** con nota explícita "*se detalla para claridad del flujo; su construcción queda fuera del alcance de este proyecto*", de modo que ambas interpretaciones queden cubiertas sin contradicción.

H-21 · "Todas las acciones del cliente" incluye las consultas: problema de volumen

Auditar toda acción, incluidas consultas de saldo y movimientos, supone **decenas de millones de eventos diarios** con los supuestos de dimensionamiento. Condiciona tecnología de persistencia, particionado, retención y coste. **Impacto:** criterios 7, 9 y 12 simultáneamente. Se dimensiona explícitamente y se propone segmentación por criticidad del evento.

H-22 · El enunciado está redactado con el vocabulario de los pilares de AWS Well-Architected

"Alta disponibilidad, seguridad, **excelencia operativa**, baja latencia (eficiencia del rendimiento), manejo de costos" son cinco de sus seis pilares. **Resolución:** estructurar los capítulos transversales sobre los pilares del Well-Architected Framework, aplicando además su **Financial Services Industry Lens**.

H-23 · La nube es opcional según el enunciado

"**Si lo considera necesario**, su arquitectura puede contener elementos de infraestructura en nube". Darla por supuesta incumple la recomendación estrella. **Resolución:** ADR dedicado "Modelo de despliegue: nube pública vs on-premise vs híbrido", con dos justificaciones y alternativas evaluadas.

H-24 · Residencia de datos: no existe región de AWS en Ecuador

Cualquier despliegue implica **transferencia internacional de datos personales**, con requisitos propios bajo la Ley Orgánica de Protección de Datos Personales. La elección de región pasa a ser una decisión **jurídica además de técnica**, en tensión directa con el requisito de baja latencia (RNF-o8). **Resolución:** ADR específico de selección de región evaluando latencia medida hacia Ecuador, marco legal de transferencia internacional, coste y disponibilidad de servicios; más medidas compensatorias (red de distribución de contenido y puntos de presencia, cifrado con claves gestionadas por la entidad, clasificación de datos y minimización de lo que cruza frontera).

H-25 · Custodia de credenciales en los frontales

Una SPA **no debe almacenar tokens en el navegador** por exposición a ataques de scripting; el patrón correcto es un **BFF que custodia el token** y expone cookie `httpOnly + SameSite + Secure`. La app móvil es **cliente público** (sin secreto), lo que hace PKCE obligatorio y aconseja *device binding* con almacenamiento en enclave seguro. **Impacto:** criterios 6 y 10.

H-26 · Los datos biométricos son categoría sensible

El reconocimiento facial implica consentimiento explícito e informado, minimización, política de retención de la plantilla biométrica, cifrado reforzado y registro de actividades de tratamiento. Técnicamente, la prueba de vida se ampara en el estándar de **detección de ataques de presentación (ISO/IEC 30107)**. **Impacto:** criterios 11 y 13.

H-27 · Elementos que faltaban en el esbozo de arquitectura

Criterio	Elemento incorporado
5 · Servicios externos	Screening de listas de sanciones en el flujo de transferencia (obligación PLAFT/UAFE)
10 · Autenticación	Autenticación reforzada por operación (step-up) según monto y perfil de riesgo, no solo al iniciar sesión
6 · Móvil	Fijado de certificado, detección de dispositivo comprometido y protección anti-manipulación
6 · Front-end	Arquitectura interna de la SPA, evaluando micro-frontends con su trade-off

4. Supuestos propuestos (a validar)

ID	Supuesto	Justificación
SUP-01	BP es un banco universal latinoamericano de tamaño medio-grande	Coherente con el enunciado; se detallará el marco normativo del país elegido + estándares internacionales
SUP-02	3.000.000 de clientes, 1.200.000 usuarios digitales activos mensuales	Permite dimensionar y costear
SUP-03	Pico de 1.500 peticiones/s en el canal; 350 transferencias/s en pico	Base para autoescalado y pruebas de carga
SUP-04	El core es un paquete bancario con APIs limitadas y ventana de cierre diario	Justifica CQRS, caché y stand-in
SUP-05	SLA del canal: 99,95 % mensual; RTO 15 min / RPO 0 para transaccional	Base de HA y DR
SUP-06	El IdP corporativo es un producto configurable (se evaluarán alternativas)	Restricción del enunciado

ID	Supuesto	Justificación
SUP-07	Nube: una sola, con dos regiones (principal + DR)	Requisito de baja latencia y DR
SUP-08	Alcance: canal digital; no se rediseña el core ni la red de pagos	Delimita el sistema en el C4 de contexto

5. Mejoras incorporadas sobre el diseño convencional

El diseño se contrastó con las prácticas de los operadores de banca digital a escala. De ese contraste se incorporan **cinco mejoras**, formuladas como patrones con catálogo formal: lo que se adopta es la solución probada, no el nombre de quien la probó.

#	Diseño inicial previsto	Mejora incorporada	Criterio que refuerza
M-01	Auditoría append-only con un solo instante	Auditoría bitemporal : instante de ocurrencia + instante de registro. Permite reconstruir qué mostró el sistema en un momento dado, incluso con reproceso o llegada tardía de movimientos (ligado a H-06)	12 · Auditoría
M-02	Multi-AZ activo-activo con autoescalado	Arquitectura celular : particionado en celdas por subconjunto de clientes para acotar el radio de impacto. Documentado en AWS Well-Architected. <i>Acotado a servicios críticos del camino transaccional para no disparar coste y complejidad</i>	14 · HA y tolerancia a fallos
M-03	App multiplataforma con pantallas compiladas	Server-Driven UI en flujos de alta rotación (campañas, avisos, pasos de onboarding): permite cambiar flujos sin depender del ciclo de publicación en tiendas	6 · Front-end y móvil
M-04	Caché y CQRS en backend	Interfaz optimista y consulta offline-first en el cliente: ataca la latencia percibida sin coste adicional de infraestructura	6 y 9 · Front-end y costos
M-05	Capítulo normativo descriptivo	Cumplimiento como código : controles regulatorios traducidos a políticas verificadas automáticamente en el pipeline (cifrado, residencia, retención, ausencia de datos personales en logs)	13 y 6 · Normativa y excelencia operativa

Descartes conscientes

Práctica	Motivo del descarte
Bases de datos y lenguajes poco convencionales	Defendible técnicamente, irresponsable organizativamente: la arquitectura debe ser operable por el equipo existente
Construir un ledger propio	Fuera de alcance: el enunciado establece que el core aporta movimientos y productos
Migración completa a stack nativo de nube	El ejercicio pide integrar el core, no reemplazarlo (H-12)

6. Decisiones de alcance adoptadas

#	Decisión	Valor acordado
D-01	Marco normativo	Ecuador (COMF, normativa SB de riesgo operativo y seguridad de canales, LOPDP, Ley de Comercio Electrónico, UAPE/PLAFT, SPI del BCE) + capa internacional transversal (ISO 27001/27002, PCI-DSS, NIST SP 800-63, OWASP ASVS y API Top 10) + tabla de equivalencias regionales (Colombia SFC, Perú SBS, UE PSD2/DORA)
D-02	Nube	AWS
D-03	Diagramas	SVG embebido en el PDF + ficheros .drawio editables como anexo
D-04	Extensión	Exhaustivo, ~60-70 páginas
D-05	Idioma	Español
D-06	BIAN	Incluido de forma complementaria según H-15

#	Decisión	Valor acordado
D-07	Autor en portada	<i>Pendiente</i>
D-08	Referencias de mercado	No se citan entidades por su nombre (neobancos u otros). Su aporte se incorpora como patrones y tecnologías validadas , justificadas por su catálogo formal y por su trade-off, nunca por argumento de autoridad

Regla de justificación (derivada de D-08)

Toda decisión se sostiene sobre tres pilares y **ninguno es una marca**: 1. **Fundamento teórico**: el patrón, su catálogo de referencia y las propiedades que aporta. 2. **Trade-off explícito**: mínimo dos justificaciones y las alternativas evaluadas con su motivo de descarte. 3. **Verificabilidad**: el SLO o la métrica con la que se validará la decisión, y la madurez del patrón (existencia de servicio gestionado equivalente en la nube elegida).

Las referencias de mercado se reservan para la **defensa oral**, donde sí aportan amplitud, no para el documento evaluado por rúbrica.

Regla de rigor sobre normativa

Se citan los instrumentos por su **nombre y contenido**; los números de resolución solo donde hay certeza, con nota de "verificar vigencia contra la codificación actual". Inventar referencias normativas sería un defecto grave en un documento profesional.

Capítulo 2 · Contexto, drivers y escenarios de calidad

Documento de trabajo. Base cuantitativa sobre la que se sostienen las decisiones de las fases siguientes.

1. Contexto de negocio

BP es una entidad financiera que opera un núcleo bancario consolidado y un sistema complementario de información de clientes. Su canal digital actual no cubre las necesidades de autoservicio de la base de clientes, lo que genera tres problemas de negocio:

Problema	Consecuencia
Dependencia de canales atendidos para operaciones simples	Coste por transacción elevado y saturación de oficinas y centro de contacto
Incorporación de clientes exclusivamente presencial	Fricción en la captación y pérdida de oportunidades frente a competidores digitales
Notificación de movimientos no sistematizada	Riesgo de incumplimiento normativo y exposición ante reclamaciones

1.1 Objetivos de negocio

ID	Objetivo	Indicador asociado
OBJ-01	Habilitar el autoservicio de consulta y transaccionalidad en canal digital	% de transacciones monetarias originadas en canal digital
OBJ-02	Permitir la vinculación remota de nuevos clientes desde el móvil	Nº de altas digitales completadas / mes y tasa de abandono del proceso
OBJ-03	Cumplir la obligación normativa de notificación de movimientos	% de movimientos notificados con evidencia verificable
OBJ-04	Reducir el coste de servicio por cliente	Objetivo: $\leq 0,06$ USD de infraestructura por usuario digital activo al mes , equivalente a ~108.000 USD/mes para la base prevista, incluyendo entorno de continuidad
OBJ-05	Disponer de una plataforma extensible para nuevas capacidades	Tiempo de incorporación de una nueva capacidad de negocio

1.2 Partes interesadas

Actor	Interés principal	Impacto en la arquitectura
Cliente persona natural	Disponibilidad, rapidez, confianza	Latencia percibida, continuidad de servicio, seguridad
Negocio / Producto	Time-to-market de nuevas funciones	Desacoplamiento y extensibilidad (RNF-09)
Riesgo y Cumplimiento	Trazabilidad y cumplimiento normativo	Auditoría, retención, residencia de datos
Seguridad de la Información	Superficie de ataque y control de accesos	Autenticación, cifrado, segmentación
Operaciones / TI	Operabilidad y coste	Observabilidad, auto-recuperación, costos
Regulador	Evidencia de cumplimiento	Auditoría probatoria, notificación, continuidad
Área de Core Bancario	Preservar la estabilidad del núcleo	Control estricto de la carga inducida sobre el Core

2. Alcance

2.1 Dentro del alcance

- Aplicación web de página única (SPA) y aplicación móvil multiplataforma.
- Capa de experiencia (BFF por canal) y capa de integración con API Gateway.
- Microservicios de dominio del canal: consulta de cliente, consulta de movimientos, transferencias y pagos, notificaciones, auditoría, preferencias y frecuentes, control de límites y riesgo transaccional.

- Proyección de lectura y caché como **réplicas derivadas no autoritativas** (H-18).
- Integración con: Core, sistema complementario de cliente, IdP corporativo, plataforma de onboarding, proveedores de notificación y red de pagos interbancarios.
- Infraestructura de nube, observabilidad, continuidad y seguridad del canal.

2.2 Fuera del alcance

Elemento	Motivo
Construcción o modificación del Core bancario	El enunciado lo establece como sistema existente proveedor de datos
Construcción del sistema complementario de cliente	Ídem
Construcción del producto de identidad (IdP)	El enunciado indica que existe y solo se configura
Construcción de la plataforma de onboarding	El criterio 11 evalúa la integración , no su diseño interno (H-20)
Motor de verificación biométrica	Capacidad de proveedor especializado
Red de pagos interbancarios	Infraestructura del banco central
Canales presenciales, cajeros y tarjetas	No mencionados en el enunciado

2.3 Frontera del sistema

El sistema "Banca por Internet BP" se define como el conjunto de aplicaciones de canal, capa de integración y microservicios de dominio que dan servicio a los clientes a través de web y móvil. Todo lo demás son **sistemas adyacentes** (del propio banco) o **sistemas externos** (terceros).

3. Supuestos dimensionales con memoria de cálculo

Los supuestos se declaran explícitamente porque el enunciado no aporta volúmenes y sin ellos no es posible dimensionar, definir SLOs ni estimar costos (H-11). Las cifras son coherentes entre sí y trazables; cualquier ajuste posterior se propaga de forma proporcional.

3.1 Base de usuarios

Magnitud	Valor	Derivación
Clientes totales	3.000.000	Supuesto base: entidad universal de tamaño grande
Usuarios digitales activos mensuales	1.800.000	60 % de penetración digital
Usuarios activos diarios	600.000	33 % de los activos mensuales (ratio habitual en banca)
Sesiones diarias	900.000	1,5 sesiones por usuario activo y día
Acciones por sesión	8	Autenticación, posición, movimientos, navegación
Acciones diarias totales	7.200.000	900.000×8

3.2 Carga sobre el canal

Magnitud	Valor	Derivación
Llamadas a API diarias	~20.000.000	~2,8 llamadas por acción
Media sostenida	~230 req/s	20 M / 86.400 s
Pico en hora punta	~1.500 req/s	Factor 6,5× sobre la media; concentración en horario laboral
Transferencias diarias (día normal)	~196.000	$1,8 \text{ M usuarios} \times 2,4 \text{ transferencias/mes} \div 22 \text{ días hábiles}$
Reparto por tipo	65 % internas / 35 % interbancarias	Rutas, SLA y coste distintos por tipo
Media de transferencias	~2,3/s	$196.000 / 86.400 \text{ s}$
Transferencias en día de nómina	~550.000	$2,75 \times$ un día normal; 2 o 3 días al mes
Concentración en ventana 08:00–10:00	35 % del día	$\sim 192.000 \text{ operaciones en } 7.200 \text{ s} \approx 27/\text{s sostenidos}$

Magnitud	Valor	Derivación
Pico de diseño	80/s durante 5 min	24.000 operaciones = 4,4 % del día de nómina. Se dimensiona a 100/s con margen
Altas digitales diarias	2.000	Objetivo de captación digital; pico de 250/hora

Verificación de coherencia: $80/s \times 300 s = 24.000$ operaciones, muy por debajo del total diario de 550.000. Toda cifra de pico de esta sección se ha comprobado contra el volumen diario correspondiente.

3.3 Volumen de auditoría (H-21)

Magnitud	Valor	Derivación
Eventos de auditoría diarios	~10.000.000	7,2 M acciones de cliente + eventos de sistema y seguridad
Tamaño medio por evento	~1 KB	Cabecera, identidad, contexto, resultado
Volumen diario	~10 GB/día	
Volumen anual	~3,6 TB/año	
Volumen con retención de 7 años	~25 TB	Retención conservadora para obligación probatoria
Escritura sostenida en horario	~210 eventos/s	60 % del volumen en 8 horas
Pico de escritura	~1.000 eventos/s	

Consecuencia arquitectónica: este volumen descarta una base de datos relacional convencional como único destino de auditoría y obliga a segmentar por criticidad del evento, con almacenamiento por niveles (caliente consultable / frío probatorio).

3.4 Notificaciones (H-06)

Magnitud	Valor	Derivación
Movimientos diarios notificables del banco	~6.000.000	Incluye movimientos originados fuera del canal digital
Media sostenida	~70 notificaciones/s	
Pico	~500 notificaciones/s	Concentración en horas comerciales

3.5 Ventanas y disponibilidad de sistemas adyacentes

Sistema	Disponibilidad asumida	Restricción operativa
Core bancario	99,5 %	Ventana de cierre diario 23:00–01:30; capacidad limitada de conexiones concurrentes
Sistema complementario de cliente	99,0 %	Latencia superior; no crítico para la operación
Red de pagos interbancarios	99,5 %	Horarios de corte; operación por ciclos
Proveedores de notificación	99,0 % cada uno	Cuotas de envío y límites de tasa
IdP corporativo	99,9 %	Crítico: sin él no hay acceso

4. Drivers arquitectónicos

Factores que condicionan el diseño, ordenados por influencia.

ID	Driver	Origen	Implicación
DRV-01	El Core es el sistema de registro y no puede absorber la carga del canal	H-12, §3.5	Separación lectura/escritura con proyección derivada y caché
DRV-02	La notificación es obligación normativa con carga probatoria	H-06, H-19	Flujo dirigido por eventos del Core, con evidencia y conmutación entre proveedores

ID	Driver	Origen	Implicación
DRV-03	Toda acción del cliente debe quedar auditada	RF-09, H-21	Auditoría asíncrona, inmutable, bitemporal y dimensionada para decenas de millones de eventos
DRV-04	No existe infraestructura de nube pública con presencia en el país	H-24	Condicionado a la decisión de modelo de despliegue (ADR de la Fase 2, H-23). De optarse por nube pública, la elección de región es decisión jurídica además de técnica, con compensación mediante red de distribución y cifrado con claves gestionadas por la entidad
DRV-05	La identidad se establece fuera del canal (onboarding) y se consume vía IdP	H-20, H-03	Integración basada en provisión de identidad y propagación del nivel de aseguramiento
DRV-06	Las transferencias cruzan sistemas que no admiten transacción distribuida	H-07	Saga con compensación y estado explícito por operación
DRV-07	Los datos de cliente proceden únicamente de dos sistemas	H-18	Toda copia se declara réplica derivada no autoritativa
DRV-08	La plataforma debe admitir capacidades futuras sin rediseño	RNF-09	Descomposición por capacidad de negocio y contratos versionados
DRV-09	Existe presupuesto, pero el coste se evalúa	H-08	Dimensionamiento justificado y optimización explícita
DRV-10	Los datos biométricos son categoría sensible	H-26	Minimización, consentimiento, retención acotada y cifrado reforzado

5. Atributos de calidad: escenarios medibles

Formato de escenario de calidad (fuente · estímulo · artefacto · entorno · respuesta · **medida**). Son los requisitos arquitectónicamente significativos que gobiernan las decisiones de la Fase 2.

Disponibilidad y tolerancia a fallos

ASR-01 · Pérdida de una zona de disponibilidad Una zona de disponibilidad completa deja de responder durante la operación normal. El sistema continúa atendiendo peticiones desde las zonas restantes. **Medida:** sin interrupción perceptible; degradación de capacidad $\leq 33\%$; recuperación automática de capacidad en ≤ 5 min. **Disponibilidad objetivo del canal: 99,95 % mensual.**

ASR-02 · Indisponibilidad del Core durante la ventana de cierre Entre las 23:00 y la 01:30 el Core no admite operaciones. Un cliente consulta sus movimientos e intenta una transferencia. **Medida:** la consulta se sirve íntegramente desde la proyección con indicación de fecha de corte; la transferencia se acepta en modo diferido con confirmación posterior, o se rechaza con mensaje explícito según política de negocio. **Cero errores técnicos expuestos al cliente.**

ASR-03 · Caída de un proveedor de notificaciones Uno de los dos proveedores deja de responder o supera su cuota. **Medida:** conmutación automática al proveedor alternativo en ≤ 30 s; ninguna notificación perdida; evidencia registrada del canal efectivamente utilizado.

ASR-04 · Degradación del sistema complementario de cliente El sistema complementario responde con latencia superior a 3 s o no responde. **Medida:** la funcionalidad principal permanece disponible con los datos básicos del Core; el detalle se marca como no disponible temporalmente. **Ninguna pantalla falla completamente por esta causa.**

Rendimiento

ASR-05 · Consulta de movimientos en hora pico Con 1.500 peticiones/s, un cliente solicita el histórico de movimientos de los últimos 90 días. **Medida:** **p95 ≤ 500 ms, p99 ≤ 1 s** medido en el borde del sistema.

ASR-06 · Frescura de la información replicada (H-18) Se registra un movimiento en el Core. **Medida:** visible en el canal en **≤ 60 s (p95) y ≤ 5 min (p99)**; la interfaz muestra la marca temporal de actualización.

ASR-07 · Pico de transferencias en día de nómina Se alcanzan 120 transferencias/s durante 30 minutos. **Medida:** **p95 ≤ 2 s** para transferencia entre cuentas propias; sin rechazos por saturación; escalado automático

completado en ≤ 3 min.

ASR-08 · Notificación de un movimiento Se produce un movimiento en cualquier canal del banco. **Medida:** notificación entregada en ≤ 2 min (p95); reintentos durante 24 h; evidencia probatoria persistida en todos los casos.

Seguridad

ASR-09 · Operación de importe elevado Un cliente autenticado inicia una transferencia que supera su límite habitual o presenta indicadores de riesgo. **Medida:** se exige autenticación reforzada adicional antes de ejecutar; la decisión y sus factores quedan registrados; **ninguna operación sensible se ejecuta sin el nivel de aseguramiento requerido.**

ASR-10 · Requerimiento probatorio del regulador Se solicita reconstruir toda la actividad de un cliente en una fecha concreta, incluida la información que el sistema le mostró. **Medida:** reconstrucción completa en ≤ 4 h, con registro inmutable y verificable, incluyendo instante de ocurrencia e instante de registro (M-01).

Continuidad

ASR-11 · Desastre en el emplazamiento principal El emplazamiento principal de procesamiento queda inoperativo (región de nube o centro de datos, según el modelo de despliegue que se decida en la Fase 2). **Medida:** **RTO ≤ 15 min** y **RPO = 0** para información transaccional y de auditoría; **RPO ≤ 5 min** para proyecciones de lectura, reconstruibles desde el origen.

Operación y evolución

ASR-12 · Despliegue de una nueva versión Se despliega una versión de un servicio de dominio en horario laboral. **Medida:** **cero interrupción** del servicio; capacidad de reversión en ≤ 5 min; ningún mensaje en curso perdido ni duplicado en su efecto.

ASR-13 · Recuperación automática ante instancia defectuosa Una instancia deja de superar sus comprobaciones de salud. **Medida:** retirada del balanceo en ≤ 30 s y reemplazo automático en ≤ 3 min, sin intervención humana.

ASR-14 · Incorporación de una nueva capacidad de negocio Negocio solicita añadir una capacidad nueva que consume datos existentes. **Medida:** sin modificar los servicios existentes; consumo mediante contratos y eventos ya publicados; **entrega en ≤ 1 trimestre.**

5.bis Política de retención de información

La retención es materia normativa y condiciona el dimensionamiento y el coste. Se fija por tipo de dato:

Tipo de información	Retención en acceso inmediato	Retención total	Fundamento
Registro de auditoría de acciones del cliente	24 meses	7 años	Obligación probatoria ante el regulador
Evidencia de notificación entregada	24 meses	7 años	Carga probatoria del cumplimiento (H-19)
Contenido de la notificación	12 meses	12 meses	Minimización de datos
Proyección de movimientos	24 meses	24 meses	El histórico anterior se obtiene del Core bajo demanda
Datos biométricos	No se conservan en el canal	Según consentimiento y contrato con el proveedor	Categoría sensible: minimización estricta (H-26)
Registros técnicos de operación	90 días	12 meses archivados	Diagnóstico e investigación de incidentes
Datos de sesión y tokens	Vigencia del token	No se persisten	Superficie de ataque mínima (H-25)

Integridad transaccional

ASR-15 · Doble envío de una operación monetaria Un cliente pulsa dos veces el botón de envío, o la aplicación reintenta por pérdida de conectividad tras haber enviado la petición. **Medida:** se ejecuta **exactamente una**

transferencia; la petición repetida devuelve el mismo resultado que la original; ambas peticiones quedan registradas en auditoría y son distinguibles entre sí.

Monitoreo y operación

ASR-16 · Detección de degradación de servicio Un servicio de dominio comienza a degradarse: la latencia supera el objetivo o la tasa de error crece. **Medida:** detección automática en **≤ 2 min**; notificación al equipo de guardia en **≤ 3 min**; traza correlacionada y guía de actuación accesibles desde la propia alerta. Ninguna alerta sin acción asociada.

Seguridad

ASR-17 · Intento masivo de acceso con credenciales comprometidas Se recibe un volumen anómalo de intentos de autenticación con credenciales obtenidas de filtraciones externas. **Medida:** contención automática por ralentización progresiva y bloqueo selectivo; **ninguna cuenta comprometida por este vector**; alerta al centro de operaciones de seguridad en **≤ 5 min**; registro completo para investigación.

ASR-18 · Indisponibilidad del producto de identidad El servicio de identidad corporativo deja de responder. **Medida:** los clientes con sesión vigente **mantienen el acceso de consulta** hasta la expiración natural de su credencial; las nuevas autenticaciones muestran un mensaje explícito de indisponibilidad temporal, sin errores técnicos; **cero pérdida de información**; recuperación automática del servicio en cuanto el proveedor restablece.

Rendimiento de la autenticación

ASR-19 · Latencia del inicio de sesión Un cliente inicia sesión en hora punta. Es la operación más frecuente del canal. **Medida:** **p95 ≤ 1,5 s** desde la acción del usuario hasta la primera pantalla con información útil, incluyendo la redirección al servicio de identidad.

6. Restricciones

ID	Restricción	Origen
RES-01	El Core y el sistema complementario son las únicas fuentes de información de cliente	Enunciado (H-18)
RES-02	La autenticación se resuelve con un producto de identidad existente, configurable	Enunciado
RES-03	La capa de integración debe incluir un API Gateway	Enunciado
RES-04	Deben existir al menos dos sistemas de notificación	Enunciado
RES-05	El modelo de arquitectura debe expresarse en C4 hasta el nivel de componentes	Enunciado
RES-06	Los datos personales quedan sujetos al régimen local de protección de datos, incluida la transferencia internacional	H-24, H-26
RES-07	La biometría no puede abandonar el dispositivo del cliente en el flujo de autenticación	H-04
RES-08	Compatibilidad mínima de los frontales: dos últimas versiones mayores de los navegadores de mayor uso; sistemas móviles con soporte de seguridad vigente del fabricante	Criterio 6 y política de seguridad: no dar soporte a plataformas sin parches de seguridad

7. Mapa de capacidades de negocio y alcance (BIAN)

Se emplea el modelo de referencia BIAN como criterio de delimitación de capacidades, previo a cualquier decisión técnica. Cada capacidad se clasifica según su relación con el proyecto.

Dominio de negocio	Capacidad (Service Domain)	Situación
Cliente	Directorio de datos de referencia de parte	Consumida (Core + sistema complementario)
Cliente	Autenticación de parte	Consumida (IdP) / Integrada (onboarding)

Dominio de negocio	Capacidad (Service Domain)	Situación
Cliente	Gestión del ciclo de vida del cliente	Adyacente (plataforma de onboarding)
Cuentas	Cuenta corriente y de ahorro: posición y movimientos	Consumida (Core) · proyección derivada en alcance
Pagos	Iniciación de pago	En alcance
Pagos	Ejecución de pago	Consumida (Core y red interbancaria)
Riesgo y cumplimiento	Evaluación de fraude	En alcance (control transaccional del canal)
Riesgo y cumplimiento	Cribado de listas restrictivas	Consumida (servicio corporativo)
Cliente	Contacto y correspondencia con el cliente	En alcance (orquestración) · Consumida (proveedores de envío)
Soporte de negocio	Registro de actividad y evidencia	En alcance (auditoría)
Productos	Catálogo y contratación de productos	Fuera de alcance — extensión futura
Préstamos	Originación y gestión de créditos	Fuera de alcance — extensión futura
Inversiones	Gestión de inversiones	Fuera de alcance — extensión futura

Las tres últimas filas materializan el requisito de extensibilidad (RNF-09, ASR-14): el mapa muestra explícitamente dónde encajarían las capacidades futuras sin rediseñar lo existente.

8. Riesgos iniciales del proyecto

ID	Riesgo	Probabilidad	Impacto	Mitigación prevista
RSG-01	El Core no soporta la carga inducida por el canal	Alta	Alto	Proyección derivada, caché y control de tasa hacia el Core
RSG-02	La transferencia internacional de datos personales no obtiene aprobación legal	Media	Alto	Evaluación jurídica temprana, minimización, cifrado con claves de la entidad
RSG-03	La latencia hacia la región elegida incumple el objetivo	Media	Medio	Medición previa, red de distribución de contenido, caché en el borde
RSG-04	El volumen de auditoría dispara el coste de almacenamiento	Media	Medio	Segmentación por criticidad y almacenamiento por niveles
RSG-05	Dependencia de un único proveedor de verificación biométrica	Media	Medio	Contrato con capacidad de sustitución; abstracción del proveedor tras una interfaz propia
RSG-06	Los horarios de corte de la red interbancaria generan expectativas erróneas en el cliente	Alta	Bajo	Comunicación explícita de fecha valor y estado en la interfaz
RSG-07	El producto de identidad es punto único de fallo: sin él no es posible autenticar a ningún cliente	Media	Muy alto	Exigir despliegue redundante al proveedor del servicio; sesiones vigentes que sobreviven a su caída; degradación explícita para nuevas autenticaciones; escenario ASR-18
RSG-08	El proveedor de verificación biométrica introduce un sesgo o una tasa de falso rechazo elevada	Media	Medio	Medición de tasas de aceptación y rechazo por segmento; vía alternativa de verificación asistida

9. Trazabilidad de esta fase

Requisito / hallazgo	Se atiende en
H-11 (faltan datos de dimensionamiento)	§3 completo
H-12 (latencia vs Core)	DRV-01, ASR-05, ASR-06
H-18 (réplica no autoritativa)	§2.1, DRV-07, ASR-06, RES-01
H-21 (volumen de auditoría)	§3.3, DRV-03, ASR-10
H-24 (residencia de datos)	DRV-04, RES-06, RSG-02, RSG-03
H-06 / H-19 (notificación normativa)	§3.4, DRV-02, ASR-03, ASR-08

Requisito / hallazgo	Se atiende en
H-20 (alcance del onboarding)	§2.2, §2.3, §7
RNF-09 (extensibilidad)	ASR-14, §7
Criterio 14 (HA y tolerancia a fallos)	ASR-01 a ASR-04, ASR-11
Criterio 15 (monitoreo)	ASR-12, ASR-13 (medidas verificables)

Capítulo 3 · Decisiones de plataforma y de canal (ADR-01 a ADR-13)

Formato: cada decisión incluye contexto, opciones evaluadas, decisión, **mínimo dos justificaciones teóricas**, consecuencias asumidas, criterio de verificación y trazabilidad a los escenarios de calidad de la Fase 1.

Criterio de citación: los productos, servicios, marcos de desarrollo, protocolos y estándares **se nombran explícitamente**, porque el enunciado exige justificar tecnologías concretas y los criterios 6 y 8 evalúan ese conocimiento. Lo que no se emplea como argumento es la referencia a otras entidades financieras: una decisión se sostiene por su fundamento y su contrapartida, nunca porque un tercero la haya adoptado.

Bloque A · Decisiones fundacionales

ADR-01 · Modelo de despliegue

Contexto. El enunciado plantea la nube como opcional ("si lo considera necesario"), por lo que el modelo de despliegue es una decisión que debe argumentarse y no presuponerse (H-23). Los condicionantes son: picos de carga con factor 6,5× sobre la media (ASR-05), necesidad de recuperación ante desastre con RTO ≤ 15 min (ASR-11), auto-recuperación sin intervención humana (ASR-13) y un Core que permanece en las instalaciones del banco.

Opciones evaluadas

Opción	A favor	En contra
Centro de datos propio	Control total; datos sin salir del país; sin transferencia internacional	Capacidad fija dimensionada al pico, ociosa el resto del tiempo; segundo centro para continuidad con coste prohibitivo; auto-recuperación y elasticidad a construir desde cero
Nube pública para toda la plataforma	Elasticidad, servicios gestionados, continuidad multi-región	El Core no es migrable en este alcance; exposición a transferencia internacional de datos
Híbrido: canal en nube pública, Core en instalaciones propias, conectividad privada	Elasticidad donde la carga es variable; el sistema de registro permanece donde está; continuidad viable	Dependencia de un enlace de comunicaciones; dos entornos que operar; latencia añadida hacia el Core

Decisión. Modelo **híbrido**: los componentes del canal se despliegan en nube pública; el Core y el sistema complementario permanecen en las instalaciones del banco; la comunicación entre ambos entornos se realiza por enlace privado dedicado con redundancia.

Justificación 1. Principio de elasticidad frente a demanda variable. El perfil de carga presenta una relación pico/media de 6,5× en el canal y de 35× en transferencias durante los días de nómina. Un dimensionamiento fijo obliga a pagar permanentemente la capacidad del pico; la capacidad elástica convierte ese coste fijo en variable, lo que es determinante para OBJ-04. **2. Principio de continuidad económicamente viable.** ASR-11 exige RTO ≤ 15 min. Replicar un segundo centro de datos con esa capacidad de conmutación supone duplicar la inversión en instalaciones; en nube pública, la capacidad de continuidad se contrata y solo se paga plenamente cuando se activa. **3. Delegación de responsabilidad operativa.** Los servicios gestionados trasladan al proveedor la operación de la infraestructura subyacente, lo que permite que un equipo reducido alcance los objetivos de auto-recuperación de ASR-13, difícilmente alcanzables con infraestructura propia sin una plantilla de operación mucho mayor.

Consecuencias. Se asume la transferencia internacional de datos personales, tratada en ADR-03. Se asume dependencia del enlace de comunicaciones, que se mitiga con doble circuito de operadores distintos y con la proyección de lectura que reduce la dependencia del Core en tiempo real (ADR-20). Se asume una curva de aprendizaje y un modelo operativo nuevo.

Verificación. Prueba de carga a 1.500 peticiones/s con escalado automático, medición del coste por usuario activo frente al objetivo de 0,06 USD/mes y ensayo de conmutación de continuidad con cronometraje del RTO.

Trazabilidad. H-23, H-08 · ASR-05, ASR-07, ASR-11, ASR-13 · DRV-09 · OBJ-04

ADR-02 · Proveedor de nube

Contexto. El enunciado admite AWS o Azure. La decisión condiciona el catálogo de servicios, el modelo de costes y la disponibilidad de talento.

Opciones evaluadas

Opción	A favor	En contra
AWS	Catálogo maduro para todos los requisitos del caso: EKS, API Gateway, MSK, Aurora PostgreSQL, ElastiCache, DynamoDB, S3 con Object Lock, KMS y CloudHSM; AWS Well-Architected Framework con Financial Services Industry Lens como marco de verificación; mayor base de profesionales certificados en la región	Curva de aprendizaje amplia por la propia extensión del catálogo
Azure	Integración natural si la entidad ya opera con Microsoft Entra ID y ofimática del mismo fabricante; equivalentes funcionales en AKS, API Management, Event Hubs, Azure SQL y Key Vault; acuerdos empresariales frecuentes en banca	Menor presencia de regiones en Sudamérica, relevante para ADR-03
Google Cloud	Fortaleza en datos y analítica; Apigee como producto de gestión de APIs	Menor presencia de regiones en Sudamérica; base de profesionales más reducida en banca local

Decisión. AWS, con diseño orientado a minimizar el acoplamiento al proveedor en las piezas críticas (ADR-06).

Justificación 1. Principio de adecuación del marco de verificación. El **AWS Well-Architected Framework** y su **Financial Services Industry Lens** proporcionan una lista de comprobación reconocida para los seis pilares de la arquitectura. Disponer de un marco de verificación externo permite auditar el diseño contra un referente y no contra el criterio del arquitecto. **2. Principio de disponibilidad de capacidades.** Todos los requisitos del caso tienen servicio gestionado nativo: **Amazon MSK** para mensajería persistente, **Aurora PostgreSQL Global Database** para replicación entre regiones, **S3 con Object Lock** para almacenamiento inmutable de retención prolongada y **AWS CloudHSM** para custodia de claves bajo control exclusivo de la entidad. Esto reduce el número de componentes que la entidad debe construir y operar. **3. Principio de reducción del riesgo de proyecto.** La mayor disponibilidad de profesionales con experiencia acreditada en la región reduce el riesgo de ejecución y de relevo del equipo, que es un riesgo de proyecto tan real como el técnico.

Consecuencias. Dependencia de proveedor, mitigada mediante orquestación de contenedores estándar (ADR-06), formatos abiertos de mensajería y datos, y ausencia de lógica de negocio en servicios propietarios. Se documenta un plan de salida como exige la buena práctica de externalización en el sector.

Verificación. Revisión del diseño contra el marco de buenas prácticas sectorial y estimación comparativa de coste frente a la alternativa.

Trazabilidad. H-22 · D-02 · Criterio 8

ADR-03 · Selección de región y residencia de datos

Contexto. No existe región de nube pública en el país (H-24), de modo que cualquier despliegue implica transferencia internacional de datos personales, sujeta al régimen local de protección de datos (RES-06). Simultáneamente, ASR-05 exige $p95 \leq 500$ ms y ASR-19 $p95 \leq 1,5$ s. **La decisión es jurídica además de técnica, y ambas dimensiones apuntan en direcciones distintas.**

Consideración técnica relevante. La latencia no depende de la distancia geográfica sino del trazado real de la infraestructura de comunicaciones. Las rutas de conectividad internacional del país discurren mayoritariamente hacia el norte del continente, por lo que un emplazamiento geográficamente más lejano puede ofrecer mejor latencia que uno más cercano. **Esta hipótesis debe medirse, no suponerse.**

Opciones evaluadas

Opción	Latencia	Encaje jurídico	Continuidad
sa-east-1 (São Paulo) como principal	Buena, a confirmar por medición	Favorable: la LGPD brasileña es afín a la LOPDP ecuatoriana, lo que simplifica la habilitación de la transferencia	Requiere segunda región para DR

Opción	Latencia	Encaje jurídico	Continuidad
us-east-1 (Norte de Virginia) o us-east-2 (Ohio) como principal	Potencialmente mejor: las rutas submarinas de Ecuador discurren hacia Panamá y Miami	Más exigente: requiere cláusulas contractuales y garantías adicionales de transferencia internacional	Amplia oferta de regiones y servicios
Regiones andinas más recientes del proveedor, si están disponibles al momento de implantar	La mejor previsible por proximidad y ruta	Favorable	Catálogo de servicios potencialmente incompleto en región nueva
Doble región activa simultánea	Máxima continuidad	Duplica la superficie jurídica	Coste muy superior; se descarta frente al modelo de espera templada de ADR de continuidad

Decisión. Región principal **sa-east-1 (São Paulo)** y región secundaria para continuidad **us-east-1 (Norte de Virginia)**, con **Amazon CloudFront** y **AWS Global Accelerator** para terminar las conexiones TLS en el punto de presencia más cercano al cliente y encaminar el tráfico por la red troncal del proveedor. La elección definitiva queda condicionada a una **campana de medición de latencia real desde las redes de los principales operadores del país** antes de la construcción; si en ese momento existe una región andina con catálogo suficiente, se reevalúa.

Justificación 1. **Principio de minimización del riesgo jurídico ante requisitos equivalentes.** Cuando dos alternativas satisfacen el requisito técnico, se elige la de menor exposición regulatoria. Un marco de protección de datos regional afín simplifica la base de legitimación de la transferencia internacional y reduce el riesgo de que el proyecto quede bloqueado por una objeción legal (RSG-02). 2. **Principio de separación entre latencia de red y latencia de aplicación.** La mayor parte de la latencia percibida procede del establecimiento de la conexión segura y de la entrega de contenido estático, no del procesamiento. **CloudFront** termina TLS en el punto de presencia más próximo y **Global Accelerator** encamina el resto por la red troncal del proveedor en lugar de por la red pública, lo que absorbe esa fracción con independencia de dónde resida el cómputo y reduce la sensibilidad de la decisión a la ubicación de la región. 3. **Principio de decisión basada en evidencia.** La hipótesis sobre el trazado de rutas debe validarse con medición antes de comprometer la arquitectura; una decisión de esta magnitud no puede apoyarse en una suposición geográfica.

Consecuencias. Se asume transferencia internacional, que obliga a: base de legitimación documentada ante la Superintendencia de Protección de Datos Personales, cifrado en reposo y en tránsito con **claves propias custodiadas en AWS CloudHSM** (modelo de clave gestionada por el cliente, de modo que el proveedor no puede descifrar), clasificación de datos con minimización de lo que cruza frontera, y evaluación de impacto previa. Se asume el coste de CloudFront y Global Accelerator, cuantificado en el bloque de costos.

Verificación. Medición de latencia desde redes de operadores locales hacia las regiones candidatas antes de la decisión final; validación jurídica de la base de transferencia; prueba de que ningún dato clasificado como restringido sale sin cifrado bajo claves de la entidad.

Trazabilidad. H-24 · RES-06 · RSG-02, RSG-03 · ASR-05, ASR-19 · DRV-04

ADR-04 · Estilo arquitectónico

Contexto. Los perfiles de carga de las distintas capacidades son muy dispares: consultas con picos de 1.500 peticiones/s frente a transferencias con 80 operaciones/s. Además, ASR-14 exige incorporar capacidades nuevas sin modificar las existentes y el criterio 3 evalúa segmentación de responsabilidades.

Opciones evaluadas

Opción	A favor	En contra
Monolito modular	Simplicidad operativa; transacciones locales; menor coste inicial	El escalado arrastra todo el conjunto aunque solo una capacidad lo necesite; un fallo compromete el proceso completo; despliegue acoplado entre equipos
Microservicios por capacidad de negocio	Escalado y despliegue independientes; aislamiento de fallos; evolución por dominio	Complejidad operativa y de datos distribuidos; requiere plataforma y observabilidad maduras
Funciones sin servidor para todo	Escalado a cero; coste por uso	Latencia de arranque en frío incompatible con ASR-19; gestión deficiente de conexiones persistentes hacia el Core

Decisión. Microservicios por capacidad de negocio para los servicios de dominio, con funciones sin servidor reservadas a adaptadores dirigidos por eventos y tareas programadas, donde el arranque en frío no afecta a la experiencia del cliente.

Justificación 1. **Principio de correspondencia entre unidad de escalado y perfil de carga.** Cuando las capacidades presentan perfiles de demanda que difieren en un orden de magnitud, agruparlas en una misma unidad de despliegue obliga a dimensionar el conjunto por el componente más exigente, con desperdicio proporcional a la diferencia. 2. **Principio de aislamiento de fallos.** La separación en procesos independientes con sus propios recursos impide que el agotamiento de un componente propague la indisponibilidad al resto, requisito directo de ASR-04, donde la degradación del sistema complementario no debe afectar a la funcionalidad principal. 3. **Principio de independencia evolutiva.** ASR-14 exige añadir capacidades sin tocar las existentes; esto solo es verificable si las unidades de despliegue y sus contratos son independientes.

Consecuencias. Se asume complejidad distribuida: consistencia eventual entre servicios (ADR-20), transacciones de negocio resueltas por compensación (ADR-24) y necesidad de trazabilidad distribuida (bloque de observabilidad). Se asume la necesidad de una plataforma común que evite que cada equipo resuelva lo transversal de forma distinta.

Verificación. Prueba de que el escalado de un servicio no altera la capacidad de los demás; ensayo de degradación del sistema complementario comprobando que la funcionalidad principal permanece (ASR-04).

Trazabilidad. ASR-04, ASR-07, ASR-14 · Criterios 3 y 4

ADR-05 · Criterio de descomposición en servicios

Contexto. Decidido el estilo (ADR-04), queda por definir **cuáles** son los servicios. El criterio de corte determina la estabilidad de las fronteras durante años y es lo que evalúa el criterio 3.

Opciones evaluadas

Criterio de corte	A favor	En contra
Por entidad de datos (un servicio por tabla o agregado)	Inmediato de derivar del modelo de datos	Produce servicios anémicos con fuerte acoplamiento entre sí; las fronteras siguen al esquema, que cambia a menudo
Por capa técnica (lectura, escritura, integración)	Homogéneo técnicamente	Ninguna capacidad de negocio queda completa en un servicio; todo cambio funcional atraviesa varios
Por estructura de equipos	Alineado con la organización actual	Consagra la estructura organizativa vigente en la arquitectura; cuando la organización cambia, la arquitectura queda desalineada
Por capacidad de negocio, contrastada con un modelo de referencia sectorial	Fronteras estables; vocabulario común con negocio; solapes y huecos detectables	Requiere conocer el modelo de referencia y un esfuerzo inicial de mapeo

Decisión. Descomposición **por capacidad de negocio**, delimitada con contextos acotados de diseño dirigido por el dominio y **contrastada contra el modelo de referencia sectorial de arquitectura bancaria**, que aporta un catálogo de capacidades discretas y no solapadas.

Justificación 1. **Principio de estabilidad de las fronteras.** Las capacidades de negocio de una entidad financiera —mantener una cuenta, iniciar un pago, autenticar a una parte— evolucionan mucho más despacio que su implementación tecnológica o que la estructura organizativa. Anclar las fronteras a lo más estable minimiza las reestructuraciones futuras. 2. **Principio de verificabilidad de la descomposición.** Contrastar contra un catálogo externo convierte "estos servicios me parecen razonables" en una afirmación comprobable: permite detectar dos servicios que cubren la misma capacidad, o una capacidad que nadie cubre. Sin referente externo, la descomposición no es auditable. 3. **Principio de lenguaje compartido.** Que el nombre del servicio coincida con el término que usa negocio elimina una capa de traducción permanente en el análisis, la priorización y el diagnóstico de incidencias.

Consecuencias. Se asume el esfuerzo de mapeo inicial y de mantenerlo. **No se adopta la nomenclatura literal de las especificaciones del modelo de referencia**, por su verbosidad; se conserva un diseño de interfaces legible con la correspondencia registrada como metadato, lo que preserva la trazabilidad sin degradar la experiencia de quien consume las interfaces.

Verificación. Anexo de trazabilidad servicio ↔ capacidad ↔ interfaz; comprobación de que ninguna capacidad en alcance queda sin dueño y ninguna está cubierta por dos servicios.

Trazabilidad. H-15 · RNF-09, ASR-14 · Criterios 3 y 4

ADR-06 · Plataforma de ejecución

Contexto. Decidido el estilo de microservicios, hay que elegir cómo se ejecutan y orquestan, atendiendo a ASR-13 (auto-recuperación) y al plan de salida exigido en externalización.

Opciones evaluadas

Opción	A favor	En contra
Amazon EKS (Kubernetes gestionado)	API estándar de Kubernetes: portable a AKS, GKE u OpenShift sin reescritura; ecosistema maduro de sondas de salud, HPA, KEDA y despliegue progresivo con Argo Rollouts	Mayor complejidad operativa; requiere competencia específica en el equipo
Amazon ECS con Fargate	Operación más sencilla; integración nativa con el resto del catálogo	API propietaria: el plan de salida exige reescribir los descriptores de despliegue
AWS Lambda exclusivamente	Sin infraestructura que gestionar; escalado a cero	Arranque en frío incompatible con ASR-19; límite de tiempo de ejecución; gestión deficiente del agrupamiento de conexiones hacia el Core
EC2 con Auto Scaling Groups	Control total sobre el sistema operativo	Auto-recuperación, despliegue progresivo y descubrimiento de servicios a construir manualmente

Decisión. **Amazon EKS** para los servicios de dominio, con **Karpenter** para el aprovisionamiento de nodos y **KEDA** para el escalado de los consumidores de eventos según el retraso de la cola; **AWS Lambda** para adaptadores dirigidos por eventos y procesos programados donde el arranque en frío no afecta a la experiencia del cliente.

Justificación 1. **Principio de portabilidad como mitigación de la dependencia de proveedor.** La buena práctica de externalización en el sector financiero exige un plan de salida demostrable. La API de Kubernetes es un estándar de facto soportado por todos los grandes proveedores, de modo que los manifiestos y los gráficos de Helm son trasladables sin reescritura. Esto convierte el plan de salida en algo realista y no en un documento formal. 2. **Principio de auto-recuperación declarativa.** El modelo de estado deseado de Kubernetes —el controlador compara continuamente lo declarado con lo existente y corrige la diferencia— proporciona de forma nativa, mediante sondas de vivacidad y disponibilidad, la sustitución automática de instancias defectuosas que exige ASR-13, sin construir lógica de supervisión propia. 3. **Principio de adecuación de la herramienta a la carga.** Las cargas dirigidas por eventos, esporádicas y sin requisito de latencia interactiva, no justifican capacidad reservada; asignarlas a ejecución bajo demanda reduce coste sin comprometer ningún escenario de calidad.

Consecuencias. Se asume la necesidad de competencia en orquestación de contenedores y de una plataforma interna que estandarice lo transversal. Se asume un coste base superior al de las funciones bajo demanda para cargas de bajo volumen, compensado por la previsibilidad de la latencia.

Verificación. Ensayo de sustitución automática de instancia con cronometraje contra ASR-13; prueba de despliegue sin interrupción contra ASR-12.

Trazabilidad. ASR-12, ASR-13 · Criterios 8 y 14

Bloque B · Frontales

ADR-07 · Tecnología de la aplicación web

Contexto. El enunciado exige una aplicación de página única. La entidad tiene como objetivo explícito el gobierno de estándares entre equipos, lo que hace relevante el grado de opinión del marco de desarrollo.

Opciones evaluadas

Opción	A favor	En contra
Angular con TypeScript	Marco integral y opinado: enrutado, formularios, cliente HTTP, inyección de dependencias y modularidad vienen resueltos y son iguales en todos los equipos; TypeScript nativo; versiones de soporte extendido con calendario publicado; RxJS para flujos asíncronos complejos	Curva de aprendizaje mayor; más código inicial; menor base de profesionales que la alternativa
React con TypeScript	Mayor disponibilidad de profesionales; ecosistema muy amplio; Module Federation maduro para micro-frontends	Es una biblioteca, no un marco: enrutado, estado y formularios se eligen por separado, y esa elección debe gobernarse equipo a equipo para evitar divergencia
Vue con TypeScript	Curva de aprendizaje suave; buen rendimiento	Base de profesionales menor en banca corporativa; ecosistema empresarial más reducido

Decisión. Angular con TypeScript, con arquitectura modular por dominio funcional y carga diferida por ruta. Se descarta la fragmentación en micro-frontends en la primera versión: con un único equipo de canal web no compensa su coste, y se reevaluará si el número de equipos que contribuyen al canal supera los tres.

Justificación 1. Principio de gobierno por diseño. Cuando varios equipos construyen sobre la misma base y existe un objetivo explícito de homogeneidad, un marco que impone estructura —como hace Angular con sus módulos, su inyección de dependencias y su interfaz de línea de comandos— traslada parte del gobierno desde la revisión humana hacia la propia herramienta. Lo que la herramienta impone no necesita vigilarse en cada revisión de código. 2. **Principio de detección temprana de defectos.** El tipado estático nativo desplaza a tiempo de compilación una clase de errores que de otro modo se manifestarían en ejecución, lo que resulta especialmente valioso en un canal donde un fallo tiene consecuencia económica directa. 3. **Principio de previsibilidad del ciclo de vida.** Las versiones de soporte extendido de Angular publican calendario de fin de soporte con antelación, lo que permite planificar las actualizaciones de seguridad y demostrar ante auditoría que el canal no opera sobre componentes sin mantenimiento, requisito de la normativa de seguridad en canales electrónicos.

Consecuencias. Se asume una curva de aprendizaje inicial y una base de profesionales menor que la de React. Se mitiga con una plantilla de proyecto corporativa, una biblioteca de componentes propia basada en Angular Material y formación inicial del equipo.

Compatibilidad soportada (RES-08). Dos últimas versiones mayores de los navegadores de mayor uso, con degradación controlada en versiones anteriores: el canal detecta la ausencia de capacidades críticas y muestra un aviso explícito en lugar de fallar. **No se da soporte a navegadores sin mantenimiento de seguridad vigente**, por ser incompatible con la normativa de seguridad en canales electrónicos. En móvil, versiones de sistema operativo con soporte de seguridad activo del fabricante. La matriz de compatibilidad se revisa semestralmente con datos de uso real del canal.

Verificación. Auditoría de consistencia estructural entre módulos desarrollados por equipos distintos; pruebas automatizadas sobre la matriz de compatibilidad declarada.

Trazabilidad. RF-11, RES-08 · Criterio 6 · RNF-09

ADR-08 · Tecnología de la aplicación móvil

Contexto. El enunciado pide explícitamente **mentonar dos opciones y justificar la elección**. La aplicación móvil concentra los requisitos más exigentes: es el canal del onboarding con verificación facial (RF-07), debe emplear biometría del dispositivo sin que esta salga de él (RES-07) y debe cumplir ASR-19 de latencia de inicio de sesión.

Opciones evaluadas

Opción	A favor	En contra
Flutter (Dart)	Motor de renderizado propio (Impeller/Skia): el mismo código produce idéntico comportamiento y aspecto en iOS y Android, con una sola superficie de prueba y certificación; compilación anticipada a código nativo ARM, con arranque y desplazamiento predecibles; acceso a Keychain, Keystore y biometría mediante <i>platform channels</i> bajo control del propio equipo	Dart tiene base de profesionales menor; el paquete inicial pesa más que el de la alternativa

Opción	A favor	En contra
React Native	Comparte lenguaje JavaScript/TypeScript con el desarrollo web y su base de profesionales; ecosistema muy amplio; la nueva arquitectura con JSI y Fabric ha reducido notablemente el coste del puente	Al apoyarse en componentes nativos de cada plataforma, las diferencias de comportamiento afloran y obligan a verificación doble; para Keychain, Keystore, fijación de certificado y detección de entorno comprometido depende de bibliotecas de terceros, lo que amplía la superficie de cadena de suministro en funciones críticas de seguridad
.NET MAUI	Integración natural si la entidad es Microsoft-céntrica; C# compartido con servicios de backend	Comunidad y madurez menores en el segmento móvil financiero; menos bibliotecas específicas de seguridad móvil
Kotlin Multiplatform	Comparte lógica de negocio manteniendo interfaz nativa por plataforma	La interfaz se desarrolla dos veces: no elimina el doble esfuerzo en la capa donde más cambios se producen
Nativo separado (Swift y Kotlin)	Máximo control y acceso inmediato a novedades del sistema operativo	Duplica esfuerzo y mantenimiento; contradice el requisito explícito de marco multiplataforma del enunciado

Decisión. Flutter. Las dos opciones que el enunciado solicita comparar son **Flutter** y **React Native**; se elige la primera por los motivos siguientes.

Justificación 1. Principio de reducción de la superficie de verificación. En un canal regulado, cada diferencia de comportamiento entre plataformas es un caso de prueba adicional y un riesgo de divergencia funcional. Al renderizar su propia interfaz en lugar de delegar en los componentes de cada sistema operativo, Flutter garantiza que el mismo código produce el mismo resultado, lo que reduce el coste de certificación y la probabilidad de un defecto que solo se manifieste en una plataforma. **2. Principio de previsibilidad del rendimiento.** La compilación anticipada a código nativo ARM elimina la intermediación en tiempo de ejecución entre lógica e interfaz, proporcionando una latencia de arranque y de interacción estable. Es un requisito directo de ASR-19, donde el objetivo es $p_{95} \leq 1,5$ s hasta la primera pantalla útil. **3. Principio de minimización de dependencias en el camino de seguridad.** El acceso a Keychain, Keystore, biometría y atestación del dispositivo se resuelve con *platform channels* escritos y auditados por el propio equipo, en lugar de depender de bibliotecas de terceros para funciones críticas de seguridad (RES-07). Cada dependencia externa en ese camino es un eslabón adicional de la cadena de suministro que habría que auditar de forma continua.

Consecuencias. Se asume una base de profesionales en Dart menor y la necesidad de formación específica. Se asume que las capacidades más recientes de iOS o Android pueden requerir desarrollar el *platform channel* correspondiente. **Nota de coherencia con ADR-07:** si el canal web se hubiera resuelto con React, React Native habría ganado peso por compartir lenguaje y profesionales; al haberse elegido Angular, esa sinergia no existe y no condiciona esta decisión. La coherencia entre ambas elecciones se preserva mediante un sistema de diseño común expresado en tokens, consumido por ambos canales.

Verificación. Comparativa de latencia de arranque y de inicio de sesión entre ambas plataformas contra ASR-19; verificación de acceso al enclave seguro sin bibliotecas de terceros.

Trazabilidad. RF-12, RES-07 · ASR-19 · Criterio 6 · Instrucción explícita del enunciado

ADR-09 · Patrón de backend por canal

Contexto. Dos frontales con necesidades de datos distintas consumen los mismos servicios de dominio. Sin una capa intermedia, cada frontal orquesta llamadas y duplica lógica, o los servicios de dominio se contaminan con necesidades de presentación.

Opciones evaluadas

Opción	A favor	En contra
Frontales consumiendo directamente los servicios de dominio	Menos piezas	Muchas llamadas por pantalla, penalizando especialmente al móvil; lógica de composición duplicada en cada frontal; los servicios acaban adaptándose a necesidades de presentación
Un único backend compartido por ambos canales	Una sola pieza que mantener	Cada cambio de un canal afecta al otro; la respuesta se dimensiona por el canal más exigente, penalizando al móvil

Opción	A favor	En contra
Un backend por canal	Cada canal evoluciona por separado; la respuesta se ajusta a lo que el canal necesita; permite custodiar credenciales del lado servidor en el canal web	Dos piezas que mantener; riesgo de duplicación si no se comparte lo común

Decisión. Un backend de experiencia por canal, web y móvil, sobre una base común de composición y resiliencia compartida como biblioteca.

Justificación 1. **Principio de adecuación de la interfaz al consumidor.** Los canales difieren en ancho de banda disponible, tamaño de pantalla y patrón de uso. Una única representación obliga a que el canal más restringido transporte datos que no utiliza, penalizando directamente la latencia percibida en el canal móvil. 2. **Principio de independencia de ritmo de cambio.** La capa de experiencia cambia con cada iteración de producto; la capa de dominio cambia con el negocio. Separarlas permite que la primera evolucione rápido sin arrastrar revisiones ni riesgo sobre la segunda. 3. **Principio de habilitación de controles de seguridad específicos.** La existencia de un componente de servidor por canal es condición necesaria para custodiar las credenciales de sesión fuera del navegador (ADR-10), control que no sería posible si el frontal consumiera directamente los servicios de dominio.

Consecuencias. Se asume mantener dos componentes; se mitiga extrayendo la composición y la resiliencia a una biblioteca común versionada. Se asume un salto adicional de red, cuya latencia se compensa reduciendo el número de llamadas por pantalla.

Verificación. Medición del número de llamadas y del volumen transferido por pantalla en cada canal, antes y después.

Trazabilidad. ASR-05, ASR-19 · Criterios 3 y 6

ADR-10 · Custodia de credenciales de sesión en el canal web

Contexto. Una aplicación de página única que conserve credenciales de sesión en el almacenamiento del navegador queda expuesta a su extracción ante cualquier vulnerabilidad de ejecución de guiones, propia o de una dependencia (H-25).

Opciones evaluadas

Opción	A favor	En contra
Almacenamiento persistente del navegador	Sencillez; sobrevive a la recarga	Accesible desde cualquier guion ejecutado en la página; exposición directa ante inyección de código
Almacenamiento de sesión del navegador	Se limpia al cerrar la pestaña	Mismo vector de extracción
Solo en memoria con renovación silenciosa	No persiste	Se pierde al recargar; la credencial de renovación sigue expuesta
Credencial custodiada en el backend de canal, con identificador de sesión en cookie no accesible por guiones	La credencial nunca llega al navegador; revocación inmediata desde el servidor; reduce el alcance de cumplimiento del frontal	Requiere componente de servidor y protección contra falsificación de petición entre sitios

Decisión. El *access token* y el *refresh token* **permanecen en el BFF web**. El navegador solo recibe una cookie de sesión con los atributos `HttpOnly`, `SameSite=Strict` y `Secure`. El estado de sesión se mantiene en **Amazon ElastiCache for Redis** para no comprometer el escalado horizontal del BFF.

Justificación 1. **Principio de minimización de la exposición de secretos.** Un secreto que no está presente en un entorno no puede ser extraído de él. Trasladar la credencial al servidor elimina por completo la categoría de ataque, en lugar de intentar mitigarla con controles adicionales sobre el navegador, que son defensas en profundidad pero no eliminan el vector. 2. **Principio de control de la revocación.** Cuando la sesión vive en el servidor, su terminación es inmediata y efectiva. Con credenciales autocontenidas en poder del navegador, la revocación efectiva solo se consigue esperando a su caducidad o manteniendo listas de revocación, con coste y complejidad añadidos. 3. **Principio de reducción del alcance de cumplimiento.** Un frontal que no maneja credenciales reduce la superficie sujeta a verificación de seguridad de aplicaciones, simplificando las auditorías periódicas exigidas en el sector.

Consecuencias. Se asume la obligación de proteger contra falsificación de petición entre sitios: `SameSite=Strict` como control principal, verificación de las cabeceras `Origin` y `Referer`, y patrón de doble envío de testigo para las

operaciones monetarias. Se asume estado de sesión en el servidor, resuelto con Redis y con expiración alineada a la vigencia del token.

Verificación. Prueba de intrusión específica sobre extracción de credenciales desde el navegador; verificación de que la terminación de sesión invalida el acceso de forma inmediata.

Trazabilidad. H-25 · ASR-17 · Criterios 6, 10 y 13

ADR-11 · Interfaz dirigida desde el servidor en la aplicación móvil

Contexto. Los cambios de flujo en el canal móvil dependen del ciclo de publicación en las tiendas de aplicaciones, que introduce una demora no controlable por la entidad. Un cambio de origen normativo o un ajuste en el proceso de vinculación puede requerir días.

Opciones evaluadas

Opción	A favor	En contra
Todas las pantallas compiladas en la aplicación	Máximo rendimiento; sin dependencia de red para la estructura	Todo cambio requiere publicación y adopción por el usuario; coexistencia prolongada de versiones
Interfaz descrita desde el servidor en flujos de alta rotación	Cambios inmediatos sin publicar; posibilidad de revertir; coherencia entre plataformas garantizada desde el origen	Complejidad adicional; contrato de interfaz que versionar; dependencia de red
Interfaz descrita desde el servidor en toda la aplicación	Máxima agilidad	Penaliza el rendimiento y la operación sin conexión; riesgo de rechazo en la revisión de las tiendas

Decisión. Aplicación **acotada** a los flujos de alta rotación: proceso de vinculación, avisos, mensajes obligatorios y contenidos promocionales. El resto de la aplicación se compila.

Justificación 1. **Principio de independencia respecto de dependencias no controladas.** Cuando una obligación tiene plazo —una advertencia legal, un cambio de condiciones— la capacidad de cumplirla no debería depender del tiempo de revisión de un tercero. Desacoplar esos flujos convierte un riesgo de incumplimiento en un despliegue de servidor. 2. **Principio de proporcionalidad en la aplicación de un patrón.** El patrón aporta valor donde la frecuencia de cambio es alta y lo resta donde no la hay, por su coste en rendimiento y complejidad. Acotarlo a los flujos que efectivamente cambian maximiza el beneficio y limita el coste.

Consecuencias. Se asume definir y versionar un contrato de descripción de interfaz, y una estrategia de reserva si el servicio no responde. Se asume revisión de las políticas de las tiendas para garantizar que el uso acotado no compromete la publicación.

Verificación. Ensayo de cambio de un paso del proceso de vinculación sin publicar una nueva versión, con medición del tiempo hasta su efecto.

Trazabilidad. M-03 · RNF-09 · Criterio 6

ADR-12 · Estrategia de datos en el dispositivo y respuesta optimista

Contexto. ASR-05 y ASR-19 fijan objetivos de latencia, pero la percepción del cliente depende del tiempo hasta ver información útil, no del tiempo de respuesta del servidor. La conectividad móvil es intermitente.

Opciones evaluadas

Opción	A favor	En contra
Sin almacenamiento local: toda pantalla requiere red	Sin datos en el dispositivo; sin riesgo de desfase	Pantalla vacía en cada apertura; inutilizable sin cobertura
Histórico reciente almacenado localmente cifrado, con respuesta optimista en operaciones	Información inmediata al abrir; utilidad sin cobertura; mejora la latencia percibida sin coste de infraestructura	Datos en el dispositivo que proteger; necesidad de reconciliación y de indicar la antigüedad
Réplica completa sincronizada	Máxima autonomía	Volumen y complejidad desproporcionados; superficie de exposición amplia

Decisión. Almacenamiento local en base de datos cifrada (**SQLCipher** o equivalente), con la clave custodiada en **Keychain** en iOS y **Keystore** respaldado por hardware en Android, limitado al histórico de los últimos 90 días y a la posición consolidada. La interfaz muestra siempre la marca temporal del dato. Las operaciones aplican **respuesta optimista** presentando el estado "en proceso" de inmediato. **Borrado completo al cerrar sesión o tras inactividad prolongada.**

Justificación 1. Principio de separación entre latencia real y latencia percibida. La satisfacción del usuario depende del tiempo hasta obtener información útil. Disponer localmente del último estado conocido permite presentar contenido de inmediato mientras se actualiza en segundo plano, mejorando la experiencia sin ningún incremento de capacidad en el servidor. **2. Principio de degradación útil.** Ante pérdida de conectividad, un sistema que conserva el último estado conocido y lo señala como tal mantiene parte de su utilidad, frente a uno que queda completamente inoperativo.

Consecuencias. Se asume la presencia de información financiera en el dispositivo, que obliga a cifrado con claves protegidas por el hardware, borrado al cerrar sesión y prohibición de almacenar datos de mayor sensibilidad. Se asume la obligación de mostrar siempre la antigüedad del dato para no inducir a error, requisito relevante en un canal financiero.

Verificación. Medición del tiempo hasta primer contenido útil con y sin almacenamiento local; verificación del borrado efectivo al cerrar sesión; comprobación de que ningún dato sensible queda accesible en un dispositivo comprometido.

Trazabilidad. M-04 · ASR-19 · Criterios 6 y 9

ADR-13 · Protección de la aplicación móvil

Contexto. El dispositivo del cliente es un entorno no confiable sobre el que la entidad no tiene control. La normativa de seguridad en canales electrónicos exige medidas de protección del canal y de detección de entornos manipulados.

Opciones evaluadas

Opción	A favor	En contra
Sin medidas específicas	Menor coste y complejidad	Expone el canal a análisis, manipulación e interceptación; difícilmente defendible ante el regulador
Conjunto de controles: fijación de certificado, detección de entorno comprometido, ofuscación y detección de depuración	Eleva significativamente el coste del ataque; alineado con la práctica exigida en el sector	Requiere mantenimiento ante actualizaciones del sistema operativo; la fijación de certificado obliga a gestionar su renovación
Solución comercial de protección en tiempo de ejecución	Cobertura amplia y mantenida por el proveedor	Coste recurrente; dependencia adicional en la cadena de suministro

Decisión. Conjunto de controles: **fijación de certificado** (*certificate pinning*) con doble juego de claves para rotar sin interrupción; **detección de dispositivo comprometido** (*root* en Android, *jailbreak* en iOS) apoyada en **Play Integrity API** y **DeviceCheck/App Attest**, con respuesta graduada según el riesgo de la operación; **ofuscación** del código Dart y de los recursos; y **detección de depuración y emulación**. Se evaluará una solución comercial de protección en tiempo de ejecución para las funciones que requieran actualización continua frente a nuevas técnicas de evasión.

Justificación 1. Principio de defensa en profundidad sobre entorno no confiable. Ningún control en el dispositivo es infranqueable, pero su combinación eleva el coste del ataque por encima del beneficio esperado, que es el objetivo real de la seguridad en el extremo del cliente. **2. Principio de respuesta proporcional al riesgo.** Bloquear cualquier dispositivo con indicios de manipulación genera falsos positivos y fricción. Graduar la respuesta —permitir consulta, exigir verificación adicional para operar, bloquear operaciones de importe elevado— preserva el servicio y concentra la protección donde existe exposición económica.

Consecuencias. Se asume mantenimiento continuo frente a las actualizaciones de los sistemas operativos. La fijación de certificado obliga a un procedimiento de rotación con solapamiento, cuya omisión provocaría la indisponibilidad total del canal móvil, riesgo que se incorpora al registro de riesgos operativos.

Verificación. Prueba de intrusión sobre la aplicación con intento de interceptación y de ejecución en entorno manipulado; ensayo de rotación de certificado sin interrupción del servicio.

Trazabilidad. H-27 · ASR-17 · Criterios 6 y 13

Resumen de los bloques A y B

ADR	Decisión	Escenarios que gobierna
01	Despliegue híbrido: canal en nube, Core en instalaciones propias	ASR-05, 07, 11, 13
02	Proveedor de nube con marco de verificación sectorial	Criterio 8
03	Región principal en Sudamérica, continuidad en segunda región, entrega en el borde, decisión condicionada a medición	ASR-05, 19 · RSG-02, 03
04	Microservicios por capacidad, con ejecución bajo demanda para cargas dirigidas por eventos	ASR-04, 07, 14
05	Descomposición por capacidad de negocio contrastada con modelo de referencia sectorial	ASR-14 · Criterio 3
06	Orquestación de contenedores estándar gestionada	ASR-12, 13
07	Marco web integral y opinado con tipado estático	Criterio 6
08	Marco móvil con renderizado propio y compilación nativa	ASR-19 · RES-07
09	Un backend de experiencia por canal	ASR-05, 19
10	Credenciales custodiadas en servidor, nunca en el navegador	ASR-17
11	Interfaz dirigida desde servidor, acotada a flujos de alta rotación	RNF-09
12	Almacenamiento local cifrado y respuesta optimista	ASR-19
13	Conjunto de controles de protección del canal móvil	ASR-17

Pendientes: bloques C (identidad y onboarding), D (integración y protocolos), E (datos y auditoría), F (transaccionalidad), G (notificaciones), H (resiliencia y continuidad), I (observabilidad), J (seguridad y cumplimiento) y K (costos).

Capítulo 4 · Decisiones de identidad e integración (ADR-14 a ADR-27)

Mismo formato y criterio de citación que los bloques A y B: opciones evaluadas, **mínimo dos justificaciones teóricas**, consecuencias, verificación y trazabilidad. Productos, protocolos y estándares se nombran explícitamente.

Bloque C · Identidad, autenticación y onboarding

ADR-14 · Flujo de autorización OAuth 2.0

Contexto. Ambos frontales deben autenticar contra un producto de identidad existente que solo se configura (RC-01). El enunciado pide expresamente recomendar el flujo. La mención a "usuario y clave" induce a proponer el flujo de credenciales del propietario del recurso, que es la respuesta incorrecta (H-02).

Opciones evaluadas

Flujo	A favor	En contra
Resource Owner Password Credentials	La aplicación controla la pantalla de acceso; una sola llamada	Desaconsejado por el RFC 9700 (OAuth 2.0 Security BCP) y eliminado en OAuth 2.1. La aplicación manipula la contraseña del cliente, de modo que su compromiso expone la credencial; impide federación, segundo factor y claves de acceso sin modificar el cliente
Implicit	Evita el intercambio de código	Obsoleto. El token viaja en el fragmento de la URL, expuesto a historial, registros y extensiones
Authorization Code sin PKCE	Estándar previo	En clientes públicos el código puede ser interceptado por otra aplicación registrada en el mismo esquema de redirección
Authorization Code + PKCE (RFC 7636)	Estándar vigente para clientes públicos y confidenciales; la credencial nunca llega a la aplicación; compatible con segundo factor, federación y claves de acceso	El usuario abandona brevemente el contexto de la aplicación hacia el proveedor de identidad
Client Credentials	—	No aplica: presupone ausencia de usuario

Decisión. Authorization Code con PKCE en ambos canales, con la pantalla de acceso alojada en el proveedor de identidad: - **Web:** cliente confidencial gestionado por el BFF (coherente con ADR-10); PKCE igualmente aplicado. - **Móvil:** cliente público; PKCE obligatorio; apertura en **ASWebAuthenticationSession** (iOS) y **Custom Tabs** (Android) conforme al **RFC 8252, nunca en un WebView embebido**; retorno mediante *universal links* y *app links* verificados.

Justificación 1. Principio de no exposición de la credencial al cliente. Si la aplicación nunca manipula la contraseña, su compromiso no compromete la credencial. Esto es especialmente relevante en móvil, donde el binario se ejecuta en un entorno no confiable (ADR-13). **2. Principio de alineación con el estándar vigente.** El RFC 9700 desaconseja explícitamente el flujo de contraseña y OAuth 2.1 lo elimina. Construir sobre un flujo en retirada genera deuda de seguridad y complica las certificaciones y auditorías periódicas del sector. **3. Principio de evolución sin reescritura del cliente.** Al delegar la autenticación en el proveedor, incorporar un segundo factor, federar con un proveedor externo o migrar a claves de acceso se resuelve por configuración, sin desplegar versiones nuevas de los frontales — lo que en móvil implicaría además esperar al ciclo de publicación.

Consecuencias. El usuario sale momentáneamente del contexto de la aplicación; se mitiga con personalización visual del proveedor y con las pestañas seguras del sistema, que conservan el contexto. Obliga a gestionar las direcciones de redirección y la verificación de los enlaces de aplicación. El uso de WebView embebido queda **prohibido explícitamente** en el estándar de desarrollo, por impedir al usuario verificar el dominio y permitir a la aplicación observar lo introducido.

Verificación. Auditoría del flujo contra RFC 8252 y RFC 9700; prueba de que la credencial no transita en ningún momento por el proceso de la aplicación; comprobación de que la aplicación rechaza abrir la autenticación en WebView.

ADR-15 · Integración con el producto de identidad

Contexto. El enunciado establece que el producto existe y solo se configura, pero no lo identifica. La arquitectura debe integrarse sin quedar atada a un producto concreto, y a la vez debe poder exigirle capacidades mínimas.

Opciones evaluadas

Opción	A favor	En contra
Integración contra el estándar OpenID Connect, agnóstica del producto	El producto es sustituible sin tocar a los consumidores; permite exigir una lista verificable de capacidades	Renuncia a funciones propietarias que pudieran resultar cómodas
Integración contra la API propietaria del producto	Acceso a funciones avanzadas específicas	Sustituir el producto obliga a modificar todos los consumidores
Sustituir el producto por otro	Oportunidad de modernizar	Fuera del alcance y contrario a la restricción del enunciado

Decisión. Integración exclusivamente mediante **OpenID Connect** y **OAuth 2.0**, sin dependencias de API propietaria en los servicios. Se define una **lista de capacidades exigibles** al producto, que debe cumplir:

Capacidad exigida	Motivo
Authorization Code + PKCE	ADR-14
Documento de descubrimiento y publicación de claves con rotación	Validación local de credenciales sin consultar al proveedor en cada petición
Intercambio de credenciales (RFC 8693)	Propagación de identidad entre servicios (ADR-20)
Segundo factor y autenticación reforzada por operación, con expresión de método y nivel en la credencial	ADR-19
Atributos de contexto de autenticación y método empleado	Propagación del nivel de aseguramiento (H-03)
Cierre de sesión desde el proveedor hacia las aplicaciones	Revocación efectiva
Provisión de identidades por API o SCIM 2.0	Integración con onboarding (ADR-17)
Despliegue redundante y objetivo de disponibilidad documentado	RSG-07

Recomendación para el caso de que la entidad deba seleccionar producto: si prima el control sobre la residencia de las credenciales y el coste, **Keycloak** desplegado en EKS con alta disponibilidad; si prima la operación delegada y existe acuerdo corporativo, un producto empresarial gestionado como **ForgeRock**, **Ping Identity** o **Okta**. **Amazon Cognito** se descarta como proveedor principal por su soporte limitado de intercambio de credenciales y de políticas de autenticación reforzada.

Justificación 1. Principio de desacoplamiento por estándar. Integrar contra una especificación pública y no contra un producto convierte la sustitución del proveedor en un cambio de configuración. Es la aplicación directa del requisito de plan de salida que la buena práctica de externalización exige en el sector financiero. **2. Principio de exigencia verificable.** Transformar "la compañía cuenta con un producto" en una lista de capacidades comprobables permite validar antes de construir si el producto sostiene la arquitectura, en lugar de descubrir la carencia durante la integración.

Consecuencias. Se renuncia a funciones propietarias. Si el producto existente no cumple alguna capacidad de la lista, se escala como riesgo de proyecto con dos salidas: extender el producto o sustituirlo, ambas con impacto en plazo.

Verificación. Prueba de conformidad contra la lista de capacidades antes de iniciar la construcción; ejercicio teórico de sustitución para comprobar que ningún servicio contiene dependencias propietarias.

Trazabilidad. RC-01 · RSG-07 · Criterio 10

ADR-16 · Método de autenticación posterior al onboarding

Contexto. El enunciado indica que tras el onboarding el cliente accede "mediante usuario y clave, huella o algún otro método" y pide especificar al menos uno (H-04). La restricción RES-07 impide que la biometría abandone el dispositivo.

Opciones evaluadas

Opción	A favor	En contra
Solo usuario y contraseña	Universal; sin dependencia del dispositivo	Reutilización de credenciales entre servicios; vulnerable a robo por suplantación; fricción elevada en uso frecuente
Biometría enviada al servidor para comparación	Aparente simplicidad	Se descarta. Crea una base de datos biométrica: dato sensible e irrevocable , ya que una huella comprometida no puede rotarse. Contraviene RES-07 y el principio de minimización
Biometría local que desbloquea una clave vinculada al dispositivo	La biometría no sale del terminal; el factor de posesión reside en hardware no exportable; experiencia de acceso inmediata	Requiere un flujo de re-vinculación al cambiar de dispositivo
Claves de acceso (FIDO2/WebAuthn)	Resistentes a suplantación por estar ligadas al origen; sin secreto compartido	Adopción desigual; requiere soporte del proveedor de identidad

Decisión. Modelo de **dos capas**: - **Método principal en móvil**: vinculación del dispositivo con generación de un par de claves asimétricas en el **Secure Enclave** (iOS) o **StrongBox/TEE** (Android); la clave privada, **no exportable**, se desbloquea con **Face ID o huella**; el servidor conserva únicamente la clave pública y verifica una firma. - **Credencial de respaldo y canal web**: **usuario y contraseña** con política de robustez, verificación contra repositorios de credenciales filtradas y segundo factor. - **Evolución declarada**: migración a **claves de acceso (passkeys)** cuando el proveedor de identidad y la base instalada lo permitan, unificando ambos canales.

Justificación 1. Principio de irrevocabilidad del dato biométrico. Una contraseña comprometida se cambia; una huella, no. Por tanto la biometría debe usarse como **mecanismo de desbloqueo local** y nunca como secreto transmitido o almacenado centralmente. Esta distinción es la que evita crear un activo de riesgo permanente para la entidad. **2. Principio de posesión demostrable por hardware.** Una clave privada generada en el elemento seguro y marcada como no exportable convierte al dispositivo en un factor de posesión verificable criptográficamente, muy superior a un código de un solo uso enviado por mensaje, interceptable mediante duplicado de tarjeta. **3. Principio de resistencia a la suplantación de sitio.** Las claves de acceso están ligadas al origen que las creó, de modo que no pueden emplearse en un sitio fraudulento aunque el cliente sea engañado. Es el único mecanismo que elimina el vector de suplantación en lugar de mitigarlo.

Consecuencias. Se requiere un flujo de re-vinculación al cambiar de dispositivo, que es un momento de riesgo y exige verificación reforzada: se resuelve reutilizando el proceso de verificación de identidad de ADR-18. La contraseña permanece y debe protegerse contra ataques de reutilización (ASR-17).

Verificación. Comprobación de que ninguna muestra ni plantilla biométrica abandona el dispositivo mediante inspección del tráfico; prueba de que la clave privada no es exportable; ensayo del flujo de cambio de dispositivo.

Trazabilidad. H-04, H-26 · RES-07 · ASR-17 · Criterios 10 y 13

ADR-17 · Integración con la plataforma de onboarding

Contexto. El onboarding es un sistema adyacente fuera del alcance de construcción (H-20); lo evaluado es la integración (criterio 11). El requisito es que, al concluir, el cliente pueda autenticarse en el canal.

Opciones evaluadas

Opción	A favor	En contra
El canal orquesta la verificación de identidad directamente	Control total del flujo	Duplica una capacidad corporativa en un canal; el onboarding de oficina y web quedaría fuera; contradice el criterio 3

Opción	A favor	En contra
El onboarding orquesta y provisiona la identidad en el proveedor	Capacidad reutilizable por todos los canales; el canal solo consume identidad	Exige contrato claro entre onboarding y proveedor de identidad
El canal replica los datos del cliente tras el onboarding	Independencia	Crea un tercer origen de datos de cliente, contrario a RES-01 (H-18)

Decisión. El onboarding **provisiona la identidad en el proveedor** al completarse la verificación, y **publica un evento de alta**. El canal no participa en la verificación: se limita a lanzar el proceso desde la aplicación móvil y a consultar su estado.

Secuencia acordada: 1. La aplicación móvil inicia el proceso y recibe un identificador de solicitud. 2. El onboarding orquesta la verificación de identidad contra el proveedor especializado (ADR-18). 3. Con resultado favorable, el onboarding **crea la identidad en el proveedor mediante SCIM 2.0**, incluyendo el **nivel de aseguramiento alcanzado**, el método de verificación y su fecha. 4. El onboarding solicita el **alta del cliente en el Core** y espera su identificador. 5. El onboarding publica el evento `cliente.vinculado` con la correspondencia entre identificadores. 6. La aplicación completa la vinculación del dispositivo (ADR-16) y el cliente ya puede autenticarse por el flujo estándar (ADR-14).

Justificación 1. Principio de separación entre establecimiento y uso de la identidad. Quien verifica quién es una persona y quien la autentica a diario son responsabilidades distintas, con ritmos de cambio y requisitos regulatorios distintos. Separarlas permite que la verificación evolucione —cambio de proveedor, nuevo requisito normativo— sin tocar el canal. **2. Principio de fuente única de identidad.** Que el proveedor sea el único lugar donde se crea y consulta la identidad evita ciclos de vida paralelos, que son el origen habitual de accesos huérfanos tras una baja: un riesgo de auditoría recurrente en el sector. **3. Principio de reutilización de capacidades.** Al dejar el onboarding fuera del canal, los canales presenciales y web consumen el mismo proceso, satisfaciendo RNF-09 sin trabajo adicional.

Consecuencias. Se asume dependencia de la disponibilidad del onboarding para captar clientes nuevos, no para operar los existentes, lo que acota el impacto. Se asume la necesidad de un contrato formal entre onboarding y proveedor de identidad, que se documenta como interfaz de integración.

Verificación. Prueba extremo a extremo desde el inicio del proceso hasta la primera autenticación satisfactoria; comprobación de que el nivel de aseguramiento se refleja correctamente en la credencial emitida.

Trazabilidad. H-20, H-03 · RF-07, RF-08 · RNF-09 · **Criterio 11**

ADR-18 · Verificación de identidad con reconocimiento facial

Contexto. El onboarding emplea reconocimiento facial (RF-07). Los datos biométricos son categoría sensible (H-26) y la verificación debe resistir ataques de presentación: fotografías, vídeos y máscaras.

Opciones evaluadas

Opción	A favor	En contra
Desarrollo propio del motor biométrico	Control total; sin dependencia externa	Requiere competencia muy especializada; sin certificación reconocida la prueba de vida no es demostrable ante el regulador
Proveedor especializado con certificación de detección de ataques de presentación	Capacidad probada y certificable; mantenimiento frente a nuevas técnicas de fraude incluido	Dependencia de un tercero; coste por verificación
Verificación asistida por videollamada con agente	Alta confianza; sin biometría automatizada	No escala; coste por alta muy superior; horario limitado

Decisión. Proveedor especializado integrado tras una **interfaz propia de abstracción**, con estas exigencias: - **Prueba de vida conforme a ISO/IEC 30107-3**, con nivel de detección de ataques de presentación certificado por laboratorio independiente. - **Verificación documental** con lectura del chip cuando el documento lo permita, y validación de elementos de seguridad en caso contrario. - **Cotejo facial 1:1** entre la persona y el documento, y **búsqueda 1:N** contra vinculaciones previas para detectar identidades duplicadas. - Objetivo de aseguramiento: **NIST**

SP 800-63A, nivel IAL2. - Verificación asistida por agente como vía alternativa ante rechazos reiterados, para no excluir a clientes con dificultades de captura.

Herramientas de la industria evaluadas (el enunciado invita expresamente a recomendarlas)

Proveedor	Perfil	Consideración para este caso
iProov	Especialista en prueba de vida con certificación independiente de detección de ataques de presentación	Referencia en el control que aquí resulta decisivo; se integra como motor de prueba de vida junto a otro proveedor para documento
Veridas	Verificación documental y biométrica con presencia consolidada en mercados de habla hispana	Cobertura de documentos de identidad de la región y soporte en el idioma del cliente
FacePhi	Biometría facial orientada al sector financiero, con amplio despliegue en banca iberoamericana	Experiencia específica en flujos de vinculación bancaria
Incode	Plataforma integral de verificación con fuerte implantación en América Latina	Cobertura documental regional y proceso unificado
Onfido y Jumio	Plataformas globales de verificación documental y biométrica	Amplia cobertura internacional; conviene validar su catálogo de documentos del país
Sumsub	Verificación con módulos de cumplimiento y cribado integrados	Interesante si se decide unificar verificación y cribado en un mismo proveedor

Recomendación: combinación de un motor de **prueba de vida con certificación independiente** y un proveedor con **cobertura documental regional acreditada**, integrados ambos tras la interfaz de abstracción propia. Se exige prueba de concepto con documentos reales del país antes de la adjudicación, porque la cobertura documental declarada y la efectiva no siempre coinciden.

Herramientas complementarias para robustecer la solución, como sugiere el enunciado:

Ámbito	Herramientas
Antifraude transaccional y de comportamiento	Feedzai, Featurespace, NICE Actimize, BioCatch para biometría de comportamiento
Cribado contra listas restrictivas	LSEG World-Check, Dow Jones Risk & Compliance, ComplyAdvantage
Protección de la aplicación móvil en tiempo de ejecución	Appdome, Promon SHIELD, Guardsquare
Detección de dispositivo y reputación	Play Integrity API, App Attest, Fingerprint

Justificación 1. Principio de verificabilidad del control. Sin referencia a un estándar medible, "prueba de vida" es una afirmación comercial no comparable entre proveedores ni demostrable ante el regulador. Exigir certificación conforme a la norma de detección de ataques de presentación convierte el control en auditable y permite comparar ofertas sobre la misma base. **2. Principio de minimización del dato sensible.** El canal **no almacena plantillas biométricas**: conserva el resultado de la verificación, su nivel, la fecha y las evidencias documentales exigidas por la norma de prevención de blanqueo. Cuanto menor sea el volumen de dato biométrico bajo custodia de la entidad, menor la consecuencia de una brecha sobre un dato que no puede revocarse. **3. Principio de sustituibilidad del proveedor.** La abstracción tras una interfaz propia permite cambiar de proveedor, o combinar dos, sin modificar el flujo de onboarding. Mitiga el riesgo RSG-05 y responde a la exigencia de plan de salida.

Consecuencias. Se asume el coste por verificación, relevante en el cálculo de coste de captación. Se asume la obligación de recabar **consentimiento explícito e informado** para el tratamiento biométrico y de registrar la actividad de tratamiento. Debe medirse la **tasa de falso rechazo por segmento demográfico** para detectar sesgos que pudieran derivar en exclusión (RSG-08).

Verificación. Revisión del certificado de detección de ataques de presentación del proveedor; prueba con ataques de presentación controlados; medición de tasas de aceptación y rechazo por segmento durante el piloto.

Trazabilidad. RF-07, H-26 · RSG-05, RSG-08 · DRV-10 · **Criterio 11**

ADR-19 · Autenticación reforzada por operación y propagación del nivel de aseguramiento

Contexto. ASR-09 exige que las operaciones de importe elevado o con indicadores de riesgo requieran verificación adicional. El nivel alcanzado en el onboarding debe influir en lo que el cliente puede hacer (H-03).

Opciones evaluadas

Opción	A favor	En contra
Autenticación única al iniciar sesión, sin controles posteriores	Máxima fluidez	Una sesión secuestrada permite operar sin límite; incompatible con ASR-09
Verificación adicional en todas las operaciones monetarias	Máxima seguridad	Fricción elevada que desplaza al cliente a canales atendidos, contrario a OBJ-01 y OBJ-04
Verificación adicional condicionada al riesgo de la operación	Fricción proporcional a la exposición; experiencia fluida en el uso habitual	Requiere un motor de decisión y señales de calidad

Decisión. Autenticación reforzada condicionada al riesgo, con la decisión centralizada en un servicio de política y la aplicación distribuida en los servicios de dominio.

- El nivel de aseguramiento de la identidad y el método de autenticación empleado viajan en la credencial mediante los atributos estándar de contexto y método de autenticación.
- Un **servicio de política de riesgo transaccional** evalúa señales —importe frente al histórico del cliente, beneficiario no registrado previamente, dispositivo no habitual, geolocalización incoherente, velocidad de operación— y devuelve el nivel exigido.
- Si el nivel presente en la credencial es insuficiente, el servicio responde con un requerimiento de elevación y el frontal solicita la verificación adicional al proveedor de identidad.
- La decisión y las señales que la motivaron **se registran en auditoría** (ADR del bloque E).

Justificación 1. Principio de proporcionalidad del control al riesgo. Aplicar el mismo control a una consulta de saldo y a una transferencia de importe elevado desperdicia la tolerancia a la fricción del cliente en operaciones inocuas y la agota justo donde sería aceptable. La gradación concentra la protección donde existe exposición económica.

2. Principio de decisión centralizada con aplicación distribuida. Si cada servicio implementa su criterio, aparecen tantas políticas como servicios, imposibles de auditar y de modificar de forma coherente. Centralizar la decisión y distribuir su aplicación permite cambiar el umbral de riesgo en un único punto y demostrar ante el regulador qué política estaba vigente en cada momento.

3. Principio de continuidad entre verificación de identidad y autorización. El nivel establecido en el onboarding no es un dato histórico: condiciona los límites operativos. Propagarlo en la credencial materializa la relación que el enunciado señala entre el reconocimiento facial y el flujo de autorización.

Consecuencias. Se asume la construcción de un servicio de política y la calidad de sus señales; un motor mal calibrado genera fricción injustificada. Se establece medición continua de la tasa de elevaciones y de su resultado, para ajustar umbrales con evidencia.

Verificación. Ensayo con operaciones de distintos perfiles comprobando que la elevación se solicita cuando corresponde y no antes; verificación de que ninguna operación sensible se completa sin el nivel exigido.

Trazabilidad. ASR-09 · H-03, H-27 · Criterios 10 y 13

ADR-20 · Propagación de identidad entre servicios

Contexto. Una petición del cliente atraviesa varios servicios. Cada uno debe poder autorizar sobre el usuario real y no sobre una identidad técnica con permisos amplios.

Opciones evaluadas

Opción	A favor	En contra
Reenviar la credencial original a todos los servicios	Inmediato	La credencial va dirigida a un destinatario concreto: aceptarla en otro servicio habilita su reutilización indebida (problema del delegado confundido)
Identidad técnica del servicio, sin usuario	Sencillo	Todos los servicios operan con permisos amplios; se pierde la autorización por usuario y la trazabilidad
Intercambio de credenciales (RFC 8693) con destinatario específico	Cada salto recibe una credencial acotada a él, conservando el sujeto original	Latencia adicional por el intercambio; el proveedor debe soportarlo

Opción	A favor	En contra
Propagación por cabecera de confianza interna	Sin latencia añadida	Su validez depende de que la red sea confiable: incompatible con el modelo de confianza cero

Decisión. Intercambio de credenciales conforme al RFC 8693 entre servicios, con destinatario específico por servicio y ámbitos mínimos, más **autenticación mutua TLS** para la identidad de la carga de trabajo. La credencial intercambiada se almacena en caché durante su vigencia para amortizar el coste.

En los tramos asíncronos no viaja la credencial, que caducaría y constituye información sensible: el mensaje transporta el **identificador del sujeto y el contexto de autorización**, y el consumidor obtiene su propia credencial si necesita actuar en nombre del usuario.

Justificación 1. Principio de destinatario restringido. Una credencial debe ser aceptada únicamente por aquel para quien fue emitida. Verificar el destinatario impide que un servicio comprometido reutilice credenciales recibidas para acceder a otros, conteniendo el alcance de un incidente. **2. Principio de mínimo privilegio por salto.** Cada servicio recibe exclusivamente los ámbitos que necesita, de modo que un compromiso no otorga los permisos acumulados de toda la cadena. **3. Principio de no confianza en la red.** Sustituir "esta cabecera viene de dentro, luego es fiable" por una verificación criptográfica en cada salto elimina la premisa de red interna confiable, que es la base del modelo de confianza cero exigido en entornos regulados.

Consecuencias. Se asume latencia adicional por intercambio, mitigada con caché de vigencia corta. Se asume dependencia del proveedor de identidad en el camino de las peticiones, cuya indisponibilidad se acota mediante credenciales con vigencia suficiente para absorber interrupciones breves (ASR-18).

Verificación. Prueba de que una credencial emitida para un servicio es rechazada por otro; comprobación de que ningún mensaje asíncrono transporta credenciales.

Trazabilidad. ASR-18 · Criterios 10 y 13

Bloque D · Integración y protocolos

ADR-21 · Puerta de enlace de interfaces

Contexto. La restricción RES-03 exige que la capa de integración incluya una puerta de enlace. Debe concentrar la terminación segura, la autenticación de borde, la limitación de tasa y el enrutado.

Opciones evaluadas

Opción	A favor	En contra
Amazon API Gateway (HTTP API) con AWS WAF y CloudFront	Servicio gestionado sin infraestructura que operar; integración directa con WAF, Shield, CloudWatch y autorizadores; coste por uso	Funciones de catálogo y portal limitadas; dependencia del proveedor
Kong Gateway sobre EKS	Portable entre proveedores; ecosistema de complementos; control total	Infraestructura adicional que operar y actualizar; alta disponibilidad a cargo del equipo
Apigee	Catálogo, portal de desarrolladores, analítica y monetización muy completos	Coste elevado; sus funciones diferenciales no se aprovechan sin consumidores externos
Balanceador de aplicación sin puerta de enlace	Coste mínimo	No cubre autenticación de borde, limitación de tasa ni validación de esquema: incumple RES-03

Decisión. Amazon API Gateway en modalidad HTTP API como puerta de enlace norte-sur, con **AWS WAF** para protección frente a ataques de aplicación y **CloudFront** para terminación en el borde. Se documenta la **ruta de adopción de Kong o Apigee** para el momento en que la entidad exponga interfaces a terceros.

Justificación 1. Principio de adecuación al alcance presente. En este alcance no existen consumidores externos que requieran portal de desarrolladores, catálogo público ni monetización. Incorporar un producto de gestión completo supondría coste y complejidad sin contrapartida, en contra del criterio de manejo de costos. **2. Principio de reducción de componentes que operar.** Un servicio gestionado con integración nativa en la protección de

aplicaciones, el registro y la observabilidad elimina piezas intermedias y reduce la superficie sujeta a parcheo y a guardia, coherente con el objetivo de excelencia operativa. 3. **Principio de decisión reversible documentada.** Al concentrar en la puerta de enlace únicamente responsabilidades estándar —terminación, autenticación, limitación de tasa, enrutado— y mantener fuera la lógica de negocio, su sustitución futura queda acotada a reconfiguración, no a rediseño.

Consecuencias. Se asume dependencia del proveedor en este componente, acotada por la ausencia de lógica propia en él. Se asume que la apertura a terceros exigirá reevaluar la decisión, lo que se refleja en la hoja de ruta.

Verificación. Prueba de que la puerta de enlace no contiene lógica de negocio; ensayo de limitación de tasa y de validación de esquema; prueba de protección frente a los riesgos de la lista de referencia de seguridad de interfaces.

Trazabilidad. RES-03 · ASR-17 · Criterios 5 y 8

ADR-22 · Protocolos de comunicación y su protección

Contexto. El enunciado exige justificar los **protocolos** (H-17) y el diagrama de componentes debe mostrar "protocolos de comunicación **con seguridad**". Cada tramo tiene consumidores, volúmenes y fronteras organizativas distintas.

Opciones evaluadas (decisión de fondo: protocolo uniforme frente a catálogo por tramo)

Opción	A favor	En contra
REST/JSON en todos los tramos	Máxima uniformidad; una sola competencia y un solo conjunto de herramientas; inspeccionable en cualquier punto	Penaliza los tramos internos de alto volumen, donde la serialización textual y la ausencia de multiplexado son coste puro
gRPC en todos los tramos internos	Rendimiento y contrato tipado en toda la plataforma	No es consumible directamente desde el navegador sin intermediario; su carácter binario dificulta el diagnóstico en producción y eleva la fricción entre equipos que no comparten herramientas
GraphQL como capa unificada de consulta	El cliente solicita exactamente los campos que necesita; una sola interfaz para ambos canales	Dificulta el almacenamiento intermedio por su punto de entrada único; complica la limitación de tasa y el control del coste de consultas complejas; la autorización por campo añade complejidad desproporcionada en un dominio financiero
Catálogo por tramo con criterio explícito de elección	Cada tramo emplea el protocolo adecuado a su consumidor, volumen y frontera organizativa	Mayor variedad que gobernar: exige una regla clara para evitar que la variedad crezca sin control

Decisión. Catálogo por tramo, con la regla de que toda incorporación de un protocolo nuevo requiere justificación explícita (principio 3 de este ADR).

Decisión por tramo

Tramo	Protocolo	Protección	Motivo de la elección
Cliente ↔ borde	HTTPS con HTTP/2 y HTTP/3, TLS 1.3	Certificado gestionado, HSTS, fijación de certificado en móvil	HTTP/3 reduce el coste de establecimiento en redes móviles con pérdida; TLS 1.3 disminuye una vuelta en el saludo inicial, lo que impacta directamente en ASR-19
Borde ↔ BFF	HTTPS REST/JSON	TLS 1.3 y autenticación mutua	Frontera organizativa entre canal y plataforma: prima la legibilidad y el diagnóstico sobre el rendimiento marginal
BFF ↔ servicios de dominio	REST/JSON sobre HTTPS	Autenticación mutua TLS y credencial acotada por destinatario (ADR-20)	Cruza equipos: el contrato debe ser inspeccionable y versionable sin herramientas especializadas
Servicio ↔ servicio en camino crítico de alto volumen	gRPC sobre HTTP/2	Autenticación mutua TLS	Cuando ambos extremos pertenecen al mismo equipo y el volumen lo justifica, la serialización binaria y el multiplexado reducen latencia y consumo de recursos
Publicación y consumo de eventos	Apache Kafka	TLS en tránsito, autenticación mutua o SASL/OAUTHBEARER, listas de control por tema	Orden por clave, retención y reproducción: requisitos de ADR-24 que no ofrecen las colas simples

Tramo	Protocolo	Protección	Motivo de la elección
Canal ↔ Core	El que el Core exponga: servicios SOAP, colas de mensajes o llamada a procedimiento remoto	TLS y autenticación mutua sobre enlace privado; nunca a través de red pública	El Core no se modifica: la adaptación corresponde a la capa anticorrupción (ADR-23)
Core → canal (movimientos)	Captura de cambios en datos hacia Kafka	Enlace privado y cifrado en tránsito	Evita consulta periódica sobre un recurso limitado y habilita la notificación por evento (H-06)
Canal ↔ proveedores de notificación	HTTPS REST	TLS, credencial de cliente y firma del mensaje	Interfaz de terceros: se impone verificación de integridad además del cifrado del canal
Recepción de avisos de terceros	HTTPS entrante	Firma del cuerpo verificada, marca temporal, identificador de evento para deduplicación	Un aviso entrante es una entrada no confiable: se verifica origen e integridad antes de procesarlo
Canal ↔ proveedor de identidad	OpenID Connect sobre HTTPS	TLS 1.3, PKCE, validación de firma contra claves publicadas	Estándar que permite sustituir el producto sin tocar a los consumidores (ADR-15)
Provisión de identidades	SCIM 2.0 sobre HTTPS	TLS y autenticación mutua	Estándar de provisión: evita interfaces propietarias en el ciclo de vida de identidades

Justificación 1. Principio de adecuación del protocolo a la frontera organizativa. En los tramos que cruzan equipos, el coste dominante no es el de serialización sino el de coordinación: un contrato legible e inspeccionable reduce el tiempo de diagnóstico y de incorporación. En los tramos internos de un mismo equipo, ese coste no existe y puede optimizarse el rendimiento. **2. Principio de cifrado uniforme sin zonas de confianza.** Todo tramo va cifrado y autenticado, incluidos los internos. La distinción entre red interna segura y red externa insegura es la premisa que hace que un compromiso perimetral se convierta en un compromiso total. **3. Principio de economía de variedad.** Cada protocolo adicional incorpora herramientas, competencias y modos de fallo propios. Se limita el catálogo a cinco familias —HTTP/REST, gRPC, Kafka, los del Core y los estándares de identidad— y cualquier incorporación exige justificación explícita.

Consecuencias. Se asume el coste de gestionar certificados para autenticación mutua, automatizado con emisión y rotación programadas. Se asume que la capa anticorrupción concentra la complejidad de los protocolos del Core, lo que la convierte en componente crítico y la hace merecedora de tratamiento prioritario en pruebas y observabilidad.

Verificación. Inventario de tramos con su protocolo y protección, verificado automáticamente mediante políticas que rechacen el despliegue de comunicaciones sin cifrar; prueba de que ningún tramo acepta conexiones sin autenticación mutua donde se exige.

Trazabilidad. H-17 · ASR-19 · Criterios 4 y 5

ADR-23 · Estrategia de integración con el Core

Contexto. El Core es el sistema de registro, tiene capacidad limitada, ventana de cierre diaria y un modelo de datos propio que no debe propagarse al canal (DRV-01, DRV-07).

Opciones evaluadas

Opción	A favor	En contra
Acceso directo de cada servicio al Core	Menos componentes	Multiplica las conexiones sobre un recurso limitado; propaga el modelo del Core a todo el canal; sustituirlo obligaría a modificar todos los servicios
Acceso directo a la base de datos del Core	Máximo rendimiento de lectura	Acopla al esquema interno; carga no controlada sobre el motor transaccional; habitualmente prohibido por el proveedor del Core
Capa anticorrupción: interfaces de sistema dedicadas	Traduce el modelo; punto único de control de carga; aísla la sustitución futura	Componente adicional; un salto más de latencia

Decisión. Interfaces de sistema que actúan como capa anticorrupción y constituyen el **único camino** hacia el Core. Concentran: traducción entre el modelo del Core y el modelo del canal, **limitación global de tasa** para proteger su capacidad, aislamiento mediante compartimentos, interrupción de circuito, y gestión del comportamiento durante la ventana de cierre.

Justificación 1. Principio de aislamiento del modelo de dominio. Si el modelo del Core se propaga al canal, cualquier evolución del Core se convierte en un cambio transversal. Concentrar la traducción en la frontera hace que esa evolución afecte a un único componente. 2. **Principio de punto único de control sobre un recurso limitado.** Con múltiples consumidores directos, la carga total sobre el Core es la suma de comportamientos independientes y nadie puede garantizar un límite. Un camino único permite imponer una cuota global y priorizar entre consumidores, requisito para el compromiso con el área responsable del Core. 3. **Principio de sustituibilidad del sistema de registro.** Si en el futuro se incorpora un núcleo alternativo para productos nuevos, la capa anticorrupción permite enrutar por producto sin que los servicios de dominio se enteren.

Consecuencias. Se asume un salto adicional de latencia, compensado por el hecho de que la mayoría de las consultas no llegan al Core (ADR del bloque E). La capa anticorrupción se convierte en dependencia crítica y debe desplegarse con redundancia y vigilancia reforzada.

Verificación. Comprobación de que ningún servicio distinto de la capa anticorrupción posee credenciales de acceso al Core; ensayo de limitación de tasa verificando que la carga sobre el Core permanece bajo el umbral acordado durante una prueba de carga del canal.

Trazabilidad. DRV-01, DRV-07 · RES-01 · ASR-02 · Criterios 3 y 5

ADR-24 · Bus de eventos y publicación fiable

Contexto. Las notificaciones deben dispararse por movimientos originados en cualquier canal (H-06); las proyecciones de lectura deben mantenerse actualizadas (DRV-01); y la plataforma debe admitir consumidores futuros sin modificar a los productores (RNF-09).

Opciones evaluadas

Opción	A favor	En contra
Amazon MSK (Apache Kafka gestionado)	Retención y reproducción; orden garantizado por clave; múltiples grupos de consumo independientes; ecosistema de conectores y captura de cambios	Mayor complejidad operativa y coste base que una cola simple
SNS con SQS por suscriptor	Sencillez; coste bajo	Sin reproducción: un consumidor incorporado más tarde no puede recuperar el histórico; orden no garantizado en la modalidad estándar
EventBridge	Enrutado por contenido; integración con servicios gestionados	Retención limitada; sin orden por clave; no apto como registro de hechos
Publicación directa del productor a cada consumidor	Sin intermediario	Acopla el productor a todos los consumidores; incumple ASR-14

Decisión. Amazon MSK como bus de eventos, con: - **Patrón de bandeja de salida transaccional** en los servicios que producen eventos: el hecho y su evento se escriben en la misma transacción local y un proceso de captura de cambios los publica. - **Captura de cambios sobre el Core** para los movimientos, alimentando tanto las proyecciones como las notificaciones. - **Clave de partición por entidad** (cuenta o cliente) para garantizar orden donde importa. - **Esquemas registrados** con compatibilidad hacia atrás obligatoria (ADR-26). - **Cola de mensajes fallidos por consumidor**, con alerta y herramienta de reproceso.

Justificación 1. Principio de atomicidad local frente a escritura dual. Escribir en la base de datos y publicar en el bus son dos operaciones que no pueden confirmarse conjuntamente. Si el proceso se interrumpe entre ambas, o se pierde un evento de algo que ocurrió o se anuncia algo que no ocurrió. La bandeja de salida reduce el problema a una transacción local, que sí es atómica. 2. **Principio de reproducibilidad como habilitador de evolución.** Un registro retenido permite reconstruir una proyección corrupta e incorporar consumidores nuevos que necesitan el histórico. Es el mecanismo que hace verificable el compromiso de ASR-14 de añadir capacidades sin modificar las existentes. 3. **Principio de orden en el ámbito en que es exigible.** El orden global es innecesario y caro; el orden por entidad es imprescindible, porque dos movimientos de la misma cuenta procesados a la inversa producen un saldo incorrecto. La partición por clave proporciona exactamente esa garantía.

Consecuencias. Se asume consistencia eventual entre el Core y las proyecciones, acotada por el objetivo de ASR-06 y comunicada al cliente mediante la marca temporal. Se asume complejidad operativa, mitigada por el uso del servicio

gestionado y por una biblioteca común de productor y consumidor con idempotencia incorporada.

Verificación. Prueba de que ningún dato confirmado queda sin su evento, mediante conciliación entre la tabla de origen y el bus; ensayo de reconstrucción completa de una proyección desde el registro; medición del retraso de consumo frente a ASR-06.

Trazabilidad. H-06, H-18 · DRV-01, DRV-02 · ASR-06, ASR-14 · Criterios 4 y 5

ADR-25 · Comunicación entre servicios y malla de servicios

Contexto. ADR-22 exige autenticación mutua en todos los tramos internos y ADR-27 exige patrones de resiliencia. Estas capacidades pueden resolverse en una malla de servicios o en bibliotecas dentro de cada servicio.

Opciones evaluadas

Opción	A favor	En contra
Malla de servicios completa desde el inicio	Autenticación mutua, reintentos, interrupción de circuito y telemetría sin modificar código; políticas centralizadas	Plano de control adicional que operar y actualizar; consumo de recursos por instancia acompañante; complejidad de diagnóstico que se suma a la de un sistema ya distribuido
Autenticación mutua gestionada con emisión automática de certificados, políticas de red y resiliencia en biblioteca compartida	Cubre los requisitos con componentes que el equipo ya opera; sin plano de control adicional; diagnóstico más directo	Las políticas de resiliencia dependen de que los servicios usen la biblioteca; menor uniformidad si un servicio no la adopta
Sin cifrado entre servicios, confiando en el aislamiento de red	Simplicidad	Incompatible con el modelo de confianza cero y con la normativa de seguridad en canales

Decisión. No adoptar una malla de servicios en la primera versión. Se resuelve con: emisión y rotación automática de certificados para autenticación mutua, **políticas de red** que restringen qué servicios pueden comunicarse, y **biblioteca compartida de resiliencia** (tiempos límite, reintentos, interrupción de circuito, compartimentos) de uso obligatorio, verificado en el proceso de construcción. Se define el **umbral de reevaluación**: superar los veinticinco servicios o incorporar equipos con lenguajes distintos justificaría la adopción de la malla.

Justificación 1. Principio de proporcionalidad entre complejidad y beneficio. Una malla aporta valor cuando el número de servicios y la heterogeneidad de lenguajes hacen inviable garantizar el comportamiento por biblioteca. Con un catálogo reducido y homogéneo, introduce un plano de control adicional cuya operación y actualización consumen capacidad del equipo sin resolver un problema que exista hoy. **2. Principio de no duplicar responsabilidades.** Si la resiliencia reside simultáneamente en la biblioteca y en la malla, los reintentos se multiplican y los tiempos límite se solapan, produciendo comportamientos difíciles de diagnosticar precisamente durante un incidente. Es preferible una única ubicación de la responsabilidad. **3. Principio de decisión con umbral explícito.** Declarar de antemano la condición que justificaría el cambio evita tanto la adopción prematura como la resistencia indefinida, y convierte la decisión en revisable con un criterio objetivo.

Consecuencias. Se asume la obligación de verificar en el proceso de construcción que todo servicio utiliza la biblioteca de resiliencia. Se asume que la incorporación de un servicio en otro lenguaje exigirá portar la biblioteca o adelantar la adopción de la malla.

Verificación. Comprobación automatizada de que ningún servicio se despliega sin la biblioteca; prueba de que las políticas de red impiden la comunicación no autorizada entre servicios.

Trazabilidad. ASR-04 · Criterios 3, 4 y 9

ADR-26 · Contratos de interfaz y versionado

Contexto. Los servicios cruzan equipos y los eventos tienen consumidores que el productor no controla. Sin contratos formales, cualquier cambio es un riesgo de rotura; el criterio 1 exige además justificar y el criterio 3 evalúa el desacoplamiento.

Opciones evaluadas

Opción	A favor	En contra
Contrato generado a partir del código	Sin esfuerzo inicial; siempre refleja la implementación	El consumidor no puede empezar hasta que exista implementación; el diseño no se revisa antes de construir
Contrato primero, con generación de simuladores y de código	Consumidor y proveedor trabajan en paralelo; el diseño se revisa antes de invertir; la guía de estilo se impone automáticamente	Exige disciplina y herramientas
Sin contrato formal	Máxima flexibilidad inicial	Integraciones frágiles; cada cambio se descubre en pruebas o en producción

Decisión. **Contrato primero** para toda interfaz que cruce un equipo: - **OpenAPI 3.1** para interfaces síncronas y **AsyncAPI 3.0** para eventos. - **Spectral** como verificador de estilo en el proceso de construcción, con reglas propias: nomenclatura, formato de error conforme a RFC 9457, paginación por cursor, cabecera de idempotencia obligatoria en operaciones monetarias y metadatos de capacidad de negocio (ADR-05). - **Registro de esquemas** con compatibilidad hacia atrás obligatoria para los eventos. - **Versiónado en la ruta** para cambios incompatibles, con un máximo de dos versiones vivas y anuncio de retirada mediante la cabecera correspondiente. - **Pruebas de contrato dirigidas por el consumidor** entre servicios internos.

Justificación 1. **Principio de paralelización del trabajo.** Disponer del contrato antes que la implementación permite generar un simulador contra el que el consumidor desarrolla desde el primer día, eliminando la dependencia secuencial que de otro modo determina el plazo del proyecto. 2. **Principio de gobierno automatizado.** Un estándar verificado por una herramienta en cada integración se cumple siempre; uno confiado a la revisión humana se cumple de forma desigual y consume tiempo del arquitecto. Trasladar la verificación a la herramienta es lo que hace sostenible el gobierno cuando crece el número de equipos. 3. **Principio de compatibilidad demostrable.** Forzar la compatibilidad hacia atrás en el registro de esquemas convierte una buena intención en una restricción técnica: un cambio incompatible es rechazado antes de desplegarse, no descubierto por el consumidor afectado.

Consecuencias. Se asume la disciplina de diseñar antes de implementar y el coste de mantener las herramientas. Se asume la convivencia temporal de dos versiones en los cambios incompatibles, con su coste de mantenimiento.

Verificación. Comprobación de que ninguna interfaz se despliega sin contrato válido ni metadatos; prueba de que el registro rechaza un esquema incompatible; medición del número de versiones vivas.

Trazabilidad. RNF-09 · ASR-14 · Criterios 1, 3 y 4

ADR-27 · Resiliencia frente a sistemas externos

Contexto. El canal depende de sistemas que no controla: Core, sistema complementario, proveedor de identidad, proveedores de notificación y red interbancaria, con disponibilidades entre el 99,0 % y el 99,9 % (Fase 1, §3.5). ASR-04 exige que la degradación de uno no comprometa la funcionalidad principal.

Opciones evaluadas

Opción	A favor	En contra
Confiar en la disponibilidad declarada del tercero	Sin trabajo adicional	Con cinco dependencias entre el 99,0 % y el 99,9 %, la disponibilidad compuesta del flujo cae por debajo del 98 %: incumple ASR-01 por construcción
Únicamente reintentos	Sencillo; resuelve fallos puntuales	Ante una dependencia degradada, los reintentos multiplican la carga y retrasan su recuperación; sin tiempo límite, no protegen del modo de fallo más peligroso, que es la lentitud
Únicamente tiempos límite	Protege los recursos del llamante	Convierte en error toda incidencia transitoria que un reintento habría resuelto, degradando la experiencia sin necesidad
Conjunto completo de patrones en biblioteca compartida	Cobertura de los cuatro modos de fallo; comportamiento homogéneo y verificable; presupuesto de latencia coherente entre saltos	Exige que todos los servicios adopten la biblioteca y que se configure por dependencia
Delegar los patrones en una malla de servicios	Sin código en los servicios; política centralizada	Descartado en ADR-25: introduce un plano de control desproporcionado para el tamaño actual y duplicaría la responsabilidad con la biblioteca

Opción	A favor	En contra
Producto comercial de gestión de resiliencia	Cobertura mantenida por el proveedor	Coste recurrente y dependencia adicional para una capacidad que las bibliotecas maduras del ecosistema ya cubren

Decisión. Conjunto completo de patrones aplicado de forma uniforme a **toda** llamada saliente, provisto por la biblioteca compartida de ADR-25 (**Resilience4j** en los servicios de la plataforma):

Patrón	Configuración	Propósito
Presupuesto de tiempo por operación	Se reparte entre los saltos de modo que la suma no supere el objetivo del escenario	Impide que la suma de tiempos límite individuales exceda el compromiso extremo a extremo
Tiempo límite	Conexión 1 s; lectura ajustada al percentil 99 aceptable de cada dependencia	Evita que una dependencia lenta agote los recursos del llamante
Reintento con espera creciente y componente aleatorio	Solo en errores transitorios y operaciones idempotentes; máximo tres intentos	Absorbe fallos puntuales sin provocar avalanchas sincronizadas sobre un sistema en recuperación
Interrupción de circuito	Apertura ante umbral de error en ventana; prueba periódica en estado intermedio	Deja de castigar a un sistema degradado y libera al llamante de esperar
Compartimentos	Agrupación de conexiones independiente por dependencia	Impide que el agotamiento de recursos frente a un sistema afecte a los demás
Limitación de tasa saliente	Por dependencia, bajo la cuota acordada	Respetar los límites del tercero y evita el bloqueo por exceso
Comportamiento alternativo	Definido con negocio para cada dependencia	Convierte el fallo técnico en una respuesta comprensible para el cliente

Justificación 1. Principio de contención del fallo. Sin tiempo límite, una dependencia lenta no falla: consume progresivamente los recursos del llamante hasta provocar su caída. La lentitud es un modo de fallo más peligroso que la caída, porque no dispara alarmas hasta que el daño está hecho. **2. Principio de presupuesto de latencia.** Los compromisos de los escenarios son extremo a extremo, de modo que los tiempos límite no pueden fijarse aisladamente: deben repartirse desde el objetivo global hacia los saltos. Fijarlos por dependencia sin esa perspectiva garantiza incumplir el compromiso agregado. **3. Principio de decisión de negocio sobre la degradación.** Qué hacer cuando un sistema no responde —mostrar información antigua, encolar, rechazar— tiene consecuencias comerciales y de riesgo que no corresponde decidir al arquitecto en solitario. Documentar el comportamiento alternativo acordado convierte una decisión implícita del desarrollador en una decisión explícita y trazable de la organización.

Consecuencias. Se asume la aparición de estados intermedios visibles para el cliente —información con marca temporal antigua, operación en proceso— que exigen tratamiento explícito en la interfaz. Se asume la obligación de acordar y documentar el comportamiento alternativo de cada dependencia antes de su puesta en servicio.

Verificación. Inyección controlada de latencia y de fallos sobre cada dependencia, comprobando que la funcionalidad principal permanece (ASR-04) y que el comportamiento alternativo es el acordado; verificación de que la suma de tiempos límite de cada flujo respeta su presupuesto.

Trazabilidad. ASR-02, ASR-03, ASR-04 · DRV-02 · Criterios 5 y 14

Resumen de los bloques C y D

ADR	Decisión
14	Authorization Code con PKCE en ambos canales; pantalla de acceso en el proveedor; prohibido WebView embebido
15	Integración exclusivamente por OpenID Connect, con lista de capacidades exigibles al producto
16	Biometría local que desbloquea clave en elemento seguro + contraseña de respaldo; evolución a claves de acceso
17	El onboarding provisiona la identidad por SCIM 2.0 y publica evento de alta; el canal no verifica
18	Proveedor especializado con prueba de vida certificada; objetivo IAL2; sin plantillas biométricas en el canal
19	Autenticación reforzada condicionada al riesgo; decisión centralizada, aplicación distribuida
20	Intercambio de credenciales con destinatario específico; sin credenciales en mensajes asíncronos
21	Amazon API Gateway con WAF y CloudFront; ruta documentada hacia producto completo si se abre a terceros

ADR	Decisión
22	Catálogo de protocolos por tramo, cifrado y autenticado sin zonas de confianza
23	Capa anticorrupción como único camino al Core, con control global de tasa
24	Amazon MSK con bandeja de salida transaccional y captura de cambios; orden por clave de entidad
25	Sin malla de servicios en la primera versión; umbral explícito de reevaluación
26	Contrato primero con verificación automática de estilo y compatibilidad
27	Conjunto uniforme de patrones de resiliencia con presupuesto de latencia repartido

Pendientes: bloques E (datos y auditoría), F (transaccionalidad), G (notificaciones), H (resiliencia y continuidad), I (observabilidad), J (seguridad y cumplimiento) y K (costos).

Capítulo 5 · Decisiones de datos, auditoría y operación monetaria (ADR-28 a ADR-39)

Mismo formato y criterio de citación que los bloques anteriores.

Bloque E · Datos, caché y auditoría

ADR-28 · Estrategia de acceso a datos

Contexto. El canal genera unos 20 millones de llamadas diarias (Fase 1, §3.2) sobre un Core con capacidad limitada, ventana de cierre diaria y disponibilidad del 99,5 % (DRV-01). Simultáneamente, ASR-05 exige $p95 \leq 500$ ms y ASR-01 fija el 99,95 % de disponibilidad del canal. La restricción RES-01 establece que solo existen dos orígenes autoritativos de información de cliente (H-18).

Opciones evaluadas

Opción	A favor	En contra
Consulta directa al Core en cada petición	Dato siempre actual; ningún componente adicional	El volumen supera la capacidad del Core; la disponibilidad del canal queda limitada por la del Core (99,5 %), incompatible con ASR-01; durante la ventana de cierre el canal quedaría inoperativo
Caché de respuestas sobre consulta directa	Reduce el volumen con poco esfuerzo	La invalidación depende de la caducidad, no del cambio real; durante la ventana de cierre las entradas caducan sin posibilidad de refresco; no habilita consultas que el Core no ofrece
Réplica de la base de datos del Core	Rendimiento máximo en lectura	Acopla el canal al esquema interno del Core; carga adicional sobre su motor transaccional; habitualmente vetado por el proveedor del Core
Separación de responsabilidades entre consulta y comando, con proyección materializada alimentada por eventos	Sirve consultas sin tocar el Core; sobrevive a su ventana de cierre; permite modelos de consulta que el Core no soporta; reconstruible en su totalidad	Consistencia eventual acotada; coste de almacenamiento adicional; componente que mantener

Decisión. Separación de consulta y comando: las escrituras (transferencias) se dirigen al Core de forma síncrona a través de la capa anticorrupción (ADR-23); las lecturas se sirven de una **proyección materializada** alimentada por captura de cambios del Core (ADR-24), construida sobre **Aurora PostgreSQL** con particionado por fecha, complementada con **Amazon OpenSearch** para la búsqueda por concepto y comercio en el histórico.

La proyección se declara explícitamente como réplica derivada y no autoritativa: no acepta escrituras de negocio, su contenido es integramente derivable de los sistemas de registro, puede reconstruirse desde el bus de eventos y su antigüedad se muestra siempre al cliente.

Justificación 1. Principio de separación de modelos según el patrón de acceso. El modelo adecuado para registrar una operación —normalizado, orientado a la integridad transaccional— no es el adecuado para consultar un histórico con filtros por fecha, importe y concepto —desnormalizado, indexado por cliente y periodo—. Forzar ambos usos sobre una misma estructura obliga a comprometer los dos. **2. Principio de desacoplamiento de la disponibilidad.** Si cada consulta depende del Core, la disponibilidad del canal no puede superar la del Core. Matemáticamente, prometer 99,95 % sobre una dependencia del 99,5 % es imposible. La proyección rompe esa dependencia para el 95 % del tráfico, que es de lectura. **3. Principio de conservación de la autoridad del dato.** La proyección no constituye un tercer origen porque carece de autoridad: no origina información, no admite escrituras de negocio y es reconstruible por completo. Esta distinción es la que hace compatible el patrón con la restricción RES-01, y debe declararse de forma explícita para que la arquitectura no parezca contradecir el enunciado.

Consecuencias. Se asume **consistencia eventual**, acotada por ASR-06 en 60 s (p95) y comunicada al cliente mediante la marca temporal visible. Se asume el coste de almacenamiento de la proyección y la obligación de disponer

de un procedimiento probado de reconstrucción. Las operaciones que exigen saldo exacto —autorizar una transferencia— consultan el Core y no la proyección.

Verificación. Prueba de carga a 1.500 peticiones/s midiendo el porcentaje que alcanza el Core, con objetivo inferior al 5 %; medición del retraso de la proyección frente a ASR-06; ensayo completo de reconstrucción desde el bus con cronometraje.

Trazabilidad. H-12, H-18 · DRV-01, DRV-07 · ASR-01, ASR-05, ASR-06 · RES-01 · **Criterio 7**

ADR-29 · Caché y persistencia para clientes frecuentes

Contexto. El enunciado indica que el sistema "cuenta con un mecanismo de persistencia de información para clientes frecuentes" y pide expresamente **una alternativa basada en patrones de diseño que relacione los componentes que deberían interactuar**. La formulación admite tres lecturas (H-05), que se resuelven cubriéndolas las tres de forma diferenciada.

Opciones evaluadas

Opción	A favor	En contra
Caché local en cada instancia de servicio	Latencia mínima; sin infraestructura adicional	Cada instancia mantiene una copia distinta; la invalidación no es coordinada; la tasa de acierto cae al escalar horizontalmente
Caché distribuida con carga bajo demanda e invalidación por evento	Coherente entre instancias; sobrevive al reemplazo de instancias; invalidación precisa	Un salto de red adicional; componente que operar
Escritura diferida a través de la caché	Absorbe picos de escritura	Riesgo de pérdida ante fallo de la caché: inaceptable en información financiera
Precarga completa de todos los clientes	Tasa de acierto máxima	Memoria desproporcionada para 1,8 millones de usuarios activos, la mayoría con acceso esporádico

Decisión. Solución de **tres capas**, cada una atendiendo una de las lecturas del enunciado:

Capa 1 — Caché de datos de cliente (lectura: *rendimiento para los que más acceden*) Patrón **Cache-Aside** sobre **Amazon ElastiCache for Redis**: el servicio consulta la caché; ante ausencia, consulta el origen y la puebla. Caducidad amplia, con **invalidación dirigida por evento**: cuando el bus publica un cambio del cliente, se elimina la entrada afectada.

Capa 2 — Preferencias y beneficiarios frecuentes (lectura: *datos propios de uso habitual*) Patrón **Repository** sobre el servicio de Preferencias, con base propia en Aurora PostgreSQL. **Estos datos sí son autoritativos del canal**: los beneficiarios frecuentes, alias y configuración de notificaciones no existen en el Core, de modo que no vulneran RES-01.

Capa 3 — Precalentamiento selectivo (lectura: *tratamiento diferenciado del cliente frecuente*) Al autenticarse un cliente clasificado como frecuente, se precarga de forma asíncrona su posición consolidada y sus beneficiarios, de modo que la primera pantalla se sirva íntegramente de caché.

Relación entre componentes

Componente	Patrón	Responsabilidad
Interceptor del BFF	Interceptor	Registra el acceso y alimenta la clasificación de frecuencia
Servicio de Cliente	Cache-Aside	Consulta y puebla la caché; nunca escribe en ella dato no derivado
Servicio de Preferencias	Repository	Custodia beneficiarios y preferencias como dato autoritativo del canal
Consumidor de invalidación	Publisher-Subscriber	Elimina entradas afectadas al recibir eventos de cambio
Proyección de movimientos	Materialized View	Sirve el histórico sin alcanzar el Core (ADR-28)
Clasificador de frecuencia	Strategy	Determina qué clientes reciben precalentamiento según su patrón de uso

Justificación 1. Principio de localidad de referencia. En un canal digital, una minoría de clientes concentra la mayoría de los accesos. Dimensionar la caché por frecuencia de uso, en lugar de por volumen total de clientes, maximiza la tasa de acierto por unidad de memoria y hace que el coste crezca con el uso real y no con la base de clientes. 2.

Principio de invalidación dirigida por el cambio frente a caducidad ciega. Una caducidad corta reduce el error a costa de la tasa de acierto; una larga mejora el acierto a costa de servir datos obsoletos. La invalidación por evento elimina el dilema: permite caducidades amplias porque el dato se retira en cuanto se conoce su cambio. 3. **Principio de distinción entre dato derivado y dato propio.** Confundir la caché de información del Core con la persistencia de preferencias del canal es el error conceptual que subyace a la ambigüedad del enunciado. La primera es una copia sin autoridad y desechable; la segunda es información originada en el canal, de la que este sí es sistema de registro. Separarlas evita tanto vulnerar RES-01 como tratar como desechable un dato que no lo es.

Consecuencias. Se asume la coherencia entre caché y proyección, resuelta porque ambas se invalidan desde el mismo flujo de eventos. Se asume el riesgo de avalancha al expirar entradas muy solicitadas, mitigado con refresco anticipado y bloqueo por clave. Se asume que la clasificación de frecuencia es una heurística revisable.

Verificación. Medición de la tasa de acierto por capa; prueba de que una modificación en el Core invalida la entrada correspondiente dentro del objetivo de ASR-06; ensayo de expiración simultánea comprobando que no se propaga al Core.

Trazabilidad. H-05 · RF-10 · ASR-05 · RES-01 · **Criterios 4 y 7**

ADR-30 · Persistencia por servicio

Contexto. Decidida la descomposición en servicios (ADR-05), cada uno requiere persistencia con patrones de acceso muy distintos: transaccional, clave-valor de alto volumen, búsqueda y archivo inmutable.

Opciones evaluadas

Opción	A favor	En contra
Una única base compartida por todos los servicios	Operación simple; consultas entre entidades directas	Acopla los servicios por esquema: un cambio afecta a todos; elimina la autonomía de despliegue que justifica ADR-04
Un motor único, con base independiente por servicio	Autonomía sin multiplicar competencias	Obliga a forzar sobre un mismo motor patrones de acceso muy dispares
Base independiente por servicio, con motor elegido según el patrón de acceso	Cada servicio usa la herramienta adecuada; autonomía plena	Varias tecnologías que operar y dominar
Persistencia políglota sin criterio	Flexibilidad máxima	Proliferación de motores sin justificación: coste operativo creciente y competencias dispersas

Decisión. Base independiente por servicio, con motor seleccionado por patrón de acceso y con la regla de que incorporar un motor nuevo exige justificación explícita:

Motor	Uso	Patrón de acceso que lo justifica
Aurora PostgreSQL	Transferencias, Preferencias, Política de riesgo, proyección de movimientos	Transaccionalidad, integridad referencial, consultas con filtros y rangos
Amazon DynamoDB	Registro de idempotencia, estado de procesos de larga duración	Acceso por clave a muy alto volumen, escritura intensiva, caducidad nativa por registro
ElastiCache for Redis	Caché de cliente, sesión del BFF, limitación de tasa	Latencia de milisegundo, estructuras de datos en memoria, caducidad
Amazon OpenSearch	Auditoría en acceso inmediato, búsqueda en el histórico	Búsqueda por texto y agregaciones sobre grandes volúmenes
Amazon S3 con Object Lock	Auditoría de archivo, evidencias	Escritura única, lectura múltiple, retención prolongada a bajo coste

Justificación 1. Principio de adecuación del motor al patrón de acceso. Almacenar el registro de idempotencia —cientos de millones de claves de vida corta, acceso exclusivo por identificador— en un motor relacional supone pagar garantías de integridad referencial que no se utilizan, con un coste de escritura y de mantenimiento de índices desproporcionado. 2. **Principio de autonomía del servicio.** Una base compartida reintroduce por la puerta trasera el acoplamiento que la descomposición pretendía eliminar: dos servicios que comparten tablas no pueden desplegarse ni evolucionar por separado, de modo que dejan de ser servicios independientes salvo en el organigrama. 3. **Principio de economía de variedad.** Cada motor adicional incorpora respaldo, parcheo, ajuste, supervisión y competencias

propias. Limitar el catálogo a cinco motores con uso claramente diferenciado y exigir justificación para ampliarlo mantiene acotado el coste operativo, directamente ligado al criterio 9.

Consecuencias. Se asume la imposibilidad de consultas que crucen servicios en la base de datos: se resuelven por composición en el BFF o mediante proyecciones. Se asume la necesidad de conciliación entre servicios, que se cubre con los procesos de verificación periódica.

Verificación. Comprobación de que ningún servicio posee credenciales sobre la base de otro; revisión de que cada motor tiene uso diferenciado y documentado.

Trazabilidad. ADR-04, ADR-05 · **Criterios 3 y 7**

ADR-31 · Arquitectura de auditoría

Contexto. Debe registrarse **toda** acción del cliente (RF-09), lo que supone unos 10 millones de eventos diarios y 25 TB a siete años (H-21). ASR-10 exige reconstruir la actividad de un cliente en una fecha concreta —**incluida la información que el sistema le mostró**— en menos de cuatro horas. La auditoría tiene valor probatorio ante el regulador.

Opciones evaluadas

Opción	A favor	En contra
Tabla relacional única con escritura síncrona	Sencillez; consistencia inmediata	No sostiene el volumen con retención de años; añade latencia al camino crítico; convierte la auditoría en punto de fallo de la operación
Escritura síncrona a un servicio de auditoría	Garantiza el registro antes de responder	Acopla la disponibilidad de la operación a la del servicio de auditoría; penaliza ASR-05 y ASR-07
Registro en ficheros de aplicación	Coste nulo	No es un registro probatorio: alterable, sin garantía de entrega y sin modelo consultable
Servicio gestionado de registro inmutable con verificación criptográfica	Inmutabilidad nativa	Se descarta por riesgo de continuidad del servicio: comprometer una obligación de siete años con un producto cuyo ciclo de vida no está garantizado traslada un riesgo regulatorio a una decisión técnica reversible
Captura asíncrona mediante interceptor, con bandeja de salida, bus y almacenamiento por niveles	No penaliza el camino crítico; la bandeja de salida garantiza que nada se pierde; permite separar acceso inmediato y archivo	Consistencia eventual de unos segundos; más componentes

Decisión. Captura **asíncrona con garantía de entrega**:

1. **Interceptor** en el BFF y en los servicios de dominio que registra cada acción sin que el desarrollador deba recordarlo.
2. El evento se escribe en la **bandeja de salida** del servicio, en la misma transacción que el efecto de negocio.
3. Un proceso de captura de cambios lo publica en **Amazon MSK**.
4. Dos destinos: **Amazon OpenSearch** para los 24 meses de acceso inmediato y **Amazon S3 con Object Lock en modo cumplimiento** para el archivo de siete años.
5. **Encadenamiento de resúmenes criptográficos** por lote: cada lote incorpora el resumen del anterior, de modo que cualquier alteración rompe la cadena.
6. **Modelo bitemporal**: cada registro almacena el **instante en que ocurrió el hecho** y el **instante en que el sistema lo registró**.

Justificación 1. **Principio de no penalización del camino crítico.** La auditoría no puede añadir latencia a la operación ni convertirse en causa de su fallo: sería paradójico que un control de cumplimiento provocara la indisponibilidad del servicio que audita. La captura asíncrona con bandeja de salida ofrece la garantía de registro sin acoplar disponibilidad, porque el hecho y su evidencia se confirman en la misma transacción local. 2. **Principio de inmutabilidad demostrable.** Una obligación probatoria exige poder **demostrar** que el registro no fue alterado, no solo afirmarlo. El almacenamiento con bloqueo de objeto impide el borrado incluso a los administradores, y el encadenamiento de resúmenes permite verificar la integridad de toda la serie con un cálculo reproducible ante un tercero. 3. **Principio de bitemporalidad.** ASR-10 pregunta qué vio el cliente en un momento dado. Con un único

instante, cualquier reproceso o llegada tardía de información hace irreconstruible el estado que se le presentó. Distinguir cuándo ocurrió el hecho de cuándo se supo es lo que permite responder con exactitud a un requerimiento y a una reclamación.

Consecuencias. Se asume una ventana de segundos entre la acción y su disponibilidad en auditoría. Se asume el coste de almacenamiento, contenido mediante niveles (ADR-32) y **segmentación por criticidad**: las operaciones monetarias y los eventos de seguridad se conservan íntegros durante siete años; las consultas de navegación se conservan de forma agregada tras doce meses. Se asume que el modo de cumplimiento del bloqueo de objetos **impide borrar incluso por error**, lo que exige acertar en la política de retención desde el inicio.

Verificación. Simulacro de requerimiento regulatorio reconstruyendo la actividad de un cliente en una fecha, con cronometraje frente a ASR-10; verificación de la cadena de resúmenes; prueba de que un administrador con permisos elevados no puede alterar ni eliminar un registro.

Trazabilidad. RF-09, H-21, M-01 · ASR-10 · DRV-03 · **Criterio 12**

ADR-32 · Ciclo de vida y niveles de almacenamiento

Contexto. La política de retención (Fase 1, §5.bis) fija plazos de hasta siete años. Conservar todo en almacenamiento de acceso inmediato durante ese periodo es inviable económicamente y contrario al criterio 9.

Opciones evaluadas

Opción	A favor	En contra
Todo en acceso inmediato durante siete años	Consulta uniforme e instantánea	Coste desproporcionado para información consultada en una fracción ínfima de los casos
Archivo en cinta o soporte externo	Coste mínimo	Tiempo de recuperación incompatible con ASR-10; custodia y verificación manuales
Transición automática entre niveles según antigüedad	Coste proporcional a la probabilidad de acceso; recuperación dentro del objetivo	Requiere anticipar el tiempo de recuperación en el nivel más frío
Purga temprana	Coste mínimo	Incumplimiento normativo: la retención es obligación, no decisión de coste

Decisión. **Transición automática por antigüedad** mediante reglas de ciclo de vida, con niveles dimensionados para que el tiempo de recuperación del archivo permanezca dentro del objetivo de cuatro horas de ASR-10. Se incorpora **retención por orden judicial**, que suspende la purga de la información afectada por un litigio, y la **purga se ejecuta de forma automatizada y verificada**, con registro de lo eliminado.

Justificación 1. Principio de coste proporcional a la probabilidad de acceso. La probabilidad de consultar un registro decae rápidamente con su antigüedad, mientras que el coste de mantenerlo disponible al instante permanece constante. Alinear el nivel de almacenamiento con esa curva reduce el coste sin afectar al servicio real. **2. Principio de retención como control verificable.** La retención no es una configuración sino una obligación regulatoria: debe implementarse como política aplicada automáticamente y auditable, no como una tarea manual susceptible de olvido. Es una aplicación directa del cumplimiento expresado como código (M-05).

Consecuencias. Se asume que la recuperación desde el nivel de archivo requiere un tiempo de restauración que debe contemplarse en los procedimientos de respuesta a requerimientos. La suspensión de purga por litigio debe poder activarse de forma selectiva y quedar registrada.

Verificación. Ensayo de recuperación desde el nivel más frío con cronometraje; prueba de que la purga automática respeta la retención por orden judicial; conciliación entre lo purgado y lo previsto por política.

Trazabilidad. H-21, M-05 · ASR-10 · **Criterios 9, 12 y 13**

Bloque F · Transaccionalidad

ADR-33 · Coordinación de la transferencia

Contexto. Una transferencia atraviesa el canal, los controles de límites y cumplimiento, el Core y, si es interbancaria, una red externa (H-07). No existe posibilidad de transacción atómica entre todos ellos. ASR-07 fija $p95 \leq 2 \text{ s}$ para transferencias entre cuentas propias.

Opciones evaluadas

Opción	A favor	En contra
Confirmación en dos fases entre todos los participantes	Atomicidad real	Imposible: la red interbancaria no participa en protocolos de confirmación distribuida; además bloquea recursos y degrada la disponibilidad de todos los participantes
Transacción de negocio coreografiada mediante eventos	Máximo desacoplamiento entre servicios	Ningún componente conoce el estado global: responder "dónde está el pago" exige reconstruirlo correlacionando eventos, inviable para soporte y para el regulador
Transacción de negocio orquestada con máquina de estados persistida	Estado consultable en un único lugar; compensaciones explícitas y ordenadas; auditable	El orquestador concentra lógica y debe diseñarse para no convertirse en un componente monolítico
Servicio gestionado de orquestación de flujos	Visibilidad y reintentos sin desarrollo	Añade saltos de red y latencia a un flujo con objetivo de 2 s; su valor se aprecia en procesos de horas o días, no de segundos

Decisión. Orquestación con máquina de estados persistida en el servicio de Transferencias, sobre Aurora PostgreSQL, con estados explícitos y transiciones válidas declaradas:

iniciada → validada → cribada → autorizada → fondos_reservados → enviada → confirmada → liquidada ↘
rechazada → compensada

Cada transición se registra en auditoría con su instante de ocurrencia (ADR-31). Las **compensaciones son operaciones de negocio explícitas**: liberar la reserva de fondos, solicitar devolución, informar al cliente. El estado es consultable por soporte y por el propio cliente.

Justificación 1. **Principio de imposibilidad de atomicidad distribuida con terceros.** Ningún participante externo cederá el control de su confirmación a un coordinador ajeno. Asumirlo desde el diseño obliga a razonar en términos de compensación y evita una arquitectura que solo funcionaría si todos los sistemas fueran propios. 2. **Principio de trazabilidad operativa.** En un entorno financiero hay que poder responder "dónde está el pago X" a soporte, a negocio y al regulador, de forma inmediata y sin ambigüedad. La orquestación mantiene esa respuesta en un único lugar; la coreografía la dispersa entre los registros de varios servicios, lo que multiplica el tiempo de resolución de incidencias precisamente cuando hay dinero en juego. 3. **Principio de compensación como operación de negocio.** Deshacer un cargo no es una reversión técnica: es una devolución con su propio asiento contable, su propia evidencia y, en ocasiones, su propio coste. Modelarla como estado del proceso y no como excepción del código la hace visible, auditable y susceptible de tratamiento diferenciado.

Consecuencias. Se asume que el servicio de Transferencias concentra la lógica del proceso, lo que se acota manteniendo en él únicamente la coordinación y dejando en cada servicio su propia lógica. Se asume la existencia de estados intermedios visibles para el cliente, que deben comunicarse con claridad. Se asume la necesidad de un procedimiento para operaciones que queden bloqueadas en un estado intermedio.

Verificación. Ensayo de fallo inyectado en cada paso comprobando que la compensación se ejecuta y el estado final es coherente; prueba de que ninguna operación puede quedar indefinidamente en un estado intermedio sin alerta.

Trazabilidad. H-07 · RF-02, RF-03 · ASR-07 · DRV-06 · **Criterios 1 y 4**

ADR-34 · Idempotencia extremo a extremo

Contexto. ASR-15 exige que un doble envío —por doble pulsación o por reintento automático tras pérdida de conectividad— produzca **exactamente una** transferencia. Los reintentos son inevitables en cualquier sistema distribuido.

Opciones evaluadas

Opción	A favor	En contra
Deshabilitar el botón en el cliente	Trivial	Solo cubre la doble pulsación; no protege frente al reintento de red ni frente a un cliente manipulado
Detección de duplicados por comparación de atributos	Sin cambios en la interfaz	Dos transferencias legítimas idénticas —misma cuenta, mismo importe, mismo día— serían indistinguibles de un duplicado: produce falsos positivos con consecuencia económica
Bloqueo temporal por cliente	Sencillo	Arbitrario: impide operaciones legítimas y no garantiza unicidad ante reintentos simultáneos
Clave de idempotencia generada por el cliente, registrada por el servidor y propagada a lo largo de la cadena	Distingue el intento lógico del envío físico; cubre todos los orígenes de duplicado	Exige disciplina en todos los componentes de la cadena

Decisión. Clave de idempotencia extremo a extremo:

- El frontal genera un identificador único **por intento del usuario**, que se mantiene estable entre reintentos de la misma operación y cambia al iniciar una operación nueva.
- El BFF la transmite en la cabecera `Idempotency-Key`.
- El servicio de Transferencias la registra en **DynamoDB** con caducidad de 24 horas, **en la misma transacción que la creación de la operación**; si la clave ya existe, devuelve la respuesta original sin repetir el efecto.
- La clave se **propaga** hacia el Core y hacia la red interbancaria como referencia de extremo a extremo, de modo que también ellos puedan deduplicar.
- La clave se asocia al **cliente autenticado** para evitar colisiones entre usuarios distintos.

Justificación 1. Principio de inevitabilidad de la entrega múltiple. En un sistema distribuido, la única garantía alcanzable de forma realista es que el mensaje llegue al menos una vez; la entrega exactamente una vez no es alcanzable extremo a extremo cuando intervienen terceros. La idempotencia no es una optimización: es la contrapartida obligatoria de esa garantía. 2. **Principio de identificación del intento lógico.** La clave debe representar la **intención del usuario**, no el envío físico ni el contenido de la operación. Es lo que permite que dos pulsaciones sean el mismo intento y que dos transferencias legítimamente idénticas sean intentos distintos, distinción que ningún método basado en comparar atributos puede establecer. 3. **Principio de propagación de la garantía.** Una idempotencia que se detiene en el borde del sistema propio no protege frente a un reintento en un salto posterior. Propagar la referencia permite que cada participante, incluido el Core y la red, aplique su propia deduplicación sobre el mismo identificador.

Consecuencias. Se asume el almacenamiento del registro de claves con su caducidad, dimensionado en el bloque de costos. Se asume que la respuesta devuelta ante una repetición debe ser idéntica a la original, lo que obliga a persistirla junto con la clave.

Verificación. Prueba de doble envío simultáneo comprobando una única operación creada; prueba de reintento tras cortar la red en el momento exacto del envío; verificación de que ambas peticiones quedan registradas en auditoría y son distinguibles entre sí.

Trazabilidad. ASR-15 · **Criterios 1 y 4**

ADR-35 · Enrutamiento por tipo de operación y controles previos

Contexto. El enunciado indica que el servicio de transferencias "realiza llamados a servicios externos dependiendo del tipo". Cada tipo tiene destino, formato, horario de corte y modo de fallo distintos (H-07). Además deben aplicarse controles de límites, cumplimiento y fraude (H-27).

Opciones evaluadas

Opción	A favor	En contra
Condicionales por tipo dentro del servicio	Inmediato	La lógica de cada esquema se dispersa; añadir un tipo obliga a modificar el servicio, contra ASR-14
Un servicio independiente por tipo de transferencia	Aislamiento total	Triplifica la lógica común de validación, compensación y estado

Opción	A favor	En contra
Enrutamiento por estrategia con adaptadores por esquema	Lógica de proceso común; la variabilidad de cada esquema queda encapsulada; añadir un esquema es añadir un adaptador	Exige definir una interfaz de adaptador suficientemente general

Decisión. Selección de estrategia por tipo de operación, con un adaptador por esquema de destino —cuentas propias, terceros de la misma entidad y red interbancaria— tras una interfaz común. El proceso, el estado y la compensación (ADR-33) son comunes; lo específico de cada esquema queda dentro de su adaptador: formato del mensaje, horarios de corte, semántica de los códigos de respuesta y tratamiento de devoluciones.

Los controles previos son obligatorios y se aplican en este orden: validación de datos y límites del cliente → **cribado contra listas restrictivas** → evaluación de fraude → decisión de autenticación reforzada (ADR-19) → **reserva de fondos**.

Justificación 1. Principio de encapsulamiento de la variabilidad. Lo que varía entre tipos de operación es el destino y su protocolo, no el proceso de negocio. Separar lo estable de lo variable permite que incorporar un esquema nuevo —un sistema de pagos inmediatos, por ejemplo— consista en añadir un adaptador sin tocar el proceso ni sus pruebas, que es exactamente lo que exige ASR-14. **2. Principio de anterioridad del control sobre el movimiento de fondos.** Cribar contra listas restrictivas después de haber reservado o movido dinero invierte el orden lógico del cumplimiento y deja a la entidad en situación de haber ejecutado una operación que debía impedir. El orden de los controles no es una preferencia de diseño sino una exigencia derivada de la normativa de prevención.

Consecuencias. Se asume que la interfaz común del adaptador debe ser lo bastante general para admitir esquemas futuros sin rediseño, y lo bastante concreta para no degenerar en un contrato vacío. Se asume que el cribado añade latencia al camino crítico, acotada mediante listas replicadas localmente y actualizadas de forma continua.

Verificación. Ensayo de incorporación de un esquema nuevo midiendo el impacto sobre el código existente; prueba de que ninguna operación alcanza la reserva de fondos sin haber superado el cribado.

Trazabilidad. H-07, H-13, H-27 · RF-02, RF-03 · ASR-14 · **Criterios 4 y 5**

Resolución de H-13: la redacción del enunciado ("pagos entre cuentas propias e interbancarias") se interpreta aquí como los **tres tipos** declarados —cuentas propias del mismo titular, terceros de la misma entidad y otras entidades—, cada uno con su adaptador, sus horarios y sus modos de fallo.

Bloque G · Notificaciones

ADR-36 · Arquitectura de notificaciones

Contexto. La norma exige notificar **los movimientos realizados** (RF-06), sin restringirse a los originados en el canal digital: un movimiento puede proceder de un cajero, de un comercio o de un abono entrante (H-06). El volumen estimado es de 6 millones diarios con picos de 500 por segundo. El enunciado exige **como mínimo dos sistemas de notificación** (RC-03).

Opciones evaluadas

Opción	A favor	En contra
Notificar desde el canal al completar la operación	Inmediato y sencillo	Incumple la obligación: solo cubre los movimientos originados en el canal, que son una fracción del total
Consulta periódica del Core en busca de movimientos nuevos	No requiere cambios en el Core	Carga constante sobre un recurso limitado; retraso proporcional al intervalo; incompatible con ASR-08
Servicio dirigido por eventos del Core y del canal	Cubre todos los orígenes; desacoplado; escala con el volumen	Depende de la disponibilidad del flujo de captura de cambios
Delegar íntegramente en un proveedor externo	Sin desarrollo	La entidad pierde el control de la evidencia y de la conmutación, ambas exigidas por la norma

Decisión. Servicio de Notificaciones dirigido por eventos, que consume tanto los eventos del canal como los procedentes de la **captura de cambios del Core** (ADR-24), con:

- **Tres canales de entrega:** notificación push propia a la aplicación móvil, y mensajería corta y correo electrónico mediante proveedores externos.
- **Dos proveedores por cada canal crítico**, con la exigencia de **independencia real de ruta**: no se aceptan dos proveedores que se apoyen en el mismo agregador, porque su fallo sería simultáneo.
- **Conmutación automática** ante error o agotamiento de cuota, dentro del objetivo de 30 s de ASR-03.
- **Aislamiento por proveedor:** cola independiente por cada uno, de modo que la degradación de uno no retrase a los demás.
- **Enrutamiento por preferencia del cliente y criticidad del evento**, con un mínimo obligatorio no renunciante para los eventos exigidos por la norma.

Justificación 1. Principio de disparo en el origen del hecho. La obligación se refiere al movimiento, no a la operación del canal. Situar el disparador en el sistema donde el movimiento se registra —el Core— es la única forma de cubrir la totalidad de los casos; cualquier disparador situado en un canal cubre únicamente su propio tráfico y deja al descubierto el resto. **2. Principio de independencia efectiva de los modos de fallo.** Dos proveedores no aportan redundancia si comparten infraestructura subyacente: fallarían a la vez. La exigencia de diversidad de ruta convierte el requisito de "mínimo dos" en redundancia real y no en duplicidad aparente. **3. Principio de aislamiento entre consumidores.** Con una cola compartida, el proveedor más lento marca el ritmo de todos y su saturación bloquea canales que funcionan correctamente. Una cola por proveedor contiene la degradación en el canal afectado.

Consecuencias. Se asume dependencia de la captura de cambios del Core, cuya interrupción impediría notificar: se vigila de forma específica y se alerta ante ausencia de eventos en horario de actividad. Se asume el coste variable de los proveedores externos, significativo al volumen previsto y por tanto relevante en el bloque de costos.

Verificación. Prueba de que un movimiento originado fuera del canal genera notificación dentro del objetivo de ASR-08; ensayo de caída de un proveedor verificando la conmutación en menos de 30 s; prueba de saturación de un proveedor comprobando que los demás canales mantienen su ritmo.

Trazabilidad. RF-06, H-06, H-19 · RC-03 · ASR-03, ASR-08 · DRV-02 · **Criterio 5**

ADR-37 · Evidencia probatoria de la notificación

Contexto. Al derivar de una obligación normativa, la notificación exige poder **demostrar** que se realizó (H-19). Ante una reclamación, la ausencia de prueba se resuelve en contra de la entidad.

Opciones evaluadas

Opción	A favor	En contra
Confiar en los registros del proveedor externo	Sin desarrollo	La evidencia queda fuera del control de la entidad y sujeta a la política de retención del tercero, habitualmente inferior al plazo legal
Registro técnico de aplicación	Coste nulo	No constituye prueba: alterable, con retención breve y sin modelo consultable
Registro propio e inmutable por notificación, enlazado al evento que la originó	Evidencia bajo control de la entidad durante todo el plazo legal; consultable por soporte y cumplimiento	Almacenamiento adicional; obligación de conciliar con el proveedor

Decisión. Registro propio de evidencia por cada notificación, persistido mediante el mismo mecanismo inmutable de la auditoría (ADR-31), que conserva: el evento de origen, el destinatario, el canal empleado, el proveedor, el instante de cada intento, el resultado devuelto y el identificador asignado por el proveedor. Retención de siete años.

El contenido del mensaje se conserva doce meses y la evidencia de entrega siete años, de modo que se satisface la obligación probatoria sin conservar datos personales más allá de lo necesario.

Justificación 1. Principio de carga probatoria bajo control propio. La obligación de demostrar recae en la entidad, no en su proveedor. Depender de registros de un tercero, con su propia política de retención y su propio ciclo de vida contractual, traslada a un contrato externo la capacidad de responder ante el regulador. **2. Principio de separación entre evidencia y contenido.** El plazo de conservación de la prueba de entrega y el del mensaje que contiene datos personales responden a obligaciones distintas y contrapuestas: probatoria una, de minimización la otra. Separar ambos elementos permite cumplir las dos simultáneamente, en lugar de sacrificar una en favor de la otra.

Consecuencias. Se asume el coste de almacenamiento de la evidencia, incluido en el dimensionamiento de auditoría. Se asume la necesidad de conciliar periódicamente los registros propios con los del proveedor para detectar divergencias.

Verificación. Simulacro de reclamación reconstruyendo la evidencia completa de notificación de un movimiento concreto; conciliación mensual con los registros del proveedor; prueba de que el contenido se purga a los doce meses mientras la evidencia permanece.

Trazabilidad. H-19 · RF-06 · **Criterios 5, 12 y 13**

Bloque E' · Catálogo de servicios y composición de información

ADR-38 · Catálogo de servicios de dominio

Contexto. El enunciado establece **tres servicios principales** —consulta de datos básicos, consulta de movimientos y transferencias— y autoriza expresamente a añadir más si mejoran el rendimiento o la respuesta al cliente (RC-04). ADR-05 fijó el **criterio** de descomposición; falta aplicarlo y declarar el resultado, justificando **cada servicio adicional de forma individual**.

Opciones evaluadas

Opción	A favor	En contra
Ceñirse a los tres servicios del enunciado	Mínimo coste operativo; literalidad	Obliga a alojar en ellos responsabilidades de naturaleza distinta —auditoría, notificación, riesgo— con perfiles de carga, retención y ritmo de cambio incompatibles
Descomponer al máximo, un servicio por operación	Granularidad extrema	Coste operativo desproporcionado; multiplica la latencia por composición; fragmenta agregados que deben permanecer consistentes
Tres servicios del enunciado más los estrictamente justificados por una capacidad de negocio propia	Cada servicio tiene una razón declarada; coste operativo acotado	Exige justificar individualmente cada incorporación y resistir la tentación de añadir más

Decisión. Catálogo de **siete servicios de dominio** y **dos servicios de sistema**, con la regla de que **ningún servicio se incorpora sin una capacidad de negocio propia y un perfil operativo diferenciado**.

#	Servicio	Origen	Capacidad de negocio	Justificación de su existencia
1	Cliente	Enunciado	Directorio de datos de referencia de parte	Consulta de datos básicos y composición del detalle (ADR-39)
2	Movimientos	Enunciado	Cuenta: posición y movimientos	Consulta del histórico sobre la proyección (ADR-28)
3	Transferencias	Enunciado	Iniciación de pago	Coordinación de la operación monetaria (ADR-33)
4	Notificaciones	Añadido	Contacto con el cliente	Perfil de carga radicalmente distinto (500/s frente a 80/s), dependencia de proveedores externos con cuotas propias y obligación normativa con evidencia. Alojarlo en Transferencias acoplaría la operación monetaria a la disponibilidad de terceros de mensajería
5	Auditoría	Añadido	Registro de actividad y evidencia	Volumen de 10 millones de eventos diarios y retención de siete años con motor de persistencia distinto (ADR-31). Su ciclo de vida y su normativa son ajenos a cualquier servicio de negocio
6	Preferencias y frecuentes	Añadido	Gestión de la relación con el cliente	Único conjunto de datos del que el canal es sistema de registro (beneficiarios, alias, preferencias de notificación). Separarlo evita confundir dato propio con caché de dato ajeno (ADR-29)

#	Servicio	Origen	Capacidad de negocio	Justificación de su existencia
7	Política de riesgo transaccional	Añadido	Evaluación de fraude	Cambia por decisión de negocio y no de tecnología: umbrales, reglas y señales se ajustan con frecuencia. Centralizar la decisión permite modificar la política en un punto y demostrar ante el regulador cuál estaba vigente (ADR-19)
S1	Adaptador de Core	Sistema	—	Capa anticorrupción y punto único de control de carga sobre el Core (ADR-23)
S2	Adaptador de sistema complementario	Sistema	—	Aislamiento de la dependencia de menor disponibilidad (ADR-39)

Servicios deliberadamente no creados, para evitar fragmentación sin beneficio:

Candidato descartado	Motivo
Consulta de saldo separada de Movimientos	Comparten el mismo agregado y la misma proyección: separarlos obligaría a componer en cada pantalla sin ganancia de escalado
Servicio de sesión independiente	La sesión es responsabilidad del BFF (ADR-10); un servicio adicional añadiría un salto en el camino más frecuente
Servicio de límites separado de Política de riesgo	Los límites son una señal más de la decisión de riesgo; separarlos dispersaría la política en dos lugares

Justificación 1. Principio de cohesión por razón de cambio. Dos responsabilidades pertenecen al mismo servicio cuando cambian por el mismo motivo y a la vez. La auditoría cambia por normativa, las notificaciones por contrato con proveedores y la política de riesgo por decisión de negocio: tres motivos independientes que justifican tres unidades de despliegue independientes. **2. Principio de perfil operativo diferenciado.** Un servicio se justifica cuando su carga, su retención o su disponibilidad requerida difieren de forma sustancial del resto. Alojar diez millones de eventos diarios de auditoría en un servicio transaccional impondría a este el dimensionamiento y el coste de aquella sin contrapartida. **3. Principio de contención deliberada del catálogo.** Cada servicio incorpora despliegue, vigilancia, guardia y contrato. Declarar explícitamente qué servicios **no** se crean y por qué evita la proliferación, que es el modo habitual en que una arquitectura de microservicios degrada en coste operativo — directamente ligado al criterio 9.

Consecuencias. Se asume que las consultas que cruzan servicios se componen en el BFF y no en la base de datos. Se asume que el catálogo es revisable: incorporar un servicio nuevo exige demostrar capacidad de negocio propia y perfil operativo diferenciado, con el mismo grado de justificación que los aquí incluidos.

Verificación. Comprobación de que cada servicio tiene una capacidad de negocio asignada y ninguna capacidad en alcance queda sin dueño; revisión de que ningún servicio comparte base de datos con otro.

Trazabilidad. RC-04 · ADR-05 · ASR-14 · **Criterios 1, 3 y 9**

ADR-39 · Composición de la información de cliente

Contexto. El enunciado establece dos orígenes: el Core, con información básica de cliente, movimientos y productos, y un **sistema independiente que complementa la información del cliente cuando los datos se requieren en detalle** (RF-05). La expresión "cuando se requieren en detalle" indica que el segundo origen **no se consulta siempre**. Su disponibilidad asumida es del 99,0 %, la más baja de todas las dependencias (Fase 1, §3.5), y ASR-04 exige que su degradación no comprometa la funcionalidad principal.

Opciones evaluadas

Opción	A favor	En contra
Consultar ambos orígenes en toda petición de cliente	Respuesta siempre completa	La disponibilidad resultante es el producto de ambas (≈98,5 %), por debajo de ASR-01; carga innecesaria sobre el sistema de menor capacidad; latencia gobernada por el más lento
Consultar ambos en paralelo y esperar a los dos	Mejor latencia que en serie	No resuelve el problema de disponibilidad: sigue exigiendo que ambos respondan

Opción	A favor	En contra
Composición diferida: básico siempre, detalle solo cuando la vista lo requiere	Disponibilidad del caso principal igual a la del origen principal; carga proporcional al uso real; degradación parcial en lugar de total	Requiere clasificar qué información es básica y cuál es de detalle, y tratar la ausencia del detalle en la interfaz
Replicar el sistema complementario en el canal	Independencia total	Vulnera RES-01: crearía un tercer origen de información de cliente (H-18)

Decisión. Composición diferida en el BFF, con estas reglas:

- La **información básica** —identificación, productos, posición— procede del Core a través de la proyección y la caché (ADR-28, ADR-29) y está siempre disponible.
- El **detalle** —información complementaria de perfil— se solicita **únicamente cuando la vista lo requiere**, nunca de forma anticipada ni en listados.
- Si el sistema complementario no responde dentro de su tiempo límite, la vista se presenta **completa en su parte básica** y el bloque de detalle se marca como temporalmente no disponible, sin error ni pantalla vacía.
- La composición se realiza **por lote** cuando afecta a varios elementos, nunca elemento a elemento.
- El detalle se cachea con caducidad propia, más breve que la de la información básica por su naturaleza y menor volumen de consulta.

Justificación 1. Principio de coste proporcional al uso efectivo. El propio enunciado indica que el detalle se requiere en ocasiones concretas. Consultarlo siempre transforma una dependencia ocasional en permanente, multiplicando la carga sobre el sistema de menor capacidad sin que la mayoría de las peticiones aprovechen el resultado.

2. Principio de contención de la dependencia menos disponible. Cuando dos orígenes se componen de forma obligatoria, la disponibilidad resultante es su producto y queda por debajo de la del peor. Diferir el segundo convierte su indisponibilidad en una **degradación parcial y visible** en lugar de en un fallo total, que es exactamente lo que exige ASR-04.

3. Principio de composición agregada. Resolver el detalle elemento a elemento en un listado multiplica las llamadas por el número de resultados, degradando la latencia de forma proporcional al tamaño de la respuesta. La composición por lote mantiene el número de llamadas constante con independencia del volumen devuelto.

Consecuencias. Se asume la obligación de clasificar cada dato como básico o de detalle, decisión funcional que debe acordarse con negocio y documentarse. Se asume que la interfaz debe representar con claridad el estado "detalle no disponible" sin inducir a error sobre la información financiera, que permanece completa.

Verificación. Ensayo de indisponibilidad total del sistema complementario comprobando que ninguna vista falla y que la información financiera permanece íntegra (ASR-04); medición del número de llamadas al componer un listado, verificando que es independiente del número de elementos.

Trazabilidad. RF-05, H-18 · ASR-01, ASR-04 · RES-01 · **Criterios 5 y 7**

Resumen de los bloques E, E', F y G

ADR	Decisión
28	Separación consulta/comando con proyección materializada declarada no autoritativa
29	Tres capas: caché con invalidación por evento, preferencias como dato propio y precalentamiento selectivo
30	Base por servicio con motor según patrón de acceso; catálogo acotado a cinco
31	Auditoría asíncrona con bandeja de salida, almacenamiento inmutable, cadena de resúmenes y modelo bitemporal
32	Transición automática entre niveles con retención por orden judicial y purga verificada
33	Orquestación con máquina de estados persistida y compensaciones como operaciones de negocio
34	Clave de idempotencia por intento, propagada hasta el Core y la red
35	Enrutamiento por estrategia con adaptadores; controles antes de reservar fondos
36	Notificación dirigida por eventos del Core, tres canales, dos proveedores con independencia real de ruta
37	Evidencia propia inmutable a siete años, separada del contenido
38	Catálogo de 7 servicios de dominio y 2 de sistema, con los descartes declarados
39	Composición diferida: básico siempre, detalle solo cuando la vista lo requiere

Pendientes: bloques H (resiliencia y continuidad), I (observabilidad), J (seguridad y cumplimiento) y K (costos).

Capítulo 6 · Decisiones de resiliencia, seguridad, cumplimiento y costo (ADR-40 a ADR-52)

Estos cuatro bloques se organizan explícitamente sobre los pilares del AWS Well-Architected Framework, porque el enunciado está redactado con ese vocabulario —alta disponibilidad, seguridad, excelencia operativa, baja latencia y manejo de costos son cinco de sus seis pilares (H-22)—. Se aplica además su Financial Services Industry Lens.

Bloque	Pilar	ADR
H	Fiabilidad	40 – 43
I	Excelencia operativa	44 – 46
J	Seguridad (y cumplimiento normativo)	47 – 50
K	Optimización de costos y eficiencia del rendimiento	51 – 52

Bloque H · Fiabilidad

ADR-40 · Modelo de alta disponibilidad

Contexto. ASR-01 exige que la pérdida completa de una zona de disponibilidad no produzca interrupción perceptible, con un objetivo del **99,95 % mensual**, equivalente a 21,6 minutos de indisponibilidad admisible al mes.

Opciones evaluadas

Opción	Tiempo de recuperación	Coste relativo	Veredicto
Zona única	Indeterminado: la pérdida de la zona es la pérdida del servicio	1,0	Incumple ASR-01 por construcción
Multizona activo-pasivo	Minutos: requiere detectar, decidir y conmutar	1,4	Un único evento de conmutación consume el presupuesto mensual completo
Multizona activo-activo en tres zonas, dimensionado N+1	Sin conmutación: el tráfico ya se reparte	1,8	Cumple: la pérdida de una zona reduce capacidad, no disponibilidad
Multirregión activo-activo	Prácticamente nulo	3,5 y superficie jurídica duplicada	Desproporcionado para el objetivo; agrava la exposición de residencia de datos (H-24)

Decisión. Activo-activo en tres zonas de disponibilidad, con capacidad dimensionada **N+1**: cada zona opera en régimen normal por debajo de su capacidad máxima, de modo que la pérdida de una sea absorbida por las dos restantes sin degradación. Las bases de datos transaccionales emplean réplica síncrona entre zonas; la caché y las proyecciones se replican de forma asíncrona por ser reconstruibles.

Justificación 1. **Principio de redundancia con capacidad de absorción.** Distribuir en tres zonas no basta si cada una opera al límite: perder una dejaría al sistema con dos tercios de capacidad frente al cien por cien de la demanda, convirtiendo un fallo de infraestructura en una saturación generalizada. La redundancia solo es efectiva si va acompañada de holgura, y esa holgura es el precio del compromiso de ASR-01. 2. **Principio de eliminación del tiempo de conmutación.** En un esquema activo-pasivo, el tiempo que transcurre entre el fallo y la conmutación es indisponibilidad efectiva. Con un presupuesto de 21,6 minutos al mes, un único evento agotaría el margen anual. El esquema activo-activo suprime esa ventana porque no hay nada que conmutar. 3. **Principio de coherencia entre replicación y naturaleza del dato.** Exigir replicación síncrona a todo penaliza la latencia de escritura sin beneficio. La información transaccional la requiere porque su pérdida es irreparable; las proyecciones y la caché no, porque son reconstruibles desde el bus (ADR-28).

Consecuencias. Se asume el sobrecoste de la holgura, cuantificado en ADR-51 y justificado como coste directo del objetivo de disponibilidad. Se asume la latencia añadida de la réplica síncrona entre zonas, del orden de milisegundos y absorbible dentro del presupuesto de ASR-07.

Verificación. Ensayo de aislamiento completo de una zona durante la operación normal, midiendo error percibido por el cliente y tiempo de recuperación de la capacidad; verificación de que el sistema opera dentro de los objetivos de latencia con solo dos zonas activas.

Trazabilidad. ASR-01 · **Criterio 14**

ADR-41 · Arquitectura celular en el camino transaccional

Contexto. La redundancia multizona protege frente a fallos de infraestructura, pero **no frente a fallos lógicos**: un despliegue defectuoso, una migración de datos errónea o el agotamiento de un recurso compartido se replican de forma idéntica en las tres zonas y afectan al cien por cien de los clientes simultáneamente. Esta es la mejora M-02 identificada en el análisis.

Opciones evaluadas

Opción	Radio de impacto de un fallo lógico	Coste y complejidad
Sin particionado	100 % de los clientes	Mínimos
Particionado de toda la plataforma en celdas	~1/N de los clientes en cualquier capacidad	Elevados: multiplica entornos, despliegues y vigilancia en servicios cuyo fallo es tolerable
Particionado únicamente del camino transaccional crítico	~1/N en las operaciones monetarias; sin cambios en el resto	Moderados y acotados a donde el fallo tiene consecuencia económica

Decisión. Particionar en **celdas** el camino transaccional —servicio de Transferencias, su política de riesgo y su persistencia— asignando cada cliente a una celda de forma estable mediante función de dispersión sobre su identificador. Cada celda dispone de capacidad y despliegue propios. **Los despliegues se propagan celda a celda**, no simultáneamente.

Las capacidades de consulta, notificación y auditoría **no se particionan**: su fallo degrada la experiencia pero no compromete dinero, y el coste del particionado no se justificaría.

Justificación 1. Principio de acotación del radio de impacto ante fallos correlacionados. La redundancia de infraestructura asume que los fallos son independientes entre zonas, lo cual es falso para los fallos lógicos: el mismo código defectuoso se ejecuta idéntico en las tres. El particionado en celdas es la única defensa frente a esa clase de fallo, porque introduce independencia donde la redundancia no la proporciona. **2. Principio de despliegue como experimento con población acotada.** Propagar un cambio celda a celda convierte cada despliegue en una prueba sobre una fracción de clientes, con reversión antes de alcanzar al resto. Transforma el riesgo de despliegue de un evento de alcance total en una serie de eventos de alcance limitado. **3. Principio de proporcionalidad.** Aplicar el patrón a toda la plataforma multiplicaría el coste operativo sin contrapartida en capacidades cuya degradación es recuperable. Limitarlo a donde el fallo tiene consecuencia económica concentra la inversión donde produce retorno, que es lo que evalúa el criterio 9.

Consecuencias. Se asume el enrutamiento por cliente hacia su celda, resuelto en el BFF mediante un atributo de la credencial. Se asume que el traslado de un cliente entre celdas es una operación planificada, no automática. Se asume mayor complejidad operativa, mitigada porque todas las celdas se despliegan desde la misma definición declarativa.

Verificación. Inyección de un fallo lógico en una celda comprobando que las demás permanecen operativas y que el porcentaje de clientes afectados corresponde a la fracción prevista; ensayo de despliegue progresivo con reversión tras la primera celda.

Trazabilidad. M-02 · ASR-01, ASR-12 · **Criterios 9 y 14**

ADR-42 · Estrategia de recuperación ante desastres

Contexto. ASR-11 fija **RTO ≤ 15 minutos** y **RPO = 0** para información transaccional y de auditoría, con RPO ≤ 5 minutos admisible para las proyecciones por ser reconstruibles.

Opciones evaluadas

Estrategia	Tiempo de recuperación alcanzable	Coste del entorno secundario	Veredicto
Copia de seguridad y restauración	Horas	Muy bajo	Incumple ASR-11 en un orden de magnitud
Infraestructura mínima permanente	Aproximadamente una hora	Bajo	Insuficiente: el aprovisionamiento y el escalado consumen el objetivo
Entorno secundario templado con capacidad reducida	Minutos	Medio	Cumple: la infraestructura existe y solo requiere escalar y redirigir
Dos regiones activas simultáneamente	Prácticamente nulo	Muy alto	Desproporcionado y duplica la superficie de residencia de datos (H-24)

Decisión. Entorno secundario templado en la región de continuidad, con: - Infraestructura desplegada de forma permanente a capacidad reducida, escalable automáticamente al activarse. - **Replicación continua** de las bases transaccionales con objetivo de pérdida nula y del almacenamiento de auditoría. - Reconstrucción de las proyecciones desde el bus de eventos, que se replica entre regiones. - **Conmutación decidida por procedimiento**, no automática, para evitar activaciones espurias ante una partición de red. - **Ensayo trimestral completo con cronometraje**, incluyendo el regreso a la región principal.

Justificación 1. **Principio de correspondencia entre estrategia y objetivo.** Cada estrategia de continuidad tiene un rango de tiempo de recuperación alcanzable. Elegir por coste sin comprobar ese rango conduce a comprometer objetivos inalcanzables: el entorno templado es la opción de menor coste que efectivamente alcanza los quince minutos. 2. **Principio de diferenciación del objetivo de pérdida según la naturaleza del dato.** Exigir pérdida nula a todo multiplica el coste de replicación. La información transaccional y probatoria lo requiere porque es irrecuperable; las proyecciones no, porque se reconstruyen desde su origen. Esta distinción abarata la continuidad sin degradar la garantía donde importa. 3. **Principio de que un plan no ensayado no es un plan.** La deriva entre las dos regiones es inevitable a lo largo del tiempo, y solo el ensayo periódico la revela. Un procedimiento documentado pero nunca ejecutado ofrece una garantía aparente que se desvanece precisamente cuando se necesita.

Consecuencias. Se asume el coste permanente del entorno secundario, dimensionado en ADR-51. Se asume el riesgo de deriva de configuración, mitigado porque ambas regiones se despliegan desde la misma definición declarativa (ADR-45). Se asume que la conmutación manual introduce un tiempo de decisión, que se acota con criterios de activación predefinidos y delegación explícita de la autoridad para activarla.

Verificación. Ensayo trimestral con cronometraje del tiempo de recuperación y verificación de pérdida nula mediante conciliación de la última operación registrada antes de la caída simulada; prueba del regreso a la región principal.

Trazabilidad. ASR-11 · H-24 · **Criterio 14**

ADR-43 · Catálogo de modos degradados

Contexto. El canal depende de cinco sistemas externos con disponibilidades entre el 99,0 % y el 99,9 %. ASR-02, ASR-04 y ASR-18 exigen comportamientos concretos ante la indisponibilidad de cada uno. Sin un catálogo explícito, cada fallo se traduce en un error técnico incomprensible para el cliente.

Opciones evaluadas

Opción	A favor	En contra
Propagar el error técnico al cliente	Ningún desarrollo	El cliente no comprende qué ocurre ni qué hacer; genera llamadas a soporte y desconfianza sobre la integridad de sus fondos
Mensaje genérico de "servicio no disponible"	Sencillo	Oculto que buena parte del servicio sigue operativa; empuja al cliente a canales atendidos
Catálogo de modos degradados declarados por dependencia, acordados con negocio	El cliente conserva la funcionalidad disponible y comprende la limitación; reduce el impacto comercial	Exige acordar y documentar el comportamiento de cada dependencia antes de su puesta en servicio

Decisión. Catálogo explícito de modos degradados, acordado con negocio y documentado como parte del diseño de cada integración:

Dependencia no disponible	Comportamiento	Mensaje al cliente
Core (ventana de cierre o caída)	Consultas servidas desde la proyección con la marca temporal del último dato; transferencias aceptadas en modo diferido o rechazadas según política de negocio	"Información actualizada a las HH:MM. Tu transferencia se procesará a partir de las HH:MM."
Sistema complementario	Vista completa en su parte básica; bloque de detalle marcado como no disponible (ADR-39)	"Información complementaria temporalmente no disponible."
Producto de identidad	Las sesiones vigentes se mantienen hasta su expiración natural; nuevas autenticaciones muestran indisponibilidad temporal	"No es posible iniciar sesión en este momento. Si ya tienes la sesión abierta, puedes continuar."
Proveedor de notificación	Conmutación al alternativo; si ambos fallan, encolado con reintento y evidencia del retraso	Sin mensaje: transparente para el cliente
Red interbancaria	Operación aceptada y registrada con fecha valor del siguiente ciclo	"Recibida. Se ejecutará en el próximo ciclo de la red, el DD/MM a las HH:MM."
Verificación de identidad (onboarding)	Solicitud guardada; ofrecimiento de vía asistida	"Retomaremos tu solicitud en cuanto se restablezca el servicio."

Justificación 1. **Principio de degradación explícita frente a fallo genérico.** Un canal financiero no puede limitarse a fallar: el cliente que no ve su dinero asume lo peor. Declarar qué ocurre con cada dependencia convierte un incidente técnico en una limitación comprensible y acotada, lo que reduce tanto la llamada a soporte como el daño reputacional. 2. **Principio de decisión de negocio sobre la degradación.** Si aceptar una transferencia cuando el Core no responde es admisible, y bajo qué límite, es una decisión con consecuencias de riesgo y comerciales que no corresponde a quien implementa. Documentar el comportamiento acordado convierte una decisión implícita del desarrollador en una decisión explícita y trazable de la organización.

Consecuencias. Se asume que la interfaz debe representar estados intermedios y marcas temporales sin inducir a error sobre la información financiera. Se asume la obligación de acordar el modo degradado de cada dependencia **antes** de su puesta en servicio, lo que se incorpora como requisito de aceptación.

Verificación. Ensayo de indisponibilidad de cada dependencia comprobando que el comportamiento observado coincide con el catálogo y que el mensaje mostrado es el acordado.

Trazabilidad. ASR-02, ASR-03, ASR-04, ASR-18 · ADR-27 · **Criterio 14**

Bloque I · Excelencia operativa

ADR-44 · Observabilidad

Contexto. Una operación atraviesa el BFF, varios servicios de dominio, el bus, la capa anticorrupción y sistemas externos. ASR-16 exige detectar una degradación en **≤ 2 minutos** y notificarla en **≤ 3**. ASR-10 exige reconstruir actividad meses después. El criterio 15 evalúa específicamente el monitoreo.

Opciones evaluadas

Opción	A favor	En contra
Registros de aplicación únicamente	Coste mínimo	No permiten correlacionar una operación a través de varios servicios; el diagnóstico exige buscar en paralelo en varios orígenes
Métricas de infraestructura únicamente	Detección temprana de saturación	Indican que algo va mal, no qué ni dónde; no detectan fallos funcionales sin síntoma técnico
Suite propietaria integral de un fabricante	Puesta en marcha rápida; correlación incluida	Instrumentación acoplada al fabricante: cambiar de herramienta obliga a reinstrumentar todos los servicios
Instrumentación con estándar abierto y destinos gestionados	La instrumentación sobrevive al cambio de herramienta; correlación completa	Requiere definir convenciones propias y mantenerlas

Decisión. Instrumentación con **OpenTelemetry** y destinos gestionados —**Amazon Managed Service for Prometheus, Amazon Managed Grafana** y **AWS X-Ray**—, con cuatro elementos:

1. **Trazas distribuidas** con propagación de `traceparent` en cabeceras HTTP y en las cabeceras de los mensajes del bus, para que la traza no se interrumpa en los tramos asíncronos.
2. **Métricas** de tasa, error y duración por servicio, más **métricas de negocio**: transferencias iniciadas frente a confirmadas en el Core, notificaciones emitidas frente a entregadas, altas iniciadas frente a completadas.
3. **Registros estructurados** en formato uniforme, con identificador de traza e identificador de negocio, y **sin datos personales**.
4. **Vigilancia de ausencia**: alerta cuando un flujo deja de producir eventos en horario de actividad.

Justificación 1. **Principio de instrumentación desacoplada del destino**. La instrumentación es la inversión costosa y duradera; la herramienta de visualización es sustituible. Emplear un estándar abierto permite cambiar de destino sin reinstrumentar nueve servicios, y es coherente con la exigencia de plan de salida que aplica también a las herramientas de operación. 2. **Principio de doble correlación, técnica y de negocio**. El identificador de traza permite reconstruir una operación durante los días en que la herramienta lo retiene; el identificador de negocio permite investigarla meses después ante una reclamación, cuando la traza técnica ya expiró. Ambos son necesarios y responden a preguntas distintas. 3. **Principio de observar el resultado y no solo la salud**. Un fallo silencioso —transferencias que se aceptan pero no llegan al Core— no produce ningún síntoma técnico: no hay errores, ni latencia, ni saturación. Solo la comparación entre magnitudes de negocio lo revela, y es precisamente la clase de fallo con mayor consecuencia económica y regulatoria.

Consecuencias. Se asume el coste de almacenamiento de telemetría, contenido mediante muestreo adaptativo que conserva íntegras las trazas con error y las de operaciones monetarias, y reduce la proporción en el tráfico de consulta sin incidencias. Se asume la disciplina de mantener las convenciones de nomenclatura, verificada en el proceso de construcción.

Verificación. Prueba de que una operación es reconstruible de extremo a extremo incluyendo los tramos asíncronos; simulacro de fallo silencioso comprobando que la divergencia entre métricas de negocio lo detecta dentro de ASR-16; auditoría de ausencia de datos personales en los registros.

Trazabilidad. ASR-10, ASR-16 · **Criterio 15**

ADR-45 · Estrategia de despliegue y auto-recuperación

Contexto. ASR-12 exige despliegue sin interrupción y reversión en ≤ 5 minutos. ASR-13 exige que una instancia defectuosa se retire del balanceo en ≤ 30 segundos y sea reemplazada en ≤ 3 minutos, sin intervención humana.

Opciones evaluadas

Opción	A favor	En contra
Despliegue manual con ventana de mantenimiento	Control total	Interrupción planificada incompatible con ASR-12; reversión lenta y dependiente de la persona
Automatización desde el proceso de construcción hacia el entorno	Sencillo de implantar	El estado real del entorno no queda registrado de forma auditable; la reversión exige reejecutar el proceso
Estado deseado declarado en repositorio, con agente que lo aplica	El estado de producción es auditable y tiene historial; la reversión es revertir un cambio en el repositorio	Requiere disciplina y un agente adicional

Decisión. **Despliegue declarativo desde repositorio** con agente de sincronización (**Argo CD**) y **despliegue progresivo** (**Argo Rollouts**), con: - **Sondas de vivacidad, disponibilidad y arranque** en todos los servicios: la de disponibilidad verifica también las dependencias críticas. - **Presupuesto de interrupción** que impide que una operación de mantenimiento reduzca las réplicas por debajo del mínimo. - **Promoción o reversión automática según indicadores**: el despliegue avanza solo si las métricas de error y latencia se mantienen dentro de umbral. - **Terminación ordenada**: al recibir la señal de parada, el servicio deja de aceptar trabajo, completa el que tiene en curso, confirma los mensajes consumidos y finaliza. - Propagación **celda a celda** en el camino transaccional (ADR-41).

Justificación 1. **Principio de estado deseado declarativo y auditable**. Que el estado de producción resida en un repositorio con historial satisface simultáneamente dos exigencias: la trazabilidad de cambios que requiere la auditoría en el sector financiero, y la reversión rápida, que pasa a ser revertir una confirmación en lugar de reconstruir y redespigar. 2. **Principio de decisión por indicadores y no por observación**. Un operador vigilando un panel

durante un despliegue detecta problemas tarde y de forma inconsistente. Vincular la promoción a métricas objetivas hace la decisión reproducible y elimina el sesgo del turno, la hora o la experiencia de quien vigila. 3. **Principio de terminación ordenada como requisito de corrección.** Sin cierre ordenado, cada despliegue produce mensajes procesados sin confirmar —que se reentregan y duplican— o confirmados sin procesar —que se pierden—. En un sistema que mueve dinero, el despliegue deja de ser una operación neutra y se convierte en una fuente de inconsistencia.

Consecuencias. Se asume que durante el despliegue conviven dos versiones, lo que obliga a que todo cambio de contrato o de esquema sea compatible hacia atrás (ADR-26). Se asume el coste de mantener las definiciones declarativas sincronizadas entre regiones.

Verificación. Despliegue en horario de máxima actividad midiendo errores atribuibles, con objetivo de cero; ensayo de reversión con cronometraje frente a ASR-12; terminación forzada de una instancia comprobando tiempos de retirada y reemplazo frente a ASR-13, y ausencia de mensajes perdidos o duplicados.

Trazabilidad. ASR-12, ASR-13 · ADR-41 · **Criterios 14 y 15**

ADR-46 · Gestión del servicio: objetivos, alertas y respuesta

Contexto. El criterio 15 evalúa el monitoreo, que no consiste en recopilar métricas sino en **actuar sobre ellas**. Los escenarios de la Fase 1 fijan objetivos distintos por capacidad.

Opciones evaluadas

Opción	A favor	En contra
Un único objetivo global de disponibilidad	Sencillo de comunicar	Obliga a dimensionar toda la plataforma al nivel de la capacidad más exigente; oculta qué función concreta está degradada
Alertas por umbral estático de recursos	Inmediato de configurar	Genera ruido: la mayoría de los avisos no corresponden a impacto real, lo que erosiona la atención sobre los válidos
Objetivos por capacidad, con alertas basadas en el consumo del presupuesto de error	Alerta solo cuando el cliente resulta afectado; prioriza por velocidad de deterioro	Requiere definir y mantener los objetivos, y educar al equipo en el modelo

Decisión. **Objetivos de nivel de servicio diferenciados por capacidad**, derivados de los escenarios de la Fase 1, con **presupuesto de error** asociado y alertas por **velocidad de consumo** de ese presupuesto.

Capacidad	Indicador	Objetivo
Consulta de posición y movimientos	Peticiones correctas en menos de 500 ms	99,95 % mensual
Iniciación de transferencia	Operaciones aceptadas y confirmadas en menos de 2 s	99,9 % mensual
Autenticación	Inicios de sesión completados en menos de 1,5 s	99,9 % mensual
Notificación de movimiento	Entregadas en menos de 2 minutos	99,5 % mensual
Frescura de la proyección	Movimientos visibles en menos de 60 s	99 % mensual

Cada alerta incorpora **guía de actuación enlazada**, con diagnóstico inicial, acciones de contención y contactos de escalado, incluidos los de los proveedores externos. Tras cada incidente se realiza **revisión sin atribución de culpa**, con acciones de mejora registradas y seguimiento de su cierre.

Justificación 1. **Principio de alertar por el síntoma que percibe el cliente.** Una alerta por consumo de procesador informa de una condición técnica que puede no tener ninguna consecuencia; una alerta por consumo del presupuesto de error informa de que el compromiso con el cliente se está deteriorando. Solo la segunda justifica despertar a una persona de madrugada. 2. **Principio de alerta accionable.** Una alerta sin acción documentada acaba siendo ignorada, y su presencia degrada la atención prestada a las demás. La regla de que toda alerta debe tener guía de actuación, o ser eliminada, mantiene la señal por encima del ruido. 3. **Principio de objetivos diferenciados según el valor de la capacidad.** Comprometer el mismo nivel para consultar un saldo y para recibir una notificación obliga a invertir en la segunda lo mismo que en la primera, sin que el negocio lo requiera. Diferenciar permite asignar el esfuerzo donde el impacto lo justifica, lo que enlaza directamente con el criterio de costos.

Consecuencias. Se asume el mantenimiento del catálogo de objetivos y su revisión periódica con negocio. Se asume la disciplina de eliminar alertas que no conducen a acción, aunque resulte incómodo desactivar avisos existentes.

Verificación. Revisión mensual de la proporción de alertas que derivaron en acción, con objetivo superior al 80 %; comprobación de que todo objetivo tiene indicador medido de forma automática y panel asociado.

Trazabilidad. ASR-16 · Fase 1 §5 · **Criterio 15**

Bloque J · Seguridad y cumplimiento normativo

ADR-47 · Marco normativo aplicable y su traducción a controles

Contexto. El enunciado pide mencionar los elementos normativos relevantes para una entidad financiera. El marco depende de la jurisdicción, que el enunciado no precisa (H-01); se asume **Ecuador** conforme a la decisión D-01, con una capa internacional transversal y equivalencias regionales para que el análisis conserve validez en otras jurisdicciones.

Nota de rigor: los instrumentos se citan por su denominación y su contenido. Los números concretos de resolución deben verificarse contra la codificación vigente en el momento de la implantación, dado que la normativa sectorial se actualiza con frecuencia. Citar una referencia que no corresponda sería un defecto más grave que citarla por su nombre.

Opciones evaluadas (cómo estructurar el análisis normativo)

Opción	A favor	En contra
Únicamente marco local	Máxima precisión sobre la jurisdicción asumida	Queda invalidado si el supuesto de país es incorrecto; la norma local fija objetivos, pero rara vez controles técnicos verificables
Únicamente estándares internacionales	Válido en cualquier jurisdicción; controles medibles y certificables	No demuestra conocimiento de regulación bancaria, que es justamente lo que evalúa el criterio 13; un supervisor local no acepta un estándar internacional como sustituto de su norma
Tres capas: marco local, estándares internacionales y equivalencias regionales	Precisión sobre la jurisdicción asumida, controles verificables y validez preservada si el supuesto cambia o la entidad opera en varios países	Mayor extensión del capítulo

Decisión. Estructura en **tres capas**, con mapeo explícito de cada obligación al ADR que la materializa.

Marco local (Ecuador)

Instrumento	Materia	Traducción a control arquitectónico
Código Orgánico Monetario y Financiero	Marco general del sistema financiero	Define la condición de entidad supervisada y la sujeción a la Superintendencia de Bancos
Normativa de la Superintendencia de Bancos sobre gestión de riesgo operativo y sobre seguridad en canales electrónicos (Codificación de Resoluciones, Libro I)	Seguridad de canales, autenticación, notificación de operaciones, continuidad	ADR-14 y 16 (autenticación), ADR-36 y 37 (notificación), ADR-40 a 43 (continuidad), ADR-31 (registro de actividad)
Ley Orgánica de Protección de Datos Personales y su autoridad de control	Tratamiento de datos personales, categorías sensibles, transferencia internacional	ADR-03 (residencia y base de legitimación), ADR-18 y 26 del análisis (biometría), ADR-32 (retención), ADR-49 (cifrado con claves propias)
Ley de Comercio Electrónico, Firmas Electrónicas y Mensajes de Datos	Validez de la contratación electrónica y de la firma	Sustenta la validez jurídica del proceso de vinculación remota y de la aceptación de condiciones
Ley Orgánica de Prevención, Detección y Erradicación del Delito de Lavado de Activos y normativa de la Unidad de Análisis Financiero y Económico	Debida diligencia, cribado, reporte	ADR-18 (diligencia en la vinculación), ADR-35 (cribado previo a mover fondos), ADR-31 (conservación probatoria)
Normativa del Banco Central del Ecuador sobre el Sistema Nacional de Pagos	Transferencias interbancarias, ciclos y horarios de corte	ADR-35 (adaptador de red y horarios), ADR-43 (comunicación de fecha valor)

Marco internacional transversal

Referencia	Aportación
ISO/IEC 27001 y 27002	Sistema de gestión de seguridad y catálogo de controles
ISO 22301	Continuidad de negocio: sustenta los objetivos de ADR-42
NIST SP 800-63	Niveles de aseguramiento de identidad y de autenticación (ADR-16, 18, 19)
ISO/IEC 30107	Detección de ataques de presentación en biometría (ADR-18)
OWASP ASVS y OWASP API Security Top 10	Verificación de seguridad de aplicaciones e interfaces
PCI DSS	Aplicable si el alcance incorpora datos de tarjeta; hoy fuera de alcance, con la tokenización prevista si se incorpora
AWS Well-Architected Framework, Financial Services Industry Lens	Marco de verificación del diseño en los seis pilares

Equivalencias regionales (para preservar la validez del análisis en otras jurisdicciones)

Materia	Ecuador	Colombia	Perú	Unión Europea
Seguridad en canales electrónicos	Normativa de la Superintendencia de Bancos	Circular Externa de la Superintendencia Financiera sobre seguridad y calidad en canales	Reglamento de la Superintendencia de Banca, Seguros y AFP sobre gestión de seguridad y ciberseguridad	Normativa de la Autoridad Bancaria Europea y la directiva de servicios de pago
Protección de datos	Ley Orgánica de Protección de Datos Personales	Régimen de habeas data	Ley de Protección de Datos Personales	Reglamento General de Protección de Datos
Resiliencia operativa	Riesgo operativo en la normativa sectorial	Riesgo operativo	Continuidad del negocio	Reglamento de resiliencia operativa digital
Pagos interbancarios	Sistema de Pagos Interbancario del Banco Central	Sistemas de compensación y ACH	Cámara de compensación electrónica	Zona única de pagos en euros

Justificación 1. Principio de trazabilidad entre obligación y control. Una obligación normativa que no puede señalarse en un componente concreto de la arquitectura no está implementada, está declarada. La tabla que vincula cada instrumento con los ADR que lo materializan es lo que convierte el capítulo de cumplimiento en verificable y no en un listado de buenas intenciones. 2. **Principio de doble capa normativa.** La norma local fija **qué** debe lograrse, con frecuencia en términos de objetivo; los estándares internacionales aportan **cómo** verificarlo, con controles medibles y certificables. Emplear ambas capas permite demostrar cumplimiento con evidencia técnica y no solo con una declaración de conformidad. 3. **Principio de portabilidad del análisis.** Dado que la jurisdicción es un supuesto, la tabla de equivalencias preserva la validez del diseño si la entidad opera en otro país o si el supuesto resulta incorrecto, lo que es además un requisito real en grupos financieros con presencia regional.

Consecuencias. Se asume la obligación de verificar la vigencia de cada instrumento antes de la implantación. Se asume que el capítulo debe revisarse con las áreas de Cumplimiento y Asesoría Jurídica, cuya validación se incorpora como hito previo a la construcción.

Verificación. Revisión conjunta con Cumplimiento del mapeo obligación-control; comprobación de que ninguna obligación identificada queda sin ADR asociado.

Trazabilidad. H-01 · D-01 · RNF-10 · **Criterio 13**

ADR-48 · Defensa en profundidad y segmentación

Contexto. El canal está expuesto a internet, maneja información financiera y opera bajo un modelo en el que la red interna no se considera confiable (ADR-20).

Opciones evaluadas

Opción	A favor	En contra
Protección perimetral robusta con interior abierto	Sencillez de operación	Un único compromiso del perímetro otorga acceso total: modelo desacreditado en cualquier entorno regulado
Cifrado y autenticación entre servicios sin segmentación de red	Buena protección de la comunicación	No limita el movimiento lateral: un servicio comprometido alcanza a todos los demás
Capas independientes de control en borde, red, identidad, aplicación y datos	Ningún control único determina el resultado; el compromiso de una capa no implica el de las demás	Mayor esfuerzo de diseño y de operación

Decisión. Cinco capas de control independientes:

Capa	Controles
Borde	Protección frente a ataques de aplicación y volumétricos; limitación de tasa; validación de esquema de las peticiones
Red	Subredes privadas sin salida directa a internet; puntos de acceso privados hacia servicios gestionados; políticas que restringen qué servicios pueden comunicarse entre sí (ADR-25)
Identidad	Privilegio mínimo por servicio; credenciales de corta vida sin secretos estáticos; autenticación mutua entre servicios
Aplicación	Validación de entrada contra el contrato; codificación de salida; protección frente a los riesgos del catálogo de referencia de seguridad de interfaces
Datos	Cifrado en tránsito y en reposo; cifrado a nivel de campo para los datos de mayor sensibilidad; enmascaramiento en entornos no productivos y en registros

El acceso de operación se realiza mediante **sesiones gestionadas y registradas**, sin servidores de salto expuestos ni claves de acceso permanentes.

Justificación 1. Principio de independencia entre capas de control. La defensa en profundidad solo aporta si el compromiso de una capa no facilita el de la siguiente. Que la segmentación de red no dependa de la identidad de aplicación, ni el cifrado de datos de la protección del borde, es lo que hace que la probabilidad conjunta de fallo sea el producto y no la suma. **2. Principio de contención del movimiento lateral.** La mayor parte del daño de un incidente no procede del acceso inicial sino de la capacidad de desplazarse a partir de él. Las políticas que restringen la comunicación entre servicios convierten un compromiso puntual en un incidente acotado.

Consecuencias. Se asume mayor complejidad de configuración de red y el riesgo de que una política excesivamente restrictiva bloquee tráfico legítimo, mitigado con despliegue previo en modo observación. Se asume que el acceso de operación requiere herramientas específicas en lugar de conexión directa.

Verificación. Prueba de intrusión con alcance interno, verificando que el compromiso de un servicio no permite alcanzar los demás; auditoría de ausencia de credenciales permanentes y de servidores expuestos.

Trazabilidad. ASR-17 · ADR-20, ADR-25 · **Criterio 13**

ADR-49 · Gestión de claves y secretos

Contexto. La residencia de datos obliga a que la entidad conserve el control efectivo sobre la información que sale del país (ADR-03, H-24). Además existen secretos de integración con múltiples terceros.

Opciones evaluadas

Opción	A favor	En contra
Claves gestionadas por el proveedor de nube	Sin gestión; coste mínimo	El proveedor conserva capacidad técnica de descifrado, lo que debilita la posición jurídica ante la transferencia internacional
Claves propias custodiadas en servicio de gestión de claves, con módulo de seguridad dedicado para las de mayor criticidad	La entidad controla el material criptográfico; revocación efectiva; refuerza la base de legitimación de la transferencia	Coste del módulo dedicado; responsabilidad sobre la custodia y la rotación
Módulo criptográfico propio en las instalaciones del banco	Control máximo	Latencia desde la nube; complejidad de alta disponibilidad; punto único de fallo

Decisión. Claves gestionadas por la entidad: claves maestras propias en el servicio de gestión de claves para el cifrado general, y **módulo de seguridad dedicado** para las claves de mayor criticidad —firma de evidencias de auditoría y protección de datos de categoría especial—. Los secretos de integración residen en un gestor de secretos con **rotación automática** y se inyectan en tiempo de ejecución; **ningún secreto reside en repositorios ni en imágenes**, y su presencia se verifica automáticamente en el proceso de construcción.

Justificación 1. Principio de separación entre custodia del dato y custodia de la clave. Cuando la entidad controla el material criptográfico, el proveedor que aloja la información no puede acceder a ella en claro. Esta separación es la que sostiene técnicamente la garantía adicional que exige la transferencia internacional de datos personales, y convierte un argumento jurídico en un hecho verificable. **2. Principio de rotación sin interrupción.** Un secreto que no puede rotarse sin cortar el servicio no se rota, y acaba siendo permanente. Diseñar desde el inicio con dos credenciales válidas durante la transición hace que la rotación periódica sea operativamente posible en lugar de teóricamente exigible.

Consecuencias. Se asume el coste del módulo dedicado y la responsabilidad sobre la custodia: la pérdida del material criptográfico implicaría la pérdida irreversible del acceso a la información cifrada, lo que obliga a procedimientos estrictos de respaldo y recuperación de claves.

Verificación. Comprobación de que ningún secreto figura en repositorios ni en imágenes; ensayo de rotación sin interrupción; verificación de que la información cifrada es ilegible sin las claves de la entidad.

Trazabilidad. H-24 · ADR-03 · RES-06 · **Criterio 13**

ADR-50 · Cumplimiento expresado como código

Contexto. Las obligaciones de ADR-47 deben mantenerse a lo largo del tiempo, no solo en el momento de la auditoría. Esta es la mejora M-05 identificada en el análisis.

Opciones evaluadas

Opción	A favor	En contra
Revisión manual periódica	Sin desarrollo	Comprueba el estado en un instante; entre revisiones, cualquier desviación pasa inadvertida
Listas de comprobación en la revisión de cambios	Integrado en el proceso	Depende del criterio y la constancia del revisor; no cubre cambios en la configuración de infraestructura
Controles expresados como políticas verificadas de forma automática	Impide la desviación en lugar de detectarla; produce evidencia continua	Requiere traducir cada obligación a una regla verificable

Decisión. Traducir los controles derivados de la normativa a **políticas verificadas automáticamente**, en dos momentos: - **Preventivo**, en el proceso de construcción y en la admisión de cargas: rechazo de despliegues sin cifrado, sin clasificación de datos, con imágenes no aprobadas, con secretos incrustados o sin dueño declarado. - **Detectivo**, de forma continua sobre el entorno: verificación permanente de configuración, con corrección automática donde sea posible y alerta donde no.

Cada política referencia **la obligación normativa que la origina**, de modo que el informe de cumplimiento se genera a partir del estado real del sistema.

Justificación 1. Principio de control preventivo sobre detectivo. Impedir que una configuración no conforme llegue a producción es cualitativamente superior a detectarla después: evita la ventana de exposición y el coste de la corrección, que en un entorno regulado incluye la notificación del incidente. **2. Principio de evidencia continua frente a evidencia puntual.** Una auditoría anual demuestra el estado en una fecha; no dice nada de los trescientos sesenta y cuatro días restantes. La verificación continua produce evidencia del estado en todo momento, que es lo que realmente responde a la pregunta del supervisor.

Consecuencias. Se asume el esfuerzo de traducir cada obligación a una regla verificable, trabajo conjunto con Cumplimiento. Se asume que una política mal formulada puede bloquear despliegues legítimos, por lo que toda política se despliega primero en modo observación antes de pasar a modo bloqueo.

Verificación. Intento deliberado de desplegar una configuración no conforme, comprobando el rechazo; generación del informe de cumplimiento a partir del estado real y contraste con una revisión manual de muestra.

Bloque K · Costos y eficiencia del rendimiento

ADR-51 · Modelo de costos y optimización

Contexto. El enunciado indica que existe presupuesto, pero el criterio 9 evalúa el **manejo de costos** (H-08). La Fase 1 fijó el objetivo de **≤ 0,06 USD por usuario digital activo al mes**, unos 108.000 USD mensuales para la base prevista.

Opciones evaluadas

Opción	A favor	En contra
Dimensionar para el pico y mantenerlo	Sin riesgo de saturación	Se paga permanentemente una capacidad utilizada unas pocas horas al día; desperdicio proporcional a la relación pico/media, aquí de 6,5×
Dimensionar para la media y aceptar degradación en el pico	Coste mínimo	Incumple los escenarios de rendimiento en el momento de mayor valor para el negocio
Capacidad base reservada para la demanda sostenida y capacidad elástica para el pico	Coste proporcional al uso; cumple los objetivos en el pico	Requiere previsión de la base y ajuste del escalado

Decisión. Capacidad base reservada más elasticidad para el pico, con seis palancas de optimización y control de consumo:

Palanca	Aplicación	Efecto esperado
Compromisos de uso a plazo	Capacidad base de cómputo y bases de datos	Reducción significativa sobre el precio bajo demanda para la parte predecible
Procesadores de arquitectura eficiente	Servicios de dominio y bases de datos	Mejor relación precio-rendimiento a igualdad de capacidad
Escalado por indicador adecuado	Consumidores de eventos escalados por retraso de cola, no por procesador	Capacidad ajustada a la demanda real de trabajo pendiente
Almacenamiento por niveles	Auditoría y evidencias (ADR-32)	El archivo de siete años deja de pagarse a precio de acceso inmediato
Coste evitado por caché y proyección	Reducción del tráfico que alcanza el Core	La palanca de mayor impacto: evita ampliar la capacidad del Core, que es el recurso más caro y menos elástico
Muestreo adaptativo de telemetría	Observabilidad (ADR-44)	Conserva íntegro lo relevante y reduce el volumen del tráfico sin incidencias

Control: etiquetado obligatorio de todo recurso con servicio, entorno y capacidad de negocio, verificado en el despliegue; presupuestos con alerta por desviación; revisión mensual de coste por capacidad frente al objetivo.

Justificación 1. **Principio de coste como atributo de calidad medible.** Un coste sin objetivo declarado ni medición periódica no se gestiona: se constata a fin de mes. Fijar un objetivo por usuario activo convierte el coste en un indicador con responsable, comparable en el tiempo y ligado al crecimiento real del negocio. 2. **Principio de prioridad del coste evitado sobre el coste optimizado.** Negociar el precio del cómputo produce ahorros porcentuales; evitar la ampliación de la capacidad del Core —un sistema con licenciamiento propio y elasticidad nula— evita un gasto de otro orden de magnitud. La arquitectura de separación entre consulta y comando (ADR-28) es, además de una decisión de rendimiento, la principal decisión de coste del proyecto. 3. **Principio de imputación como condición de la optimización.** Sin etiquetado que permita atribuir el gasto a una capacidad concreta, la optimización se convierte en recortes indiscriminados. La imputación es lo que permite decidir con criterio qué merece su coste y qué no.

Consecuencias. Se asume el compromiso de plazo en la capacidad reservada, que reduce flexibilidad a cambio de precio. Se asume la disciplina de etiquetado, verificada automáticamente (ADR-50).

Verificación. Medición mensual del coste por usuario activo frente al objetivo; comprobación de que todo recurso está etiquetado; contraste entre el coste proyectado y el real tras el primer trimestre.

ADR-52 · Eficiencia del rendimiento

Contexto. El enunciado exige garantizar **baja latencia** (RNF-08) y los escenarios fijan objetivos concretos: $p95 \leq 500$ ms en consulta, $\leq 1,5$ s en autenticación, ≤ 2 s en transferencia.

Opciones evaluadas

Opción	A favor	En contra
Sobredimensionar la capacidad	Solución inmediata	La latencia de un sistema distribuido depende del número de saltos y de la distancia, no solo de la capacidad: añadir servidores no reduce el tiempo de ida y vuelta
Optimizar el código en profundidad	Sin coste de infraestructura	Esfuerzo elevado y disperso si no se sabe dónde se consume el tiempo
Presupuesto de latencia repartido, con caché en tres niveles y medición continua	Actúa donde está el tiempo real; objetivos verificables por tramo	Requiere instrumentación y disciplina de medición

Decisión. Presupuesto de latencia repartido por escenario, asignando a cada tramo una porción del objetivo total, con: - **Tres niveles de caché**: en el borde para contenido estático y respuestas cacheables, distribuida para datos de cliente (ADR-29) y local en el dispositivo para el histórico reciente (ADR-12). - **Terminación de la conexión segura cerca del cliente** y encaminamiento por red troncal del proveedor (ADR-03). - **Conexiones persistentes y agrupadas** hacia las dependencias, evitando el coste de establecimiento en cada llamada. - **Compresión** de las respuestas y limitación de los campos devueltos por canal (ADR-09). - **Pruebas de carga continuas** en el proceso de entrega, con los objetivos como criterio de aceptación.

Justificación 1. **Principio de presupuesto repartido desde el objetivo global.** Los compromisos son de extremo a extremo, de modo que cada tramo debe recibir una asignación derivada del total. Optimizar tramos aisladamente sin esa perspectiva conduce a mejorar lo que ya era rápido mientras el compromiso agregado se sigue incumpliendo. 2. **Principio de medir antes de optimizar.** En un sistema distribuido, la intuición sobre dónde se consume el tiempo es habitualmente errónea: con frecuencia domina el establecimiento de conexiones o la distancia física, no el procesamiento. La instrumentación de ADR-44 es requisito previo de cualquier optimización, no un complemento posterior.

Consecuencias. Se asume el coste de la red de entrega y de la caché distribuida, ampliamente compensado por el coste evitado en el Core (ADR-51). Se asume que los objetivos de latencia se convierten en criterio de aceptación que puede bloquear una entrega.

Verificación. Prueba de carga a 1.500 peticiones/s verificando los objetivos de cada escenario; descomposición de la latencia por tramo comprobando que cada uno respeta su asignación.

Trazabilidad. RNF-08 · ASR-05, ASR-07, ASR-19 · **Criterios 8 y 9**

Resumen de los bloques H, I, J y K

ADR	Pilar	Decisión
40	Fiabilidad	Activo-activo en tres zonas con holgura N+1
41	Fiabilidad	Celdas en el camino transaccional, con despliegue progresivo celda a celda
42	Fiabilidad	Entorno secundario templado con ensayo trimestral cronometrado
43	Fiabilidad	Catálogo de modos degradados acordados con negocio
44	Excelencia operativa	Instrumentación estándar abierta, con métricas de negocio y vigilancia de ausencia
45	Excelencia operativa	Despliegue declarativo, progresivo y con terminación ordenada
46	Excelencia operativa	Objetivos por capacidad con presupuesto de error y alertas accionables
47	Seguridad	Marco normativo en tres capas, con mapeo obligación-control

ADR	Pilar	Decisión
48	Seguridad	Cinco capas independientes de control
49	Seguridad	Claves propias con módulo dedicado; rotación sin interrupción
50	Seguridad	Cumplimiento expresado como políticas verificadas automáticamente
51	Costos	Base reservada más elasticidad; el coste evitado en el Core como palanca principal
52	Rendimiento	Presupuesto de latencia repartido con caché en tres niveles

Fase 2 completada: 52 decisiones arquitectónicas.

Capítulo 7 · Nivel 1 · Diagrama de contexto

Figura 1. diagramas/C4-1-contexto.svg · fuente editable: diagramas/C4-1-contexto.drawio

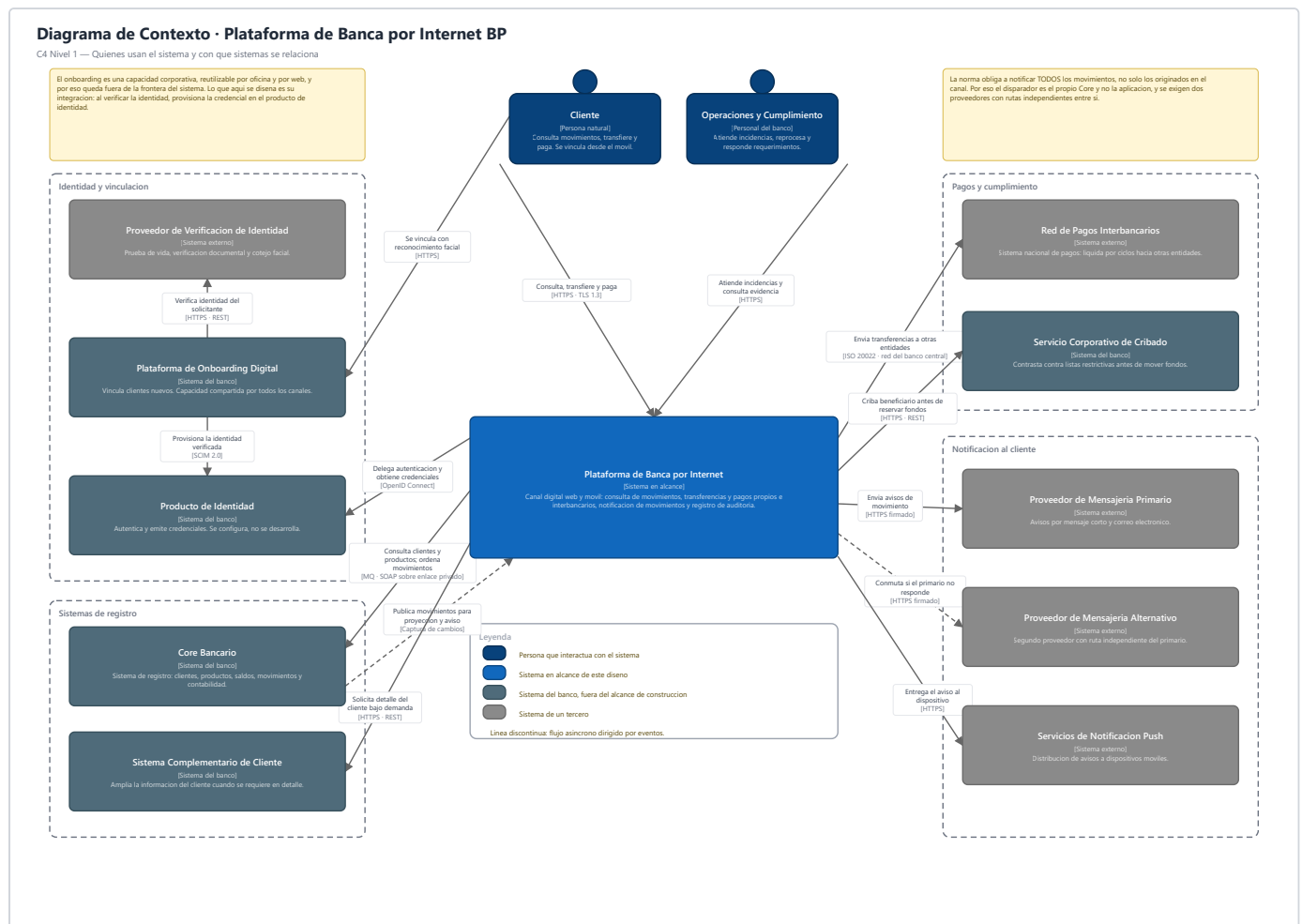


Figura 1. Diagrama de contexto · quiénes usan el sistema y con qué sistemas se relaciona

Fuente editable: diagramas/C4-1-contexto.drawio

1. Propósito y audiencia de este nivel

El enunciado pide que el diagrama de contexto sea **para usuarios no técnicos**. Por eso este nivel responde a tres preguntas y a ninguna más:

1. ¿Quién usa el sistema?
2. ¿Qué hace el sistema?
3. ¿Con qué otros sistemas necesita relacionarse, y para qué?

Deliberadamente **no aparece ninguna tecnología interna**: ni servicios, ni bases de datos, ni nube. Mezclar niveles de abstracción es el error más frecuente al aplicar C4 y resta valor precisamente a la audiencia a la que va dirigido. Las tecnologías que sí figuran son las de **frontera** —el protocolo por el que se habla con cada sistema externo—, porque son parte del acuerdo de integración y no un detalle interno.

2. Cómo leer el diagrama

Elemento	Significado
Azul oscuro, con figura de persona	Personas que interactúan con el sistema
Azul intenso, centro	El sistema que se diseña en este documento
Gris azulado	Sistemas del propio banco que existen y no se construyen aquí
Gris neutro	Sistemas de terceros
Recuadros discontinuos	Agrupación por afinidad funcional, no por propiedad
Línea continua	Interacción síncrona: alguien espera una respuesta
Línea discontinua	Flujo asíncrono dirigido por eventos

La agrupación por afinidad —identidad, registro, pagos, notificación— se ha preferido a la agrupación por propiedad —banco frente a terceros— porque el color ya distingue la propiedad y la proximidad ayuda más si refleja el propósito. Dentro del grupo "Identidad y vinculación" conviven un sistema del banco y uno externo precisamente porque colaboran en la misma capacidad.

3. Actores

Actor	Qué hace	Por qué está en el diagrama
Cliente	Consulta movimientos, transfiere y paga desde web y móvil; se vincula desde la aplicación móvil	Es el destinatario del sistema y el origen de la práctica totalidad de la carga
Operaciones y Cumplimiento	Atiende incidencias, reprocesa operaciones detenidas y responde requerimientos del regulador	La plataforma no solo sirve al cliente: debe ser operable y auditable . Omitir este actor produciría un diseño sin herramientas de explotación, que es una causa habitual de sistemas correctos sobre el papel e inviables en producción

4. El sistema en alcance

Plataforma de Banca por Internet: canal digital web y móvil que permite consultar movimientos, ordenar transferencias y pagos —a cuentas propias, a terceros de la misma entidad y a otras entidades—, notificar los movimientos conforme exige la norma y registrar la totalidad de la actividad del cliente para su posterior acreditación.

Lo que **no** incluye, y se muestra fuera de la frontera: el núcleo bancario, el sistema complementario de cliente, la plataforma de onboarding, el producto de identidad, el servicio corporativo de cribado y la red de pagos.

5. Sistemas relacionados y justificación de cada relación

5.1 Identidad y vinculación

Sistema	Relación	Por qué es así
Plataforma de Onboarding Digital (banco)	El cliente se vincula desde la aplicación móvil; al completarse, la plataforma provisiona la identidad en el producto de identidad	El onboarding es una capacidad corporativa , no de canal: también ocurre en oficina y en web. Incluirla dentro del sistema acoplaría una capacidad compartida a un canal concreto. El criterio de evaluación se titula "Arquitectura de Integración con Onboarding", lo que confirma que lo relevante es el enlace (ADR-17)
Proveedor de Verificación de Identidad (externo)	Realiza la prueba de vida, verifica el documento y coteja el rostro	Capacidad especializada que exige certificación independiente de detección de ataques de presentación. Se relaciona con el onboarding, no con el canal : el canal nunca manipula datos biométricos (ADR-18)
Producto de Identidad (banco)	Autentica a los clientes y emite las credenciales que el canal consume	El enunciado establece que el producto existe y solo se configura. El canal se integra por estándar, de modo que el producto sea sustituible (ADR-15)

5.2 Sistemas de registro

Sistema	Relación	Por qué es así
Core Bancario (banco)	El canal consulta clientes y productos y ordena movimientos; el Core publica sus cambios hacia el canal	La relación es bidireccional y de naturaleza distinta en cada sentido : síncrona para ordenar, asíncrona para enterarse. Esa segunda dirección es la que permite notificar movimientos originados fuera del canal y mantener actualizada la información de consulta sin castigar al Core (ADR-24, ADR-28)
Sistema Complementario de Cliente (banco)	Aporta el detalle del cliente solo cuando la pantalla lo requiere	El propio enunciado dice "cuando los datos se requieren en detalle". Consultarlo siempre multiplicaría la carga sobre el sistema de menor disponibilidad y haría depender de él la funcionalidad principal (ADR-39)

5.3 Pagos y cumplimiento

Sistema	Relación	Por qué es así
Red de Pagos Interbancarios (externo)	Recibe las transferencias dirigidas a otras entidades y las liquida por ciclos	Infraestructura del banco central. Impone horarios de corte y no admite transacciones distribuidas, lo que obliga a coordinar la operación con compensaciones (ADR-33)
Servicio Corporativo de Cribado (banco)	Contrasta al beneficiario contra listas restrictivas antes de reservar fondos	El orden importa: cribar después de mover dinero invierte la lógica del cumplimiento y dejaría a la entidad habiendo ejecutado una operación que debía impedir (ADR-35)

5.4 Notificación al cliente

Sistema	Relación	Por qué es así
Proveedor de Mensajería Primario (externo)	Entrega avisos por mensaje corto y correo electrónico	
Proveedor de Mensajería Alternativo (externo)	Asume la entrega cuando el primario no responde	El enunciado exige como mínimo dos sistemas de notificación . Se representan por separado, y no como una caja genérica, para hacer explícito el cumplimiento y la exigencia de rutas independientes : dos proveedores que compartan infraestructura fallarían a la vez y no aportarían redundancia real (ADR-36)
Servicios de Notificación Push (externo)	Distribuyen el aviso a los dispositivos móviles	Tercer canal, con características de entrega distintas

6. Dos decisiones que este diagrama hace visibles

6.1 La notificación se dispara en el Core, no en la aplicación

La flecha discontinua que va del Core hacia el sistema es probablemente el elemento más importante del diagrama, y responde a una lectura literal de la norma: hay que notificar **los movimientos realizados**, no "los realizados desde el canal digital". Un movimiento puede originarse en un cajero, en un comercio o en una transferencia entrante desde otra entidad.

Si el disparador fuese la aplicación, quedarían sin notificar todos los movimientos ajenos al canal, que son la mayoría. Situar el disparador en el sistema donde el movimiento se registra es la única forma de cubrir la totalidad de los casos.

6.2 El onboarding está fuera, pero su integración está dentro

El diagrama muestra al cliente vinculándose **directamente con la plataforma de onboarding** y a esta provisionando la identidad en el producto de identidad. El canal no participa en la verificación.

Esto responde a la separación entre **establecer** una identidad y **usarla**: son responsabilidades distintas, con ritmos de cambio y requisitos regulatorios distintos. Separarlas permite que la verificación evolucione —cambio de proveedor, nuevo requisito normativo— sin modificar el canal, y que los canales presenciales reutilicen exactamente el mismo proceso.

7. Trazabilidad

Elemento del diagrama	Requisito o decisión que lo origina
Cliente y sus tres interacciones	RF-01, RF-02, RF-03, RF-07
Actor de Operaciones y Cumplimiento	RF-09, ASR-10, criterio 12
Core como sistema de registro	RES-01, DRV-01, ADR-23
Flujo asíncrono desde el Core	H-06, RF-06, ADR-24, ADR-36
Sistema complementario bajo demanda	RF-05, H-18, ADR-39
Onboarding fuera de la frontera	H-20, ADR-17 · criterio 11
Proveedor de verificación de identidad	RF-07, H-26, ADR-18
Producto de identidad	RC-01, ADR-14, ADR-15
Dos proveedores de mensajería	RC-03, H-19, ADR-36
Cribado previo a la reserva de fondos	H-27, ADR-35
Red de pagos interbancarios	RF-03, H-07, ADR-33

8. Qué se responde en el siguiente nivel

Este diagrama no dice **cómo** está construido el sistema por dentro. El nivel de contenedores (Fase 4) muestra las aplicaciones, los servicios, los almacenes de datos y la mensajería que lo componen, junto con los protocolos entre ellos.

Capítulo 8 · Nivel 2 · Diagrama de contenedores

Figura 2. diagramas/C4-2-contenedores.svg · fuente editable: diagramas/C4-2-contenedores.drawio

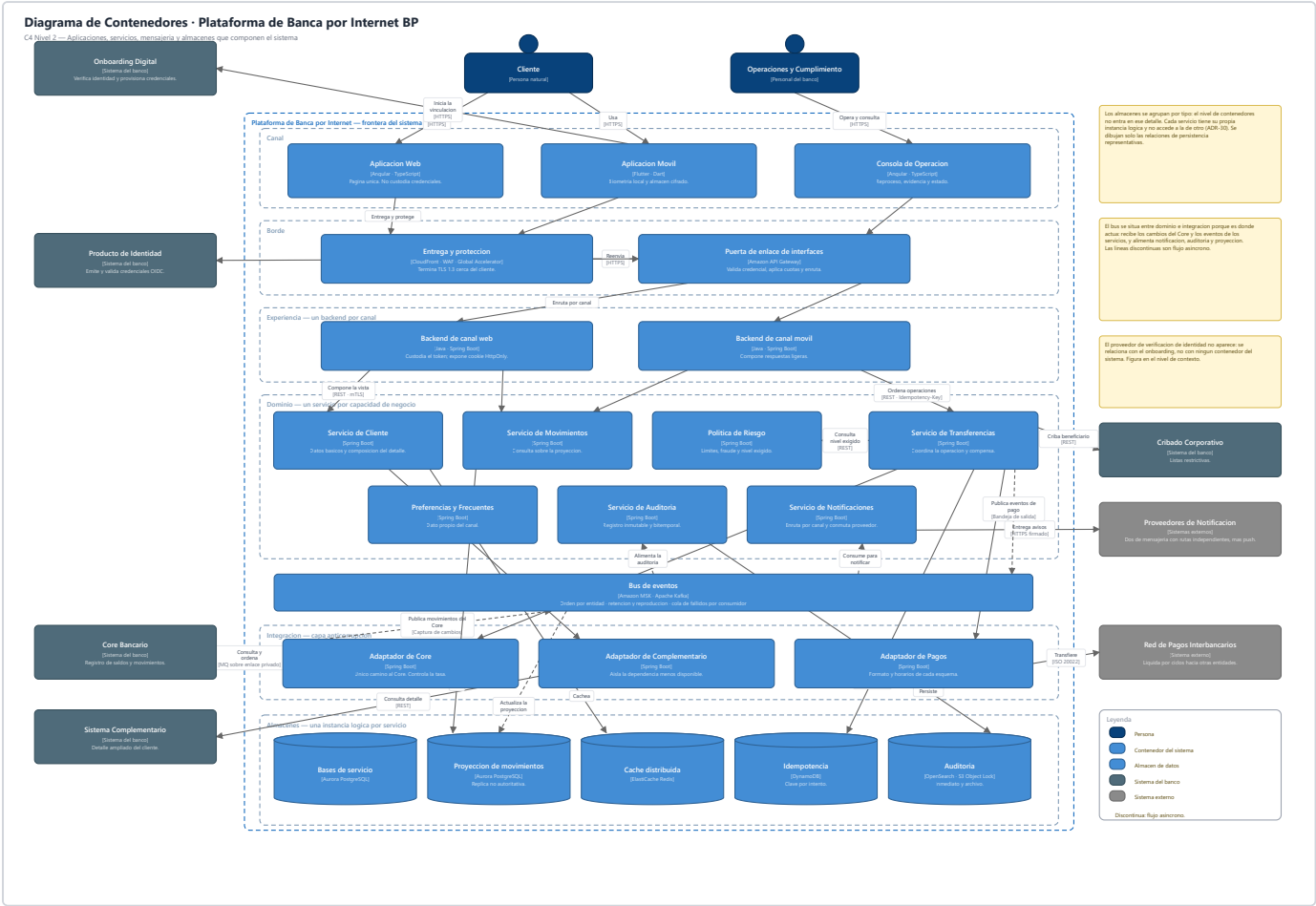


Figura 2. Diagrama de contenedores · aplicaciones, servicios, mensajería y almacenes
Fuente editable: diagramas/C4-2-contenedores.drawio

1. Propósito de este nivel

El enunciado pide que este diagrama sea **para técnicos** y represente "aplicaciones, servicios, bases de datos y mensajería, incluyendo componentes cloud sin mucho detalle".

Se abre la caja azul del nivel anterior y aparecen **32 elementos**: 3 aplicaciones de canal, 2 componentes de borde, 2 backends de experiencia, 7 servicios de dominio, 3 adaptadores de integración, 1 bus de eventos y 5 almacenes, más los sistemas con los que se relacionan.

A diferencia del nivel de contexto, aquí **sí aparece la tecnología de cada contenedor**, porque es una decisión de diseño que debe poder discutirse: cada caja indica el producto o marco con el que está construida.

2. Organización en capas

El diagrama se lee **de arriba abajo**, siguiendo el recorrido de una petición.

Capa	Contenedores	Responsabilidad
Canal	Aplicación Web, Aplicación Móvil, Consola de Operación	Interacción con las personas
Borde	Entrega y protección, Puerta de enlace	Terminación segura, protección y control de acceso

Capa	Contenedores	Responsabilidad
Experiencia	Backend de canal web, Backend de canal móvil	Composición de respuestas adaptadas a cada canal
Dominio	7 servicios por capacidad de negocio	Lógica de negocio
Mensajería	Bus de eventos	Desacoplamiento asíncrono
Integración	3 adaptadores	Traducción y aislamiento frente a sistemas externos
Almacenes	5 almacenes por patrón de acceso	Persistencia

Por qué el bus está en el centro y no al final

El bus de eventos se dibuja **entre el dominio y la integración**, no debajo de todo, porque es ahí donde actúa: recibe los cambios que publica el adaptador de Core y los eventos que publican los servicios, y alimenta hacia arriba a notificaciones y auditoría, y hacia abajo a la proyección de movimientos. Situarlo al final obligaría a que todas sus líneas atravesaran el diagrama, sugiriendo visualmente que es un destino cuando en realidad es un **punto de paso**.

3. Contenedores del canal

Contenedor	Tecnología	Por qué
Aplicación Web	Angular · TypeScript	Marco opinado que impone estructura entre equipos; tipado estático; soporte a largo plazo con calendario publicado (ADR-07). No custodia credenciales : las guarda su backend de canal
Aplicación Móvil	Flutter · Dart	Motor de renderizado propio: una sola superficie de prueba y certificación; compilación nativa para latencia predecible; acceso al enclave seguro sin bibliotecas de terceros (ADR-08)
Consola de Operación	Angular · TypeScript	Herramienta interna para reprocesar mensajes detenidos, consultar evidencia y responder requerimientos. Su ausencia sería un defecto de diseño : un sistema auditable necesita herramientas de explotación

4. Borde y experiencia

Entrega y protección (CloudFront, AWS WAF, Global Accelerator) termina la conexión segura en el punto de presencia más próximo al cliente y encamina el resto por la red troncal del proveedor. Es la medida que compensa la ausencia de región de nube en el país (ADR-03).

Puerta de enlace (Amazon API Gateway) valida la credencial contra las claves públicas del producto de identidad, aplica cuotas y enruta. **No contiene lógica de negocio**, lo que la hace sustituible (ADR-21).

Los dos backends de canal existen por tres razones (ADR-09): cada canal necesita un volumen de datos distinto, evolucionan a ritmos distintos, y —determinante— el backend web es el que **custodia el token de acceso**, de modo que el navegador solo recibe una cookie inaccesible desde JavaScript (ADR-10).

5. Los siete servicios de dominio

Se corresponden exactamente con el catálogo de ADR-38. Los tres primeros son los que exige el enunciado; los cuatro restantes se justificaron individualmente por tener **capacidad de negocio propia y perfil operativo diferenciado**:

Servicio	Origen	Razón de existir por separado
Cliente	Enunciado	Datos básicos y composición del detalle (ADR-39)
Movimientos	Enunciado	Consulta sobre la proyección, sin alcanzar el Core
Transferencias	Enunciado	Coordina la operación y sus compensaciones (ADR-33)
Política de Riesgo	Añadido	Cambia por decisión de negocio, no de tecnología; centraliza la decisión para poder demostrar qué política regía en cada momento
Notificaciones	Añadido	Perfil de carga muy distinto (500/s frente a 80/s) y dependencia de proveedores externos con cuotas propias
Auditoría	Añadido	10 millones de eventos diarios y 7 años de retención, con motor de persistencia propio

Servicio	Origen	Razón de existir por separado
Preferencias y Frecuentes	Añadido	Único conjunto de datos del que el canal es sistema de registro

Todos comparten tecnología (Spring Boot) por una razón de gobierno: un arquetipo común con resiliencia, trazas e idempotencia ya incorporadas reduce la variabilidad entre equipos (ADR-25).

6. Integración y almacenes

Los **tres adaptadores** materializan la capa anticorrupción de ADR-23. El de Core es especialmente relevante: es el **único camino** hacia el Core y concentra el control de tasa, lo que permite garantizar al área responsable un límite global de carga con independencia de cuántos servicios existan.

Los **cinco almacenes** se agrupan por patrón de acceso, según ADR-30:

Almacén	Tecnología	Patrón que lo justifica
Bases de servicio	Aurora PostgreSQL	Transaccionalidad e integridad referencial
Proyección de movimientos	Aurora PostgreSQL	Consultas por cliente y rango de fechas. Réplica derivada, no autoritativa (ADR-28)
Caché distribuida	ElastiCache Redis	Latencia de milisegundo y caducidad nativa
Idempotencia	DynamoDB	Acceso por clave a muy alto volumen con caducidad por registro
Auditoría	OpenSearch · S3 con Object Lock	Búsqueda sobre el periodo reciente e inmutabilidad para el archivo

El diagrama los muestra agrupados porque el nivel de contenedores no entra en ese detalle; **cada servicio dispone de su propia instancia lógica** y no accede a la de ningún otro.

7. Lo que el diagrama demuestra

7.1 La consulta no alcanza al Core

Siguiendo el camino de una consulta de movimientos: aplicación → borde → backend de canal → Servicio de Movimientos → **proyección**. El Core no aparece en ese recorrido. Es la materialización de la separación entre consulta y comando (ADR-28) y lo que permite comprometer una disponibilidad del 99,95 % pese a que el Core ofrece 99,5 %.

7.2 La notificación nace en el Core

El recorrido de una notificación empieza abajo: Core → adaptador → **bus** → Servicio de Notificaciones → proveedores. No pasa por ninguna aplicación de canal, porque debe cubrir también los movimientos originados en cajero, comercio o abonos entrantes (H-06, ADR-36).

7.3 Ninguna transferencia se ejecuta sin control previo

El Servicio de Transferencias consulta a Política de Riesgo el nivel de autenticación exigido y criba al beneficiario **antes** de tocar el adaptador de Core, que es donde se reservan los fondos (ADR-35).

8. Trazabilidad

Elemento	Decisión que lo origina
Tres aplicaciones de canal	ADR-07, ADR-08, criterio 6
Entrega y protección en el borde	ADR-03, ADR-21
Un backend por canal, con el token custodiado	ADR-09, ADR-10
Siete servicios de dominio	ADR-38 · RC-04
Bus de eventos con bandeja de salida	ADR-24

Elemento	Decisión que lo origina
Tres adaptadores	ADR-23, ADR-35, ADR-39
Cinco almacenes por patrón de acceso	ADR-30
Proyección declarada no autoritativa	H-18, ADR-28
Consola de Operación	RF-09, ASR-10

9. Qué se responde en el siguiente nivel

Este diagrama muestra **qué contenedores existen**, no cómo están contruidos por dentro. La Fase 5 desglosa en componentes cuatro de ellos —el backend de canal, Transferencias, Auditoría y Notificaciones—, con sus patrones y los protocolos de comunicación junto con su protección.

Capítulo 9 · Nivel 3 · Diagramas de componentes

Figura 3. `diagramas/C4-3a-componentes-transferencias.svg` **Figura 4.** `diagramas/C4-3b-componentes-bff.svg`
Figura 5. `diagramas/C4-3c-componentes-auditoria.svg` **Figura 6.** `diagramas/C4-3d-componentes-notificaciones.svg`

Fuentes editables: los cuatro `.drawio` homónimos.

1. Por qué cuatro diagramas y no uno

El enunciado pide para este nivel "mayor detalle técnico: microservicios, patrones arquitectónicos y **protocolos de comunicación con seguridad**".

La tentación es dibujar un único diagrama que abra todos los contenedores a la vez. Es un error de aplicación del modelo C4 y estaba registrado como riesgo **H-09**: el nivel 3 describe **el interior de un contenedor concreto**. Un diagrama que abriera los treinta y dos contenedores del nivel anterior produciría varios cientos de cajas, sería ilegible y, sobre todo, mezclaría dos preguntas distintas —*qué piezas existen y cómo está construida cada pieza*—.

Se abren **cuatro contenedores**, elegidos porque cada uno responde a una exigencia distinta del enunciado y porque entre los cuatro concentran los patrones que sostienen el diseño:

Contenedor abierto	Por qué este y no otro
Servicio de Transferencias	Es el contenedor donde se mueve el dinero: concentra la coordinación de la operación, sus compensaciones, la idempotencia y los controles previos
Backend de canal web	Es donde se custodia la credencial y donde se compone la respuesta: concentra las decisiones de seguridad del canal
Servicio de Auditoría	El enunciado exige registro de la actividad del cliente para su posterior acreditación : concentra las decisiones de inmutabilidad y prueba
Servicio de Notificaciones	El enunciado exige como mínimo dos sistemas de notificación : concentra las decisiones de conmutación y de evidencia

Los restantes contenedores se construyen sobre el **arquetipo común** de ADR-25 —resiliencia, trazas, idempotencia y auditoría ya incorporadas—, por lo que su estructura interna es una variación de la que muestran estos cuatro. Declararlo explícitamente es preferible a insinuar que los demás no se han pensado.

2. Cómo leer estos diagramas

Elemento	Significado
Azul claro	Componente interno del contenedor que se está abriendo
Azul intenso	Otro contenedor del sistema, dibujado fuera del recuadro
Cilindro	Almacén de datos
Gris azulado	Sistema fuera del contenedor
Recuadro discontinuo azul	Frontera del contenedor: lo de dentro se despliega junto
Etiqueta [...] sobre la flecha	Protocolo y su protección en ese tramo concreto
Línea discontinua	Flujo asíncrono o camino de excepción

Un componente no es un despliegue independiente: es una **unidad de código con una responsabilidad propia** dentro del mismo proceso. Confundir componente con microservicio es el segundo error habitual del nivel 3, y es el que lleva a plataformas con decenas de servicios diminutos que solo se llaman entre sí.

2.1 Dónde está cada cosa que el enunciado pide en este nivel

El enunciado pide tres cosas concretas. Conviene señalar dónde se encuentra cada una, porque las tres conviven en el mismo dibujo:

Lo que pide el enunciado	Dónde está en los diagramas
Microservicios	Son las cajas azul intenso dibujadas fuera del recuadro : Política de Riesgo, Adaptador de Core, Adaptador de Pagos, Servicios de dominio, Backend de canal. El recuadro discontinuo delimita el microservicio que se está abriendo; lo de dentro son sus componentes, no servicios adicionales
Patrones arquitectónicos	Rotulados en la segunda línea de cada componente , entre corchetes: <i>Idempotent Receiver</i> , <i>Process Manager</i> , <i>Transactional Outbox</i> , <i>Token Handler</i> , <i>Bulkhead</i> , <i>Hash Chain</i> ... Consolidados en la sección 8
Protocolos de comunicación con seguridad	Rotulados sobre cada flecha entre corchetes, indicando protocolo y protección: <code>REST · mTLS</code> , <code>gRPC · mTLS</code> , <code>Kafka · mTLS · SASL</code> , <code>OIDC · TLS 1.3</code> , <code>MQ · enlace privado</code> ... Consolidados en la sección 7
Componentes cloud destacados	Dibujados como cilindros y contenedores con su producto nombrado: Amazon MSK, Aurora PostgreSQL, DynamoDB, ElastiCache Redis, Amazon OpenSearch, S3 con Object Lock, Amazon API Gateway

3. Servicio de Transferencias (Figura 3)

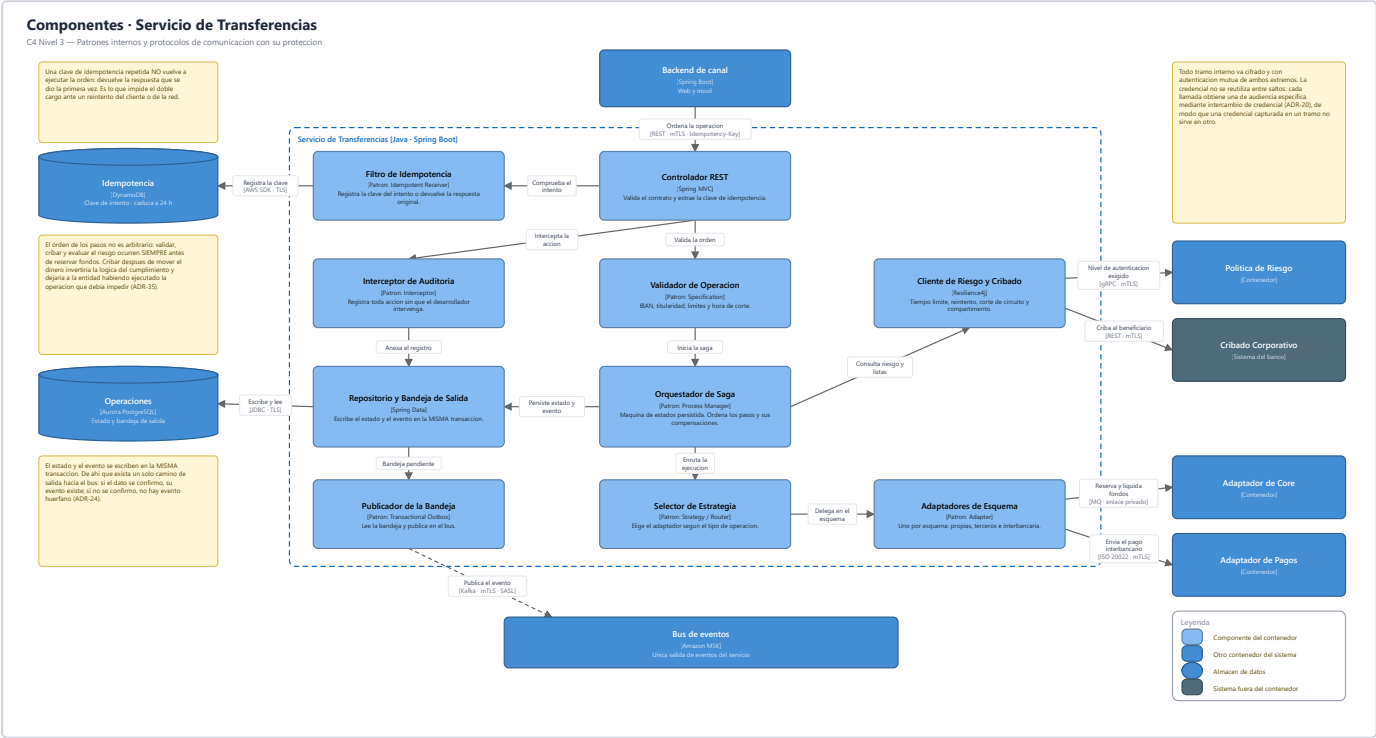


Figura 3. Componentes del Servicio de Transferencias · patrones y protocolos con su protección

Fuente editable: [diagramas/C4-3a-componentes-transferencias.drawio](#)

3.1 Componentes y patrón que los justifica

Componente	Patrón	Responsabilidad	Por qué separado
Controlador REST	—	Valida el contrato de entrada y extrae la clave de idempotencia	Frontera del servicio: ningún otro componente conoce el formato de transporte
Filtro de Idempotencia	<i>Idempotent Receiver</i>	Registra el intento o devuelve la respuesta original	Es un filtro , no una comprobación dentro de la lógica: así ningún desarrollador puede olvidarla al añadir una operación (ADR-34)
Interceptor de Auditoría	<i>Interceptor</i>	Anexa el registro de actividad a la bandeja de salida	Igual razón: la auditoría no puede depender de que alguien se acuerde de escribirla
Validador de Operación	<i>Specification</i>	IBAN, titularidad, límites y hora de corte	Las reglas cambian por decisión de negocio; aisladas, se prueban sin levantar el resto
Cliente de Riesgo y Cribado	<i>Circuit Breaker + Bulkhead</i>	Consulta el nivel de autenticación exigido y criba al beneficiario	Encapsula la resiliencia frente a dos sistemas externos con perfiles de fallo distintos (ADR-27)
Orquestador de Saga	<i>Process Manager</i>	Máquina de estados persistente: ordena pasos y compensaciones	La coordinación explícita es lo que permite responder "¿en qué paso quedó la operación?" (ADR-33)

Componente	Patrón	Responsabilidad	Por qué separado
Repositorio y Bandeja de Salida	<i>Repository + Transactional Outbox</i>	Escribe estado y evento en la misma transacción	Es el componente que hace innecesaria una transacción distribuida (ADR-24)
Publicador de la Bandeja	<i>Transactional Outbox</i>	Lee la bandeja y publica en el bus	Separado del repositorio porque su ritmo y su modo de fallo son distintos: publica en segundo plano y reintenta
Selector de Estrategia	<i>Strategy / Router</i>	Elige el adaptador según el tipo de operación	Añadir un cuarto tipo de transferencia no obliga a tocar el orquestador (ADR-35)
Adaptadores de Esquema	<i>Adapter</i>	Uno por esquema: propias, terceros e interbancaria	Cada esquema tiene destino, formato y horario propios

3.2 Lo que el diagrama demuestra

Ningún camino llega al dinero sin pasar antes por los controles. El orquestador consulta riesgo y listas restrictivas *antes* de delegar en el selector de estrategia, que es quien alcanza el adaptador de Core donde se reservan los fondos. Cribar después de mover el dinero invertiría la lógica del cumplimiento (ADR-35, H-27).

Existe un solo camino de salida hacia el bus. Todo evento —incluido el de auditoría— pasa por la bandeja de salida y su publicador. No hay ningún componente que publique directamente. Esa es la garantía estructural de que *si el dato se confirmó, su evento existe; y si no se confirmó, no hay evento huérfano*.

La idempotencia es un filtro, no una recomendación. Está situada antes de cualquier lógica de negocio. Una clave repetida devuelve la respuesta que se dio la primera vez; no vuelve a ejecutar nada.

4. Backend de canal web (Figura 4)

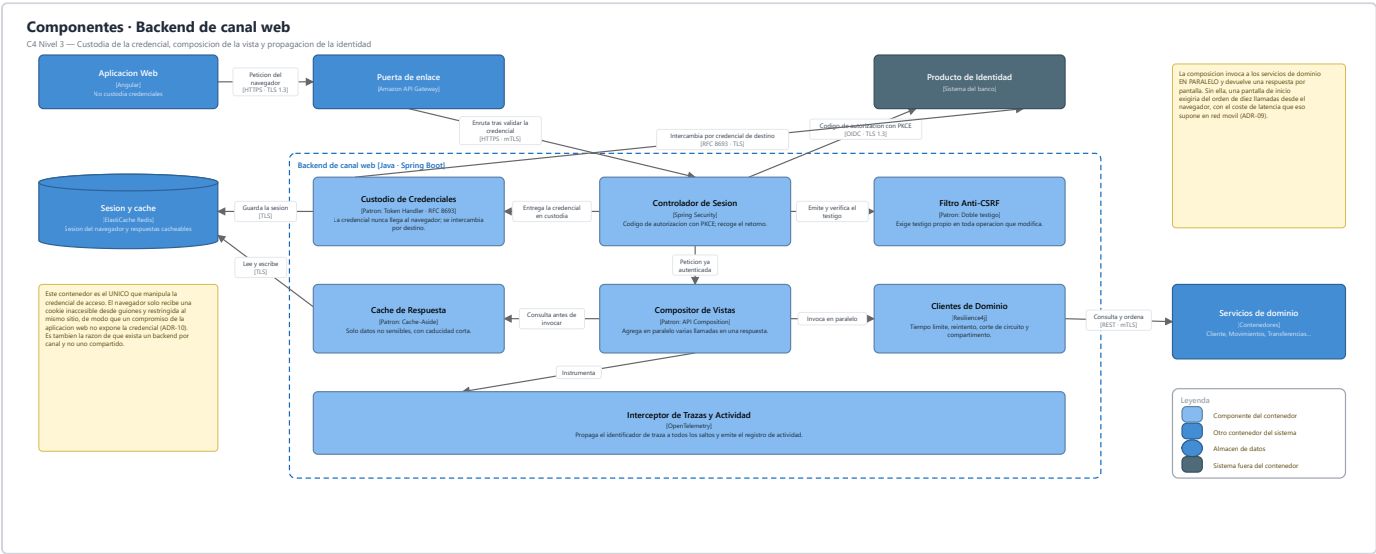


Figura 4. Componentes del backend de canal web · custodia de la credencial y composición

Fuente editable: [diagramas/C4-3b-componentes-bff.drawio](#)

4.1 Componentes y patrón que los justifica

Componente	Patrón	Responsabilidad
Controlador de Sesión	—	Inicia el flujo de código de autorización con PKCE y recoge el retorno
Custodio de Credenciales	<i>Token Handler + RFC 8693</i>	Guarda la credencial del lado del servidor y la intercambia por una de audiencia específica en cada salto
Filtro Anti-CSRF	<i>Doble testigo</i>	Exige un testigo propio en toda operación que modifica estado
Compositor de Vistas	<i>API Composition</i>	Agrega en paralelo varias llamadas de dominio en una sola respuesta por pantalla
Clientes de Dominio	<i>Circuit Breaker + Bulkhead</i>	Tiempo límite, reintento y compartimento por dependencia
Caché de Respuesta	<i>Cache-Aside</i>	Solo datos no sensibles, con caducidad corta

Componente	Patrón	Responsabilidad
Interceptor de Trazas y Actividad	Interceptor	Propaga el identificador de traza a todos los saltos y emite el registro de actividad

4.2 La decisión que este diagrama hace visible

El **Custodio de Credenciales** es el único componente que manipula la credencial de acceso. El navegador recibe exclusivamente una cookie inaccesible desde guiones y restringida al mismo sitio. La consecuencia es concreta y verificable: **un compromiso del código que se ejecuta en el navegador no expone la credencial**, porque allí no hay ninguna (ADR-10).

Ese es, además, el argumento que sostiene la existencia de un backend **por canal** en lugar de uno compartido: la aplicación móvil custodia su propia credencial en el enclave seguro del dispositivo y no necesita este componente, mientras que el navegador no dispone de almacenamiento equivalente (ADR-09, ADR-13).

El **Compositor de Vistas** justifica la otra mitad del patrón: sin él, una pantalla de inicio exigiría del orden de diez llamadas desde el navegador, con el coste de latencia que eso supone sobre red móvil (ASR-19).

5. Servicio de Auditoría (Figura 5)

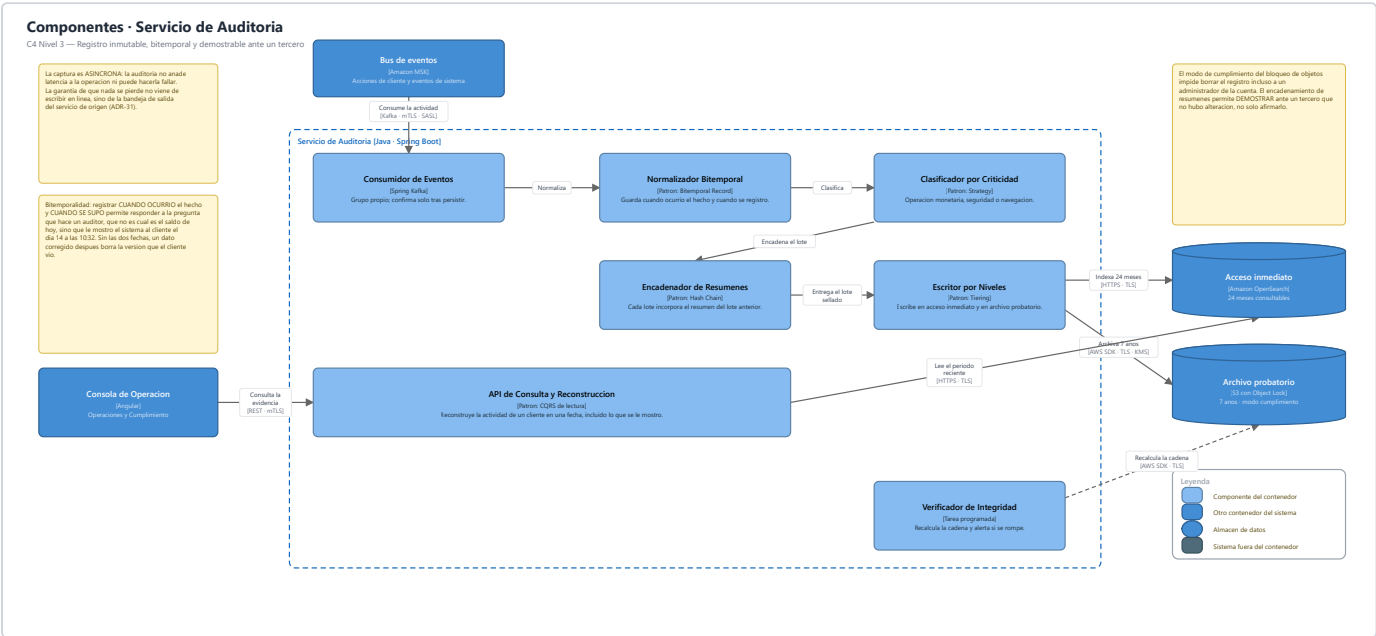


Figura 5. Componentes del Servicio de Auditoría · registro bitemporal, inmutable y verificable

Fuente editable: diagramas/C4-3c-componentes-auditoria.drawio

5.1 Componentes y patrón que los justifica

Componente	Patrón	Responsabilidad
Consumidor de Eventos	Event Consumer	Grupo de consumo propio; confirma solo tras persistir
Normalizador Bitemporal	Bitemporal Record	Registra cuándo ocurrió el hecho y cuándo se supo
Clasificador por Criticidad	Strategy	Distingue operación monetaria, seguridad y navegación, que tienen retenciones distintas
Encadenador de Resúmenes	Hash Chain	Cada lote incorpora el resumen del lote anterior
Escritor por Niveles	Tiering	Escribe en acceso inmediato (24 meses) y en archivo probatorio (7 años)
API de Consulta y Reconstrucción	CQRS de lectura	Reconstruye la actividad de un cliente en una fecha, incluido lo que se le mostró
Verificador de Integridad	Tarea programada	Recalcula la cadena y alerta si se rompe

5.2 Las dos ideas que sostienen el diseño

La captura es asíncrona, y aun así no se pierde nada. La auditoría no añade latencia a la operación ni puede hacerla fallar. La garantía de completitud no viene de escribir en línea —que acoplaría la disponibilidad de la operación a la del registro—, sino de la bandeja de salida del servicio de origen (ADR-31). Es la misma pieza que aparece en la Figura 3.

Bitemporalidad no es un lujo académico. Un auditor no pregunta cuál es el saldo de hoy; pregunta **qué le mostró el sistema al cliente el día 14 a las 10:32**. Con una sola marca temporal, un dato corregido después borra la versión que el cliente efectivamente vio, y con ella la posibilidad de acreditar la actuación de la entidad.

Demostrar es distinto de afirmar. El modo de cumplimiento del bloqueo de objetos impide borrar el registro incluso a un administrador de la cuenta; el encadenamiento de resúmenes permite **demostrar ante un tercero** que no hubo alteración. Sin esa cadena, la entidad solo puede afirmar que su registro es íntegro.

6. Servicio de Notificaciones (Figura 6)

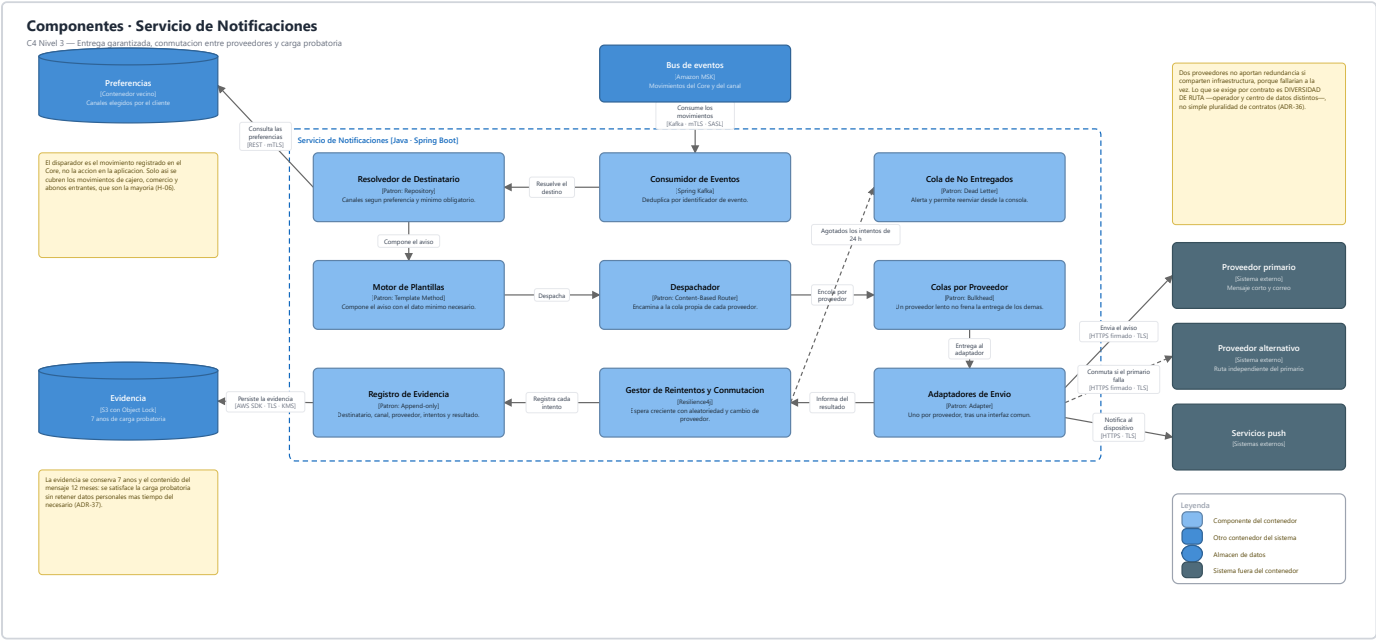


Figura 6. Componentes del Servicio de Notificaciones · conmutación y carga probatoria

Fuente editable: [diagramas/C4-3d-componentes-notificaciones.drawio](#)

6.1 Componentes y patrón que los justifica

Componente	Patrón	Responsabilidad
Consumidor de Eventos	<i>Idempotent Receiver</i>	Deduplica por identificador de evento: un evento reentregado no produce dos avisos
Resolvedor de Destinatario	<i>Repository</i>	Canales según la preferencia del cliente y el mínimo obligatorio por norma
Motor de Plantillas	<i>Template Method</i>	Compone el aviso con el dato mínimo necesario
Despachador	<i>Content-Based Router</i>	Encamina a la cola propia de cada proveedor
Colas por Proveedor	<i>Bulkhead</i>	Un proveedor lento no frena la entrega de los demás
Adaptadores de Envío	<i>Adapter</i>	Uno por proveedor, tras una interfaz común
Gestor de Reintentos y Conmutación	<i>Retry with backoff + Circuit Breaker</i>	Espera creciente con aleatoriedad y cambio de proveedor
Cola de No Entregados	<i>Dead Letter</i>	Alerta y permite reenviar desde la consola
Registro de Evidencia	<i>Append-only</i>	Destinatario, canal, proveedor, intentos y resultado de cada envío

6.2 Tres decisiones que el diagrama hace explícitas

El disparador es el movimiento registrado, no la acción en la aplicación. La entrada del servicio es el bus, alimentado por la captura de cambios del Core. Solo así se cubren los movimientos de cajero, comercio y abonos entrantes, que son la mayoría (H-06).

Dos proveedores no son redundancia si comparten infraestructura. Lo que se exige por contrato es **diversidad de ruta** —operador y centro de datos distintos—, no simple pluralidad de contratos (ADR-36). El diagrama los dibuja separados precisamente para que la exigencia sea visible y contrastable.

La evidencia y el contenido tienen retenciones distintas. La evidencia del envío se conserva siete años; el contenido del mensaje, doce meses. Se satisface la carga probatoria sin retener datos personales más tiempo del necesario (ADR-37, LOPDP).

7. Protocolos y su protección

El enunciado exige que este nivel muestre los protocolos **con su seguridad**. Los cuatro diagramas los rotulan sobre cada flecha; aquí se consolidan y se explica la regla que decide cuál se usa.

Tramo tal como aparece en los diagramas	Protocolo	Protección	Regla de ADR-22 que lo decide
Navegador → Puerta de enlace	HTTPS	TLS 1.3	Tramo público: prima el coste de establecimiento en red móvil
Puerta de enlace → Backend de canal	HTTPS REST	TLS + autenticación mutua	Frontera organizativa: contrato inspeccionable
Backend de canal → Servicios de dominio	REST/JSON	Autenticación mutua + credencial acotada por destino	Cruza equipos: legibilidad sobre rendimiento marginal
Backend de canal ↔ Producto de Identidad	OpenID Connect / RFC 8693	TLS 1.3, PKCE, validación de firma	Estándar que mantiene sustituible el producto
Backend de canal ↔ Sesión y caché	Protocolo del almacén	TLS	Almacén propio del contenedor
Transferencias → Política de Riesgo	gRPC sobre HTTP/2	Autenticación mutua	Camino crítico de alto volumen: una llamada por transferencia, misma plataforma. Es el único tramo que cumple los dos requisitos de la regla
Transferencias → Cribado Corporativo	REST	Autenticación mutua	Sistema corporativo de otra unidad: frontera organizativa
Adaptadores → Adaptador de Core	El que el Core exponga (colas)	Enlace privado + cifrado	El Core no se modifica (ADR-23)
Adaptadores → Adaptador de Pagos	ISO 20022	Autenticación mutua	Impuesto por la infraestructura del banco central
Publicación y consumo de eventos	Apache Kafka	TLS, autenticación mutua o SASL, listas de control por tema	Orden por clave, retención y reproducción
Notificaciones → Proveedores	HTTPS REST	TLS + credencial de cliente + firma del mensaje	Interfaz de terceros: integridad además de cifrado
Escritura en almacenes gestionados	Interfaz del proveedor	TLS + cifrado en reposo con clave gestionada	Datos en reposo bajo control de claves propias (ADR-49)

Dos observaciones que conviene poder defender.

Primera: **gRPC aparece exactamente una vez.** El catálogo de ADR-22 lo admite para "servicio ↔ servicio en camino crítico de alto volumen", y al bajar al nivel de componentes solo un tramo cumple simultáneamente ambas condiciones. Extenderlo a los demás tramos internos sería incoherente con el principio de economía de variedad del propio ADR.

Segunda: **no hay ningún tramo sin cifrar ni sin autenticar, tampoco los internos.** La distinción entre "red interna segura" y "red externa insegura" es precisamente la premisa que convierte un compromiso perimetral en un compromiso total.

8. Catálogo de patrones utilizados

Consolidado de los cuatro diagramas, con el problema concreto que resuelve cada uno:

Patrón	Dónde aparece	Problema que resuelve
<i>Idempotent Receiver</i>	Transferencias, Notificaciones	Reintento del cliente o reentrega del bus que produciría un doble cargo o un doble aviso
<i>Process Manager (Saga)</i>	Transferencias	Coordinar pasos sobre sistemas que no admiten transacción distribuida, con compensación explícita
<i>Transactional Outbox</i>	Transferencias	Publicar un evento sin transacción distribuida y sin eventos huérfanos
<i>Interceptor</i>	Transferencias, Backend de canal	Que la auditoría y la trazabilidad no dependan de que nadie las olvide
<i>Specification</i>	Transferencias	Reglas de negocio que cambian a ritmo propio y deben probarse aisladas
<i>Strategy / Router</i>	Transferencias, Auditoría, Notificaciones	Añadir un caso nuevo sin modificar el coordinador
<i>Adapter</i>	Transferencias, Notificaciones	Aislar formatos y modos de fallo de cada destino
<i>Token Handler</i>	Backend de canal	Que la credencial de acceso no llegue nunca al navegador
<i>API Composition</i>	Backend de canal	Reducir a una las llamadas necesarias por pantalla
<i>Cache-Aside</i>	Backend de canal	Latencia sin convertir la caché en sistema de registro
<i>Circuit Breaker + Bulkhead</i>	Los cuatro	Que la lentitud de una dependencia no agote los recursos del servicio ni se propague
<i>Retry with backoff</i>	Notificaciones	Reintentar sin amplificar la caída de un proveedor
<i>Dead Letter</i>	Notificaciones	Que un fallo definitivo sea visible y reprocesable, no silencioso
<i>Bitemporal Record</i>	Auditoría	Poder acreditar qué se le mostró al cliente, no solo cuál es el dato actual
<i>Hash Chain</i>	Auditoría	Demostrar la ausencia de alteración ante un tercero
<i>Tiering</i>	Auditoría	Conciliar consulta ágil del periodo reciente con retención de siete años a coste razonable
<i>CQRS de lectura</i>	Auditoría	Consultar sin interferir en la captura

9. Trazabilidad

Elemento de la Fase 5	Requisito, hallazgo o decisión que lo origina
Cuatro diagramas, uno por contenedor	H-09 · aplicación correcta del nivel 3 de C4
Protocolo rotulado en cada flecha	H-17 · ADR-22 · criterios 4 y 5
Filtro de idempotencia como primer paso	ADR-34 · ASR-06
Orquestador de saga con compensaciones	ADR-33 · H-07
Controles previos a la reserva de fondos	ADR-35 · H-27
Bandeja de salida como única salida de eventos	ADR-24 · ADR-31
Custodio de credenciales en el servidor	ADR-10 · ADR-09 · H-03
Intercambio de credencial por destino	ADR-20 · RFC 8693
Registro bitemporal y encadenado	ADR-31 · ADR-32 · RF-08
Dos proveedores con ruta independiente	ADR-36 · RC-03 · H-19
Evidencia probatoria a 7 años	ADR-37 · LOPDP
Arquetipo común para el resto de contenedores	ADR-25

10. Qué se responde en la siguiente fase

Estos diagramas muestran **cómo está construido cada contenedor por dentro**. La Fase 6 aporta los diagramas complementarios que el enunciado deja a criterio del arquitecto: el despliegue sobre la nube, las secuencias de los flujos críticos —vinculación, autenticación, transferencia interbancaria y notificación—, el modelo de datos, las zonas de seguridad, la recuperación ante desastres y el mapa de capacidades BIAN.

Capítulo 10 · Secuencias, despliegue, seguridad, datos, capacidades y plan

1. Por qué existen estos diagramas

El enunciado pide los tres niveles de C4 y añade: *"otros diagramas que crea conveniente"*. Esa frase es una de las pocas del enunciado donde el criterio del arquitecto se evalúa directamente: no dice cuáles, ni cuántos.

El criterio aplicado ha sido **un diagrama por pregunta que C4 no responde**. C4 describe la estructura estática del software; deja fuera el comportamiento en el tiempo, el despliegue físico, la propiedad del dato, la operación y la secuencia de entrega. Cada uno de los once diagramas de esta fase responde a una de esas preguntas y a ninguna otra.

#	Figura	Pregunta que responde	Qué exigencia del enunciado cubre
7	SEQ-1-vinculacion	¿Cómo se vincula un cliente y dónde queda la biometría?	Criterio 11 · onboarding
8	SEQ-2-autenticacion	¿Cómo se autentica y cuándo se exige refuerzo?	Criterio 10 · arquitectura de autenticación
9	SEQ-3-transferencia	¿Qué ocurre paso a paso y qué pasa si falla a mitad?	Criterios 4 y 5 · patrones e integración
10	SEQ-4-notificacion	¿Quién dispara el aviso y cómo se conmuta de proveedor?	Criterios 1 y 5 · requisito e integración
11	DEP-1-despliegue-aws	¿Dónde se ejecuta cada cosa físicamente?	Criterio 8 · conocimientos de nube
12	SEC-1-zonas-seguridad	¿Qué se detiene en cada capa?	Criterio 13 · seguridad
13	DR-1-recuperacion	¿Qué pasa si se pierde una región entera?	Criterio 14 · alta disponibilidad
14	DAT-1-mapa-de-datos	¿De quién es cada dato y cuánto se conserva?	Criterio 7 · arquitectura de acceso a datos
15	OBS-1-observabilidad	¿Cómo se sabe que el sistema funciona?	Criterio 15 · monitoreo
16	BIAN-1-capacidades	¿Qué capacidad de negocio cubre cada pieza?	Criterio 3 · segmentación de responsabilidades
17	RM-1-hoja-de-ruta	¿En qué orden se construye?	Recomendación muy valorada
18	PAT-1-patrones-cache-frecuentes	¿Qué componentes interactúan y bajo qué patrón para servir al cliente frecuente?	Instrucción literal · criterios 4 y 7

Nota sobre la Figura 18. El análisis (H-10) proponía doce diagramas complementarios, entre ellos uno de "patrones de auditoría y clientes frecuentes". Al revisar la cobertura se comprobó que la parte de auditoría ya estaba resuelta en el diagrama de componentes del Servicio de Auditoría (Figura 5) y en el mapa de datos (Figura 14), pero que la de **clientes frecuentes no lo estaba en ningún dibujo**, pese a que el enunciado pide de forma literal *"una alternativa basada en patrones de diseño que relacione los componentes que deberían interactuar"*. La Figura 18 cubre esa instrucción.

2. Cómo leer los diagramas de secuencia

Elemento	Significado
Caja superior	Participante: persona, contenedor o sistema externo
Línea discontinua vertical	Línea de vida del participante
Barra azul clara sobre la línea	Periodo en que ese participante está ocupado atendiendo la llamada
Flecha continua con punta llena	Llamada síncrona: quien llama espera respuesta
Flecha discontinua con punta abierta	Respuesta, o mensaje asíncrono que no bloquea
Banda gris horizontal	Fase del flujo: agrupa los pasos que persiguen un mismo objetivo

Elemento	Significado
Recuadro con pestaña alt	Caminos alternativos: la línea discontinua interior separa las ramas
[...] bajo el texto	Protocolo y su protección en ese mensaje

Las bandas de fase no forman parte de la notación estándar. Se han añadido porque un diagrama de veinte mensajes sin agrupación obliga a reconstruir mentalmente dónde empieza y acaba cada etapa.

3. Figura 7 · Vinculación del cliente

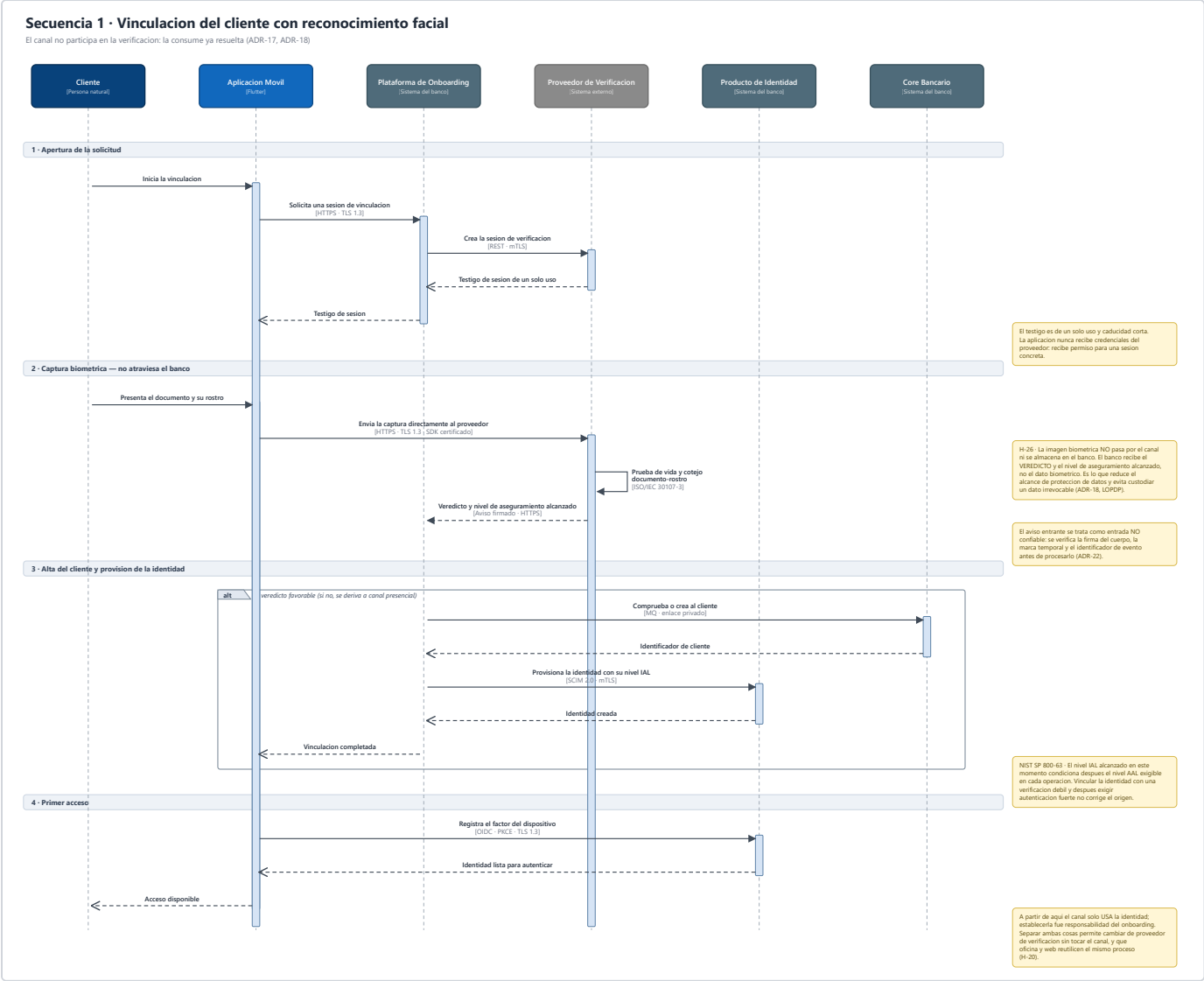


Figura 7. Secuencia · vinculación del cliente con reconocimiento facial

Fuente editable: `diagramas/SEQ-1-vinculacion.drawio`

La decisión que el diagrama hace visible: la imagen biométrica va **directamente de la aplicación al proveedor de verificación**, sin pasar por el banco.

No es un detalle de implementación. Tiene tres consecuencias concretas:

1. El banco **no custodia un dato irrevocable**. Una contraseña comprometida se cambia; un rostro, no.
2. Reduce el alcance de protección de datos: lo que el banco recibe es un **veredicto** y un nivel de aseguramiento, no un dato biométrico (LODPD).
3. Permite cambiar de proveedor sin tocar el canal, porque lo que se integra es el veredicto, no el proceso.

Lo que el banco sí conserva: la evidencia de que la verificación ocurrió, con qué proveedor, en qué momento y con qué resultado. Es lo que permite responder a un requerimiento sin almacenar el rostro.

El nivel de aseguramiento de identidad alcanzado aquí (**IAL**, NIST SP 800-63) condiciona después el nivel de autenticación exigible (**AAL**) en cada operación. Es la relación que H-03 puso en duda y que quedó formalizada en ADR-19: establecer una identidad débilmente y después exigir autenticación fuerte no corrige el origen.

4. Figura 8 · Autenticación y elevación por operación

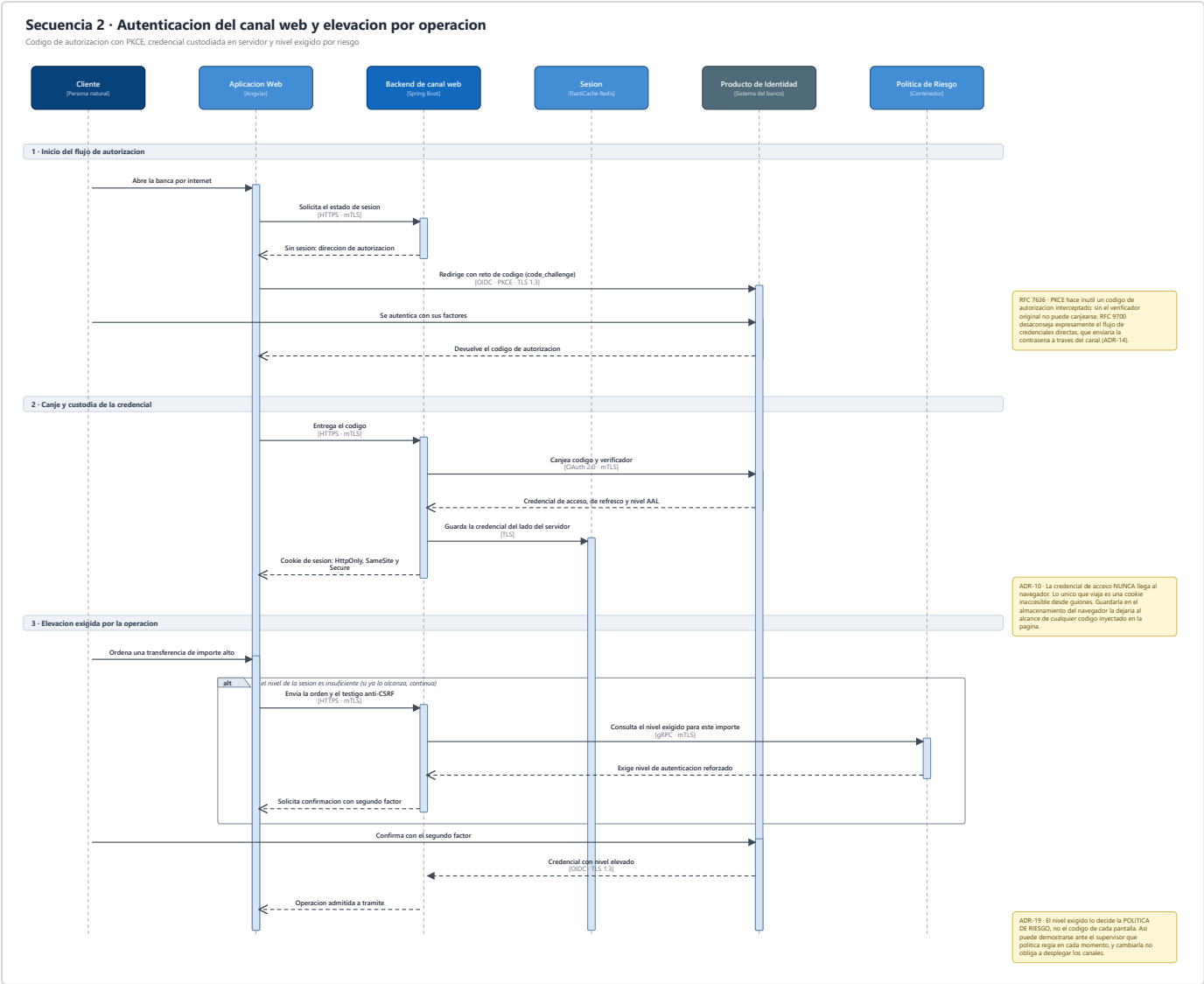


Figura 8. Secuencia · autenticación del canal web y elevación por operación

Fuente editable: [diagramas/SEQ-2-autenticacion.drawio](#)

Dos puntos que conviene poder defender en una revisión:

Por qué código de autorización con PKCE y no otra cosa. El flujo de credenciales directas —enviar usuario y contraseña al canal para que este los reenvíe— está **expresamente desaconsejado** por la práctica de seguridad vigente de OAuth 2.0 (RFC 9700). PKCE (RFC 7636) hace inútil un código interceptado: sin el verificador original no puede canjearse. En una aplicación pública, que no puede guardar un secreto, es la única protección real contra la interceptación del código.

Por qué el nivel exigido lo decide un servicio y no la pantalla. Si cada pantalla decidiera cuándo pedir un segundo factor, la política quedaría repartida por todo el código y sería imposible demostrar ante el supervisor qué regía en una fecha concreta. Centralizarla en Política de Riesgo permite **cambiarla sin desplegar los canales** y **acreditar** qué política se aplicó a cada operación (ADR-19).

La rama **alt** del diagrama muestra el caso que se olvida con frecuencia: si la sesión **ya alcanza** el nivel exigido, la operación continúa sin interrupción. Un diseño que pidiera el segundo factor siempre sería seguro y, a la vez, inutilizable.

5. Figura 9 · Transferencia interbancaria

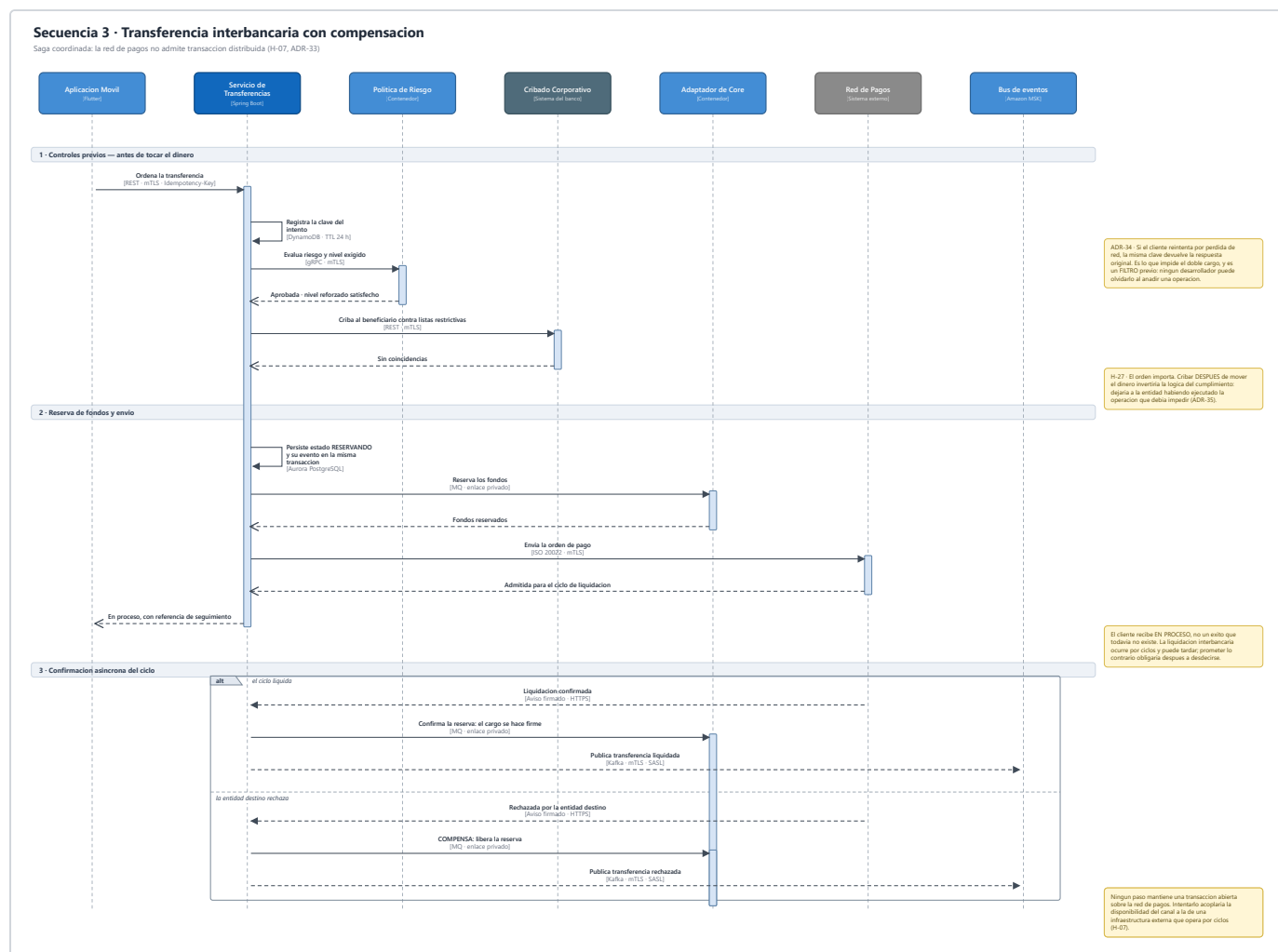


Figura 9. Secuencia · transferencia interbancaria con compensación

Fuente editable: [diagramas/SEQ-3-transferencia.drawio](#)

Es el diagrama más importante del documento, porque concentra tres decisiones que el enunciado evalúa por separado.

Primero los controles, después el dinero. Validar, evaluar riesgo y cribar al beneficiario ocurren antes de reservar fondos. Cribar después de mover el dinero invertiría la lógica del cumplimiento (H-27).

La saga y su compensación. La red de pagos no admite una transacción distribuida y liquida por ciclos. La coordinación es explícita: se **reserva**, se **envía**, y solo al confirmarse el ciclo el cargo se hace firme. Si la entidad destino rechaza, se **compensa** liberando la reserva. La compensación no es un bloque de recuperación ante error: es un **paso de negocio previsto**, con su registro y su evento (ADR-33).

Qué ve el cliente. Recibe *en proceso* con una referencia de seguimiento, no un éxito que todavía no existe. Prometer lo contrario obligaría después a desdecirse, que es peor que informar con precisión desde el principio.

Idempotencia. Si el cliente reintenta por pérdida de red, la misma clave devuelve la respuesta original. Es un **filtro previo**, no una comprobación dentro de la lógica: así ningún desarrollador puede olvidarlo al añadir una operación (ADR-34).

6. Figura 10 · Notificación de un movimiento

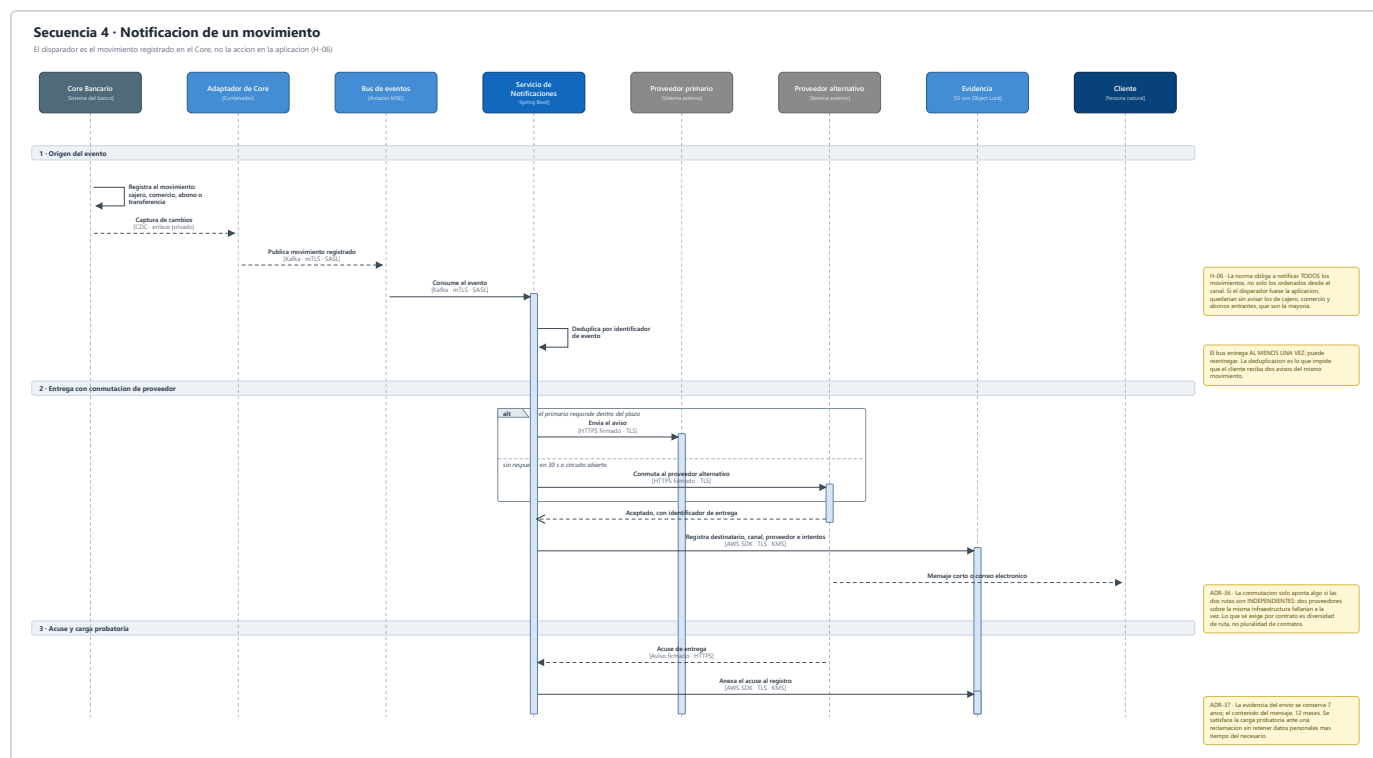


Figura 10. Secuencia · notificación de un movimiento originado en el Core

Fuente editable: [diagramas/SEQ-4-notificacion.drawio](#)

El diagrama empieza en el **Core**, no en la aplicación. Esa es toda la tesis: la norma obliga a notificar *los movimientos realizados, no los realizados desde el canal digital*. Un movimiento puede originarse en un cajero, en un comercio o en un abono entrante (H-06).

Tres mecanismos que el diagrama hace explícitos:

- **Deduplicación por identificador de evento:** el bus entrega *al menos una vez* y puede reentregar. Sin deduplicación, el cliente recibiría avisos repetidos.
- **Conmutación entre proveedores con rutas independientes:** dos proveedores sobre la misma infraestructura fallarían a la vez. Lo que se exige por contrato es **diversidad de ruta**, no pluralidad de contratos (ADR-36).
- **Evidencia con retención diferenciada:** la evidencia del envío, siete años; el contenido del mensaje, doce meses. Se cubre la carga probatoria sin retener datos personales de más (ADR-37).

7. Figura 11 · Despliegue en AWS

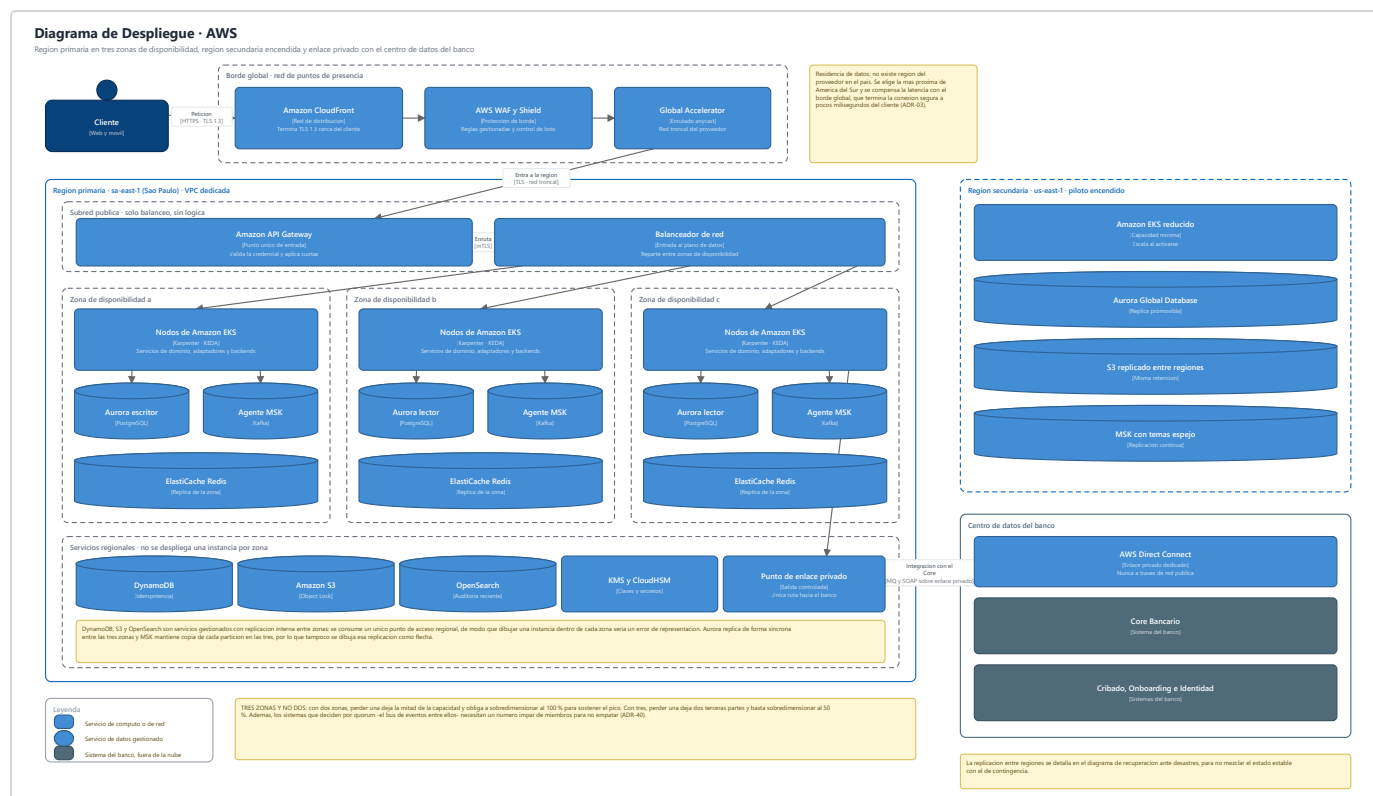


Figura 11. Despliegue en nube · tres zonas, región secundaria y enlace privado

Fuente editable: [diagramas/DEP-1-despliegue-aws.drawio](#)

Tres zonas de disponibilidad y no dos. Con dos zonas, perder una deja la mitad de la capacidad y obliga a sobredimensionar al 100 % para sostener el pico. Con tres, perder una deja dos tercios partes y basta sobredimensionar al 50 %. Además, los sistemas que deciden por quórum —el bus de eventos entre ellos— necesitan un número impar de miembros para no empatar (ADR-40).

Qué se dibuja dentro de una zona y qué no. DynamoDB, S3 y OpenSearch son servicios gestionados con replicación interna entre zonas: se consume un **punto de acceso regional**. Dibujar una instancia dentro de cada zona sería un error de representación, y es un error frecuente en diagramas de despliegue.

El enlace privado dedicado. No es una preferencia de rendimiento: es la condición para que el tráfico con el sistema de registro del banco **no transite por red pública en ningún tramo** (ADR-48). Por eso existe un único punto de enlace de salida y todo el tráfico hacia el Core pasa por él.

Residencia de datos. No hay región del proveedor en el país. Se elige la más próxima de América del Sur y se compensa la latencia con el borde global, que termina la conexión segura a pocos milisegundos del cliente (ADR-03). La alternativa —nube privada en el país— se evaluó y se descartó por coste y por velocidad de entrega, no por omisión.

8. Figura 12 · Zonas de seguridad

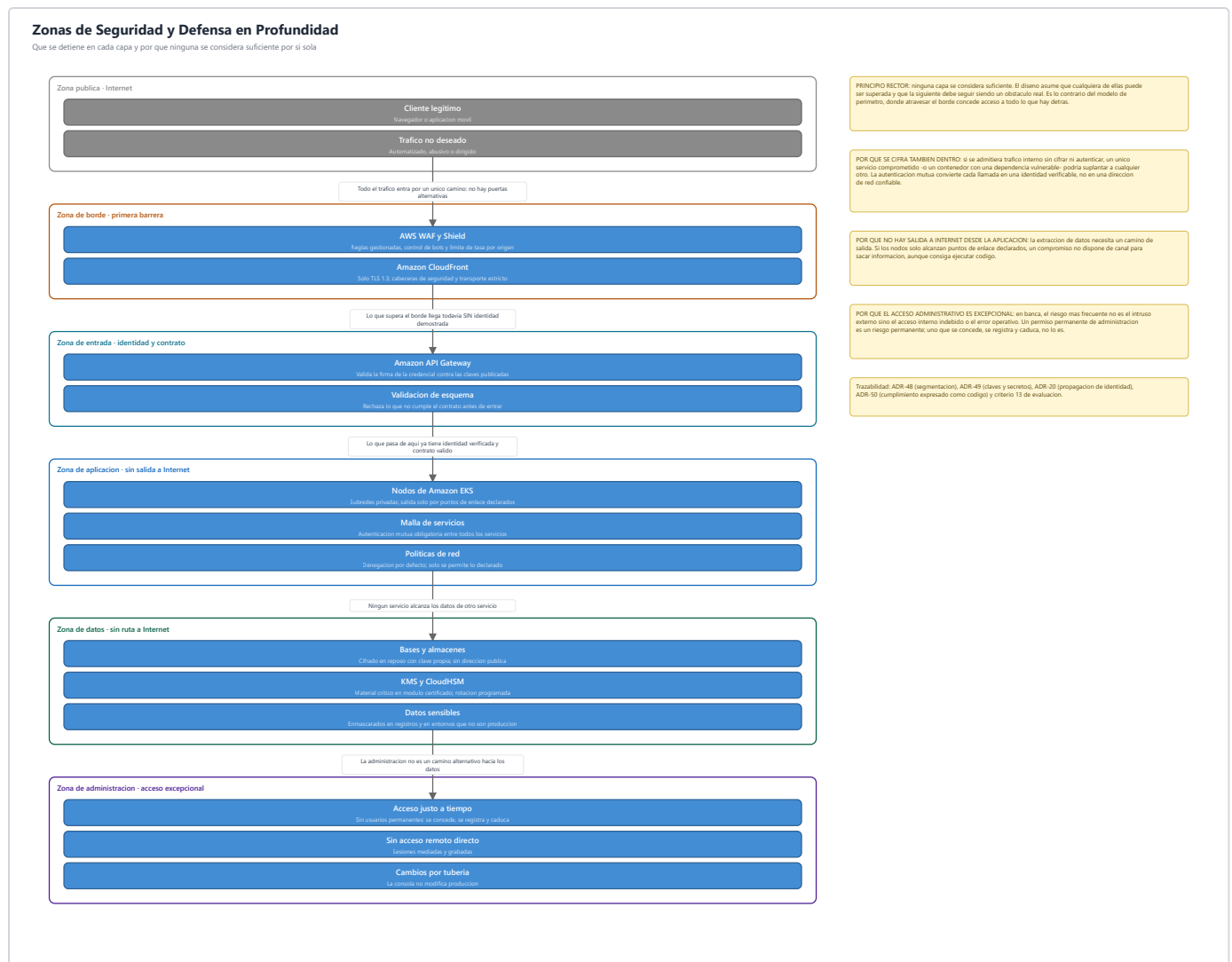


Figura 12. Zonas de seguridad y defensa en profundidad

Fuente editable: [diagramas/SEC-1-zonas-seguridad.drawio](#)

El diagrama se lee **de arriba abajo**, y cada flecha dice qué es cierto a partir de ese punto.

El principio rector es que **ninguna capa se considera suficiente**. Es lo contrario del modelo de perímetro, en el que atravesar el borde concede acceso a todo lo que hay detrás.

Tres decisiones que el diagrama justifica:

- **Se cifra y se autentica también dentro.** Si se admitiera tráfico interno sin autenticar, un único servicio comprometido podría suplantar a cualquier otro. La autenticación mutua convierte cada llamada en una **identidad verificable**, no en una dirección de red confiable.
- **La aplicación no tiene salida a Internet.** La extracción de datos necesita un camino de salida. Si los nodos solo alcanzan puntos de enlace declarados, un compromiso no dispone de canal para sacar información, aunque consiga ejecutar código.
- **El acceso administrativo es excepcional.** En banca, el riesgo más frecuente no es el intruso externo sino el acceso interno indebido o el error operativo. Un permiso permanente de administración es un riesgo permanente.

9. Figura 13 · Recuperación ante desastres

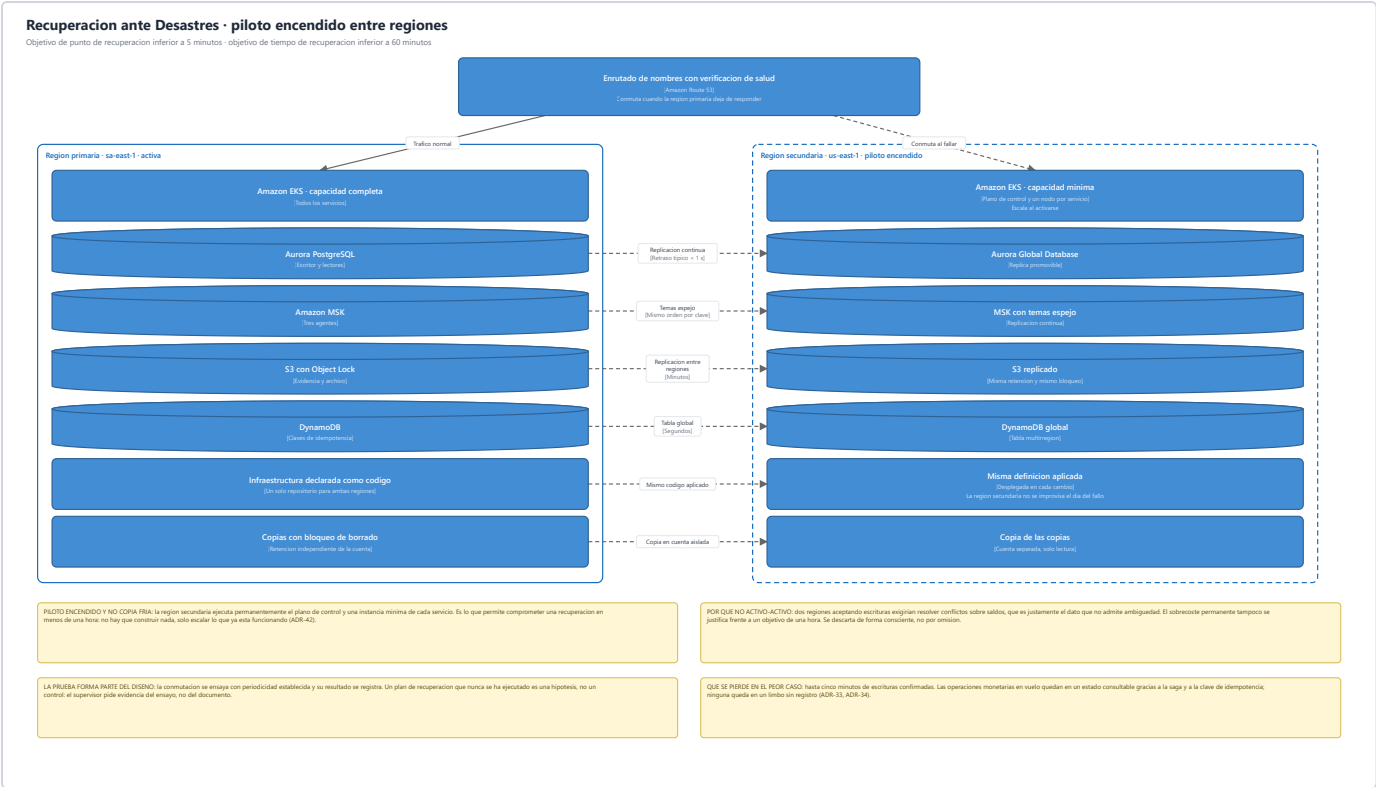


Figura 13. Recuperación ante desastres · piloto encendido entre regiones

Fuente editable: [diagramas/DR-1-recuperacion.drawio](#)

Piloto encendido, no copia fría. La región secundaria ejecuta permanentemente el plano de control y una instancia mínima de cada servicio. Es lo que permite comprometer una recuperación en menos de una hora: no hay que construir nada, solo escalar lo que ya funciona.

Por qué no activo-activo. Dos regiones aceptando escrituras exigirían resolver conflictos sobre saldos, que es justamente el dato que no admite ambigüedad. El sobrecoste permanente tampoco se justifica frente a un objetivo de una hora. **Se descarta de forma consciente**, y así se declara.

Qué se pierde en el peor caso. Hasta cinco minutos de escrituras confirmadas. Las operaciones monetarias en vuelo quedan en un estado consultable gracias a la saga y a la clave de idempotencia; **ninguna queda en un limbo sin registro**.

La prueba forma parte del diseño. La conmutación se ensaya con periodicidad establecida y su resultado se registra. Un plan de recuperación que nunca se ha ejecutado es una hipótesis, no un control: el supervisor pide evidencia del ensayo, no del documento.

10. Figura 14 · Mapa de datos

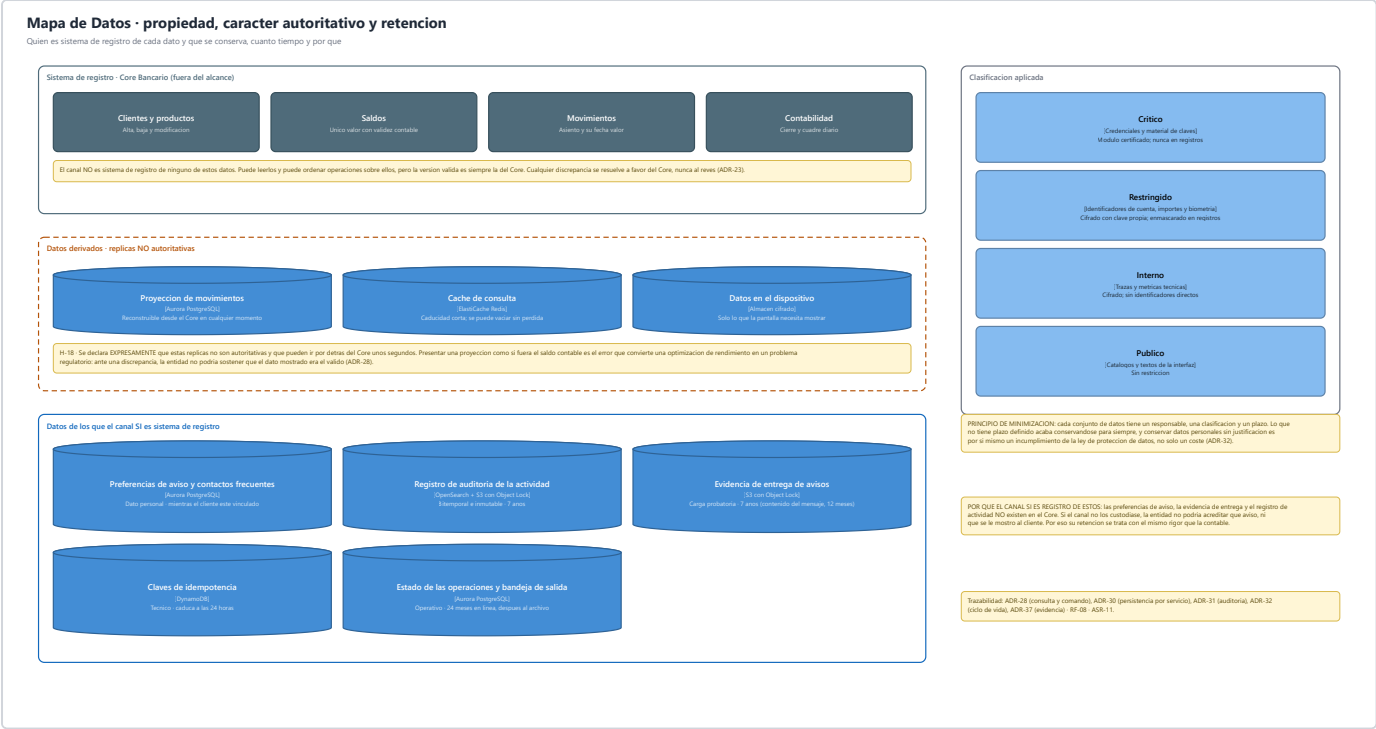


Figura 14. Mapa de datos · propiedad, carácter autoritativo y retención

Fuente editable: diagramas/DAT-1-mapa-de-datos.drawio

Responde a la pregunta que más discusiones genera en una arquitectura de canal: ¿de quién es cada dato?

Categoría	Qué incluye	Regla
Sistema de registro	Cientes, productos, saldos, movimientos, contabilidad	Está en el Core. El canal lee y ordena, pero la versión válida es siempre la del Core
Datos derivados	Proyección de movimientos, caché, datos en el dispositivo	No autoritativos y declarados como tales. Reconstruibles en cualquier momento
Datos del canal	Preferencias, auditoría, evidencia, idempotencia, estado de operaciones	No existen en el Core. Si el canal no los custodiase, la entidad no podría acreditar qué aviso ni qué mostró

Por qué importa declarar la proyección como no autoritativa (H-18): presentar una réplica como si fuera el saldo contable convierte una optimización de rendimiento en un problema regulatorio. Ante una discrepancia, la entidad no podría sostener que el dato mostrado era el válido.

Principio de minimización: cada conjunto de datos tiene responsable, clasificación y plazo. Lo que no tiene plazo definido acaba conservándose para siempre, y conservar datos personales sin justificación es por sí mismo un incumplimiento, no solo un coste (ADR-32).

11. Figura 15 · Observabilidad

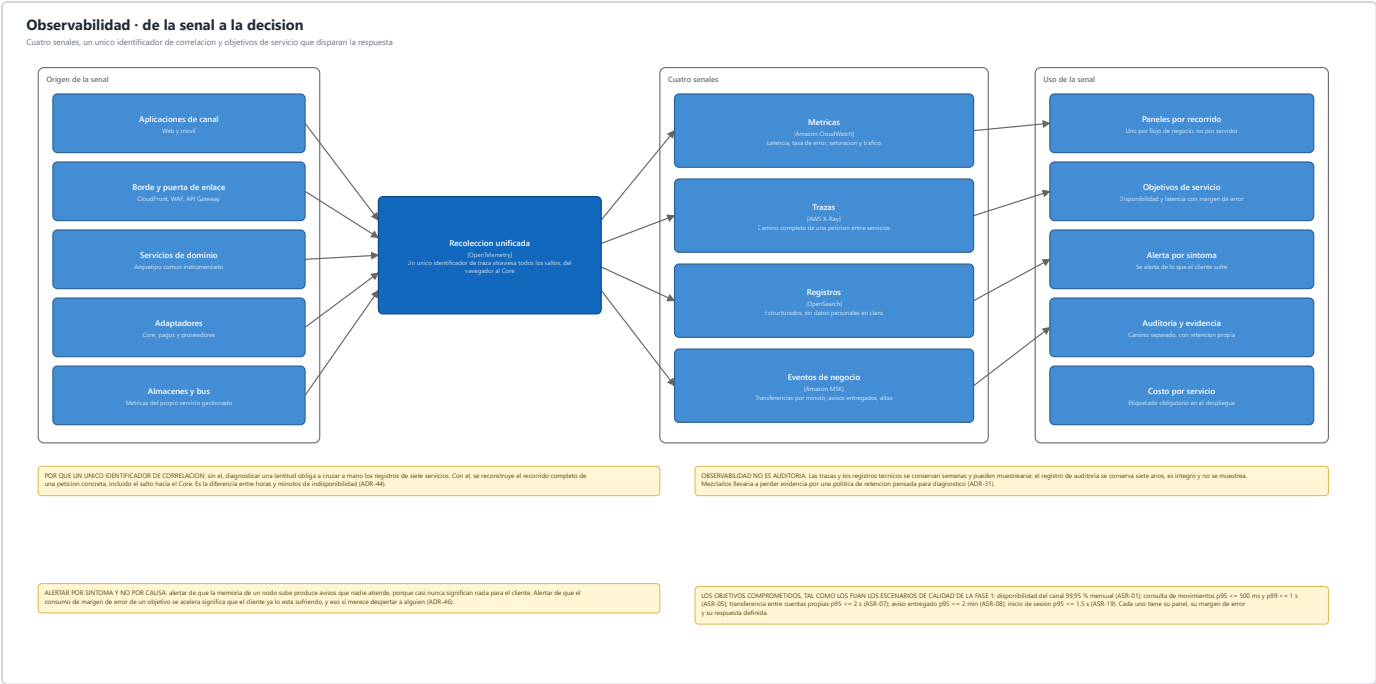


Figura 15. Observabilidad · de la señal a la decisión

Fuente editable: `diagramas/OBS-1-observabilidad.drawio`

Un único identificador de correlación. Sin él, diagnosticar una lentitud obliga a cruzar a mano los registros de siete servicios. Con él, se reconstruye el recorrido completo de una petición concreta, incluido el salto hacia el Core. Es la diferencia entre horas y minutos de indisponibilidad.

Alertar por síntoma y no por causa. Alertar de que la memoria de un nodo sube produce avisos que nadie atiende, porque casi nunca significan algo para el cliente. Alertar de que el consumo del margen de error de un objetivo se acelera significa que el cliente **ya lo está sufriendo** (ADR-46).

Observabilidad no es auditoría. Las trazas y los registros técnicos se conservan semanas y pueden muestrearse; el registro de auditoría se conserva siete años, es íntegro y **no se muestrea**. Mezclarlos llevaría a perder evidencia por una política de retención pensada para diagnóstico.

Los objetivos comprometidos son los que fijan los escenarios de calidad de la Fase 1, sin reinterpretarlos: disponibilidad del canal **99,95 % mensual** (ASR-01); consulta de movimientos **p95 ≤ 500 ms** y **p99 ≤ 1 s** (ASR-05); transferencia entre cuentas propias **p95 ≤ 2 s** (ASR-07); aviso entregado **p95 ≤ 2 min** (ASR-08); inicio de sesión **p95 ≤ 1,5 s** (ASR-19). Cada uno tiene su panel, su margen de error y su respuesta definida.

12. Figura 16 · Mapa de capacidades BIAN

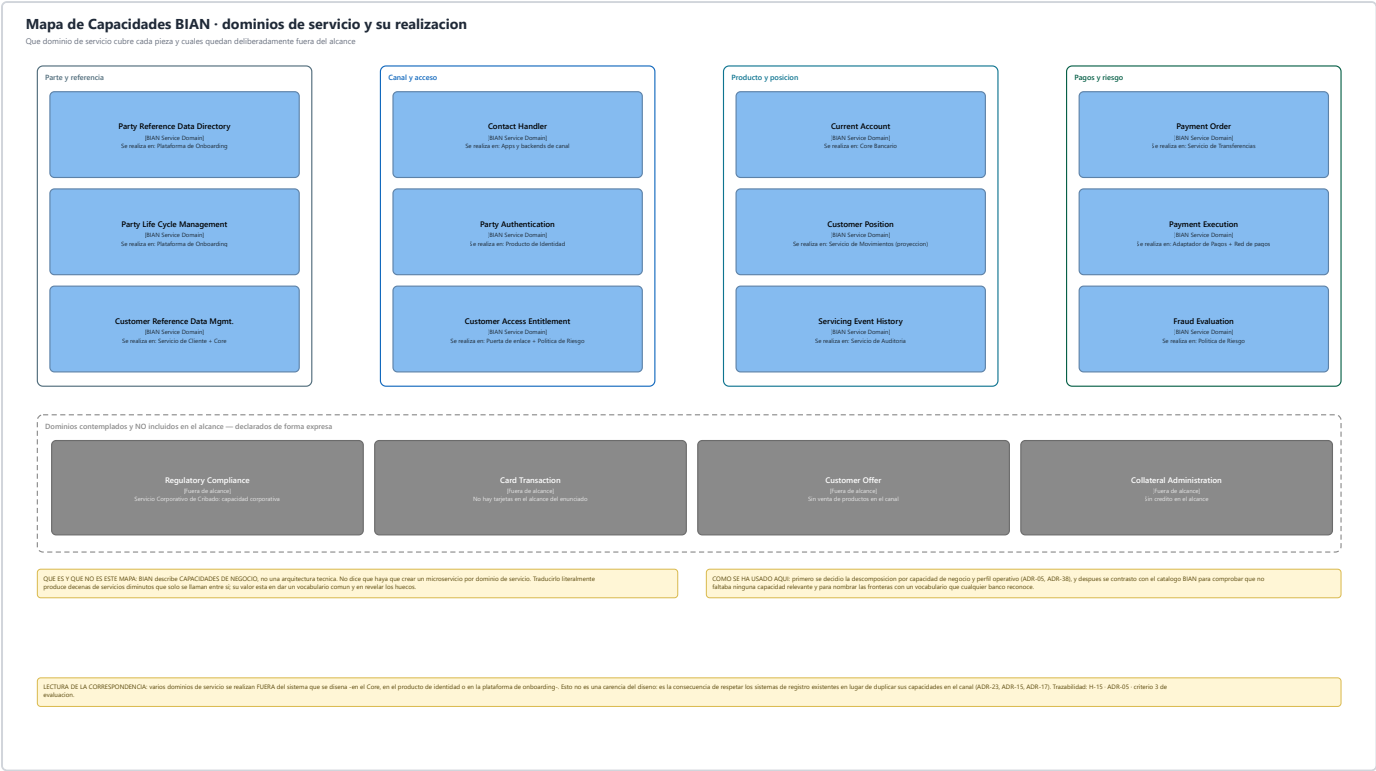


Figura 16. Mapa de capacidades BIAN · dominios de servicio y su realización

Fuente editable: `diagramas/BIAN-1-capacidades.drawio`

Qué es y qué no es este mapa. BIAN describe **capacidades de negocio**, no una arquitectura técnica. No dice que haya que crear un microservicio por dominio de servicio: traducirlo literalmente produce decenas de servicios diminutos que solo se llaman entre sí. Su valor está en dar un **vocabulario común** y en **revelar huecos**.

Cómo se ha usado aquí. Primero se decidió la descomposición por capacidad de negocio y perfil operativo (ADR-05, ADR-38); **después** se contrastó con el catálogo BIAN para comprobar que no faltaba ninguna capacidad relevante y para nombrar las fronteras con un vocabulario que cualquier banco reconoce. El orden importa: usar BIAN como punto de partida del diseño técnico es el error que H-15 señalaba.

Lectura de la correspondencia. Varios dominios de servicio se realizan **fuera** del sistema que se diseña —en el Core, en el producto de identidad o en la plataforma de onboarding—. No es una carencia: es la consecuencia de respetar los sistemas de registro existentes en lugar de duplicar sus capacidades en el canal.

Se declaran además los dominios **contemplados y excluidos** con su motivo, porque un mapa que solo muestra lo incluido no permite saber si algo se olvidó o se descartó.

13. Figura 17 · Hoja de ruta

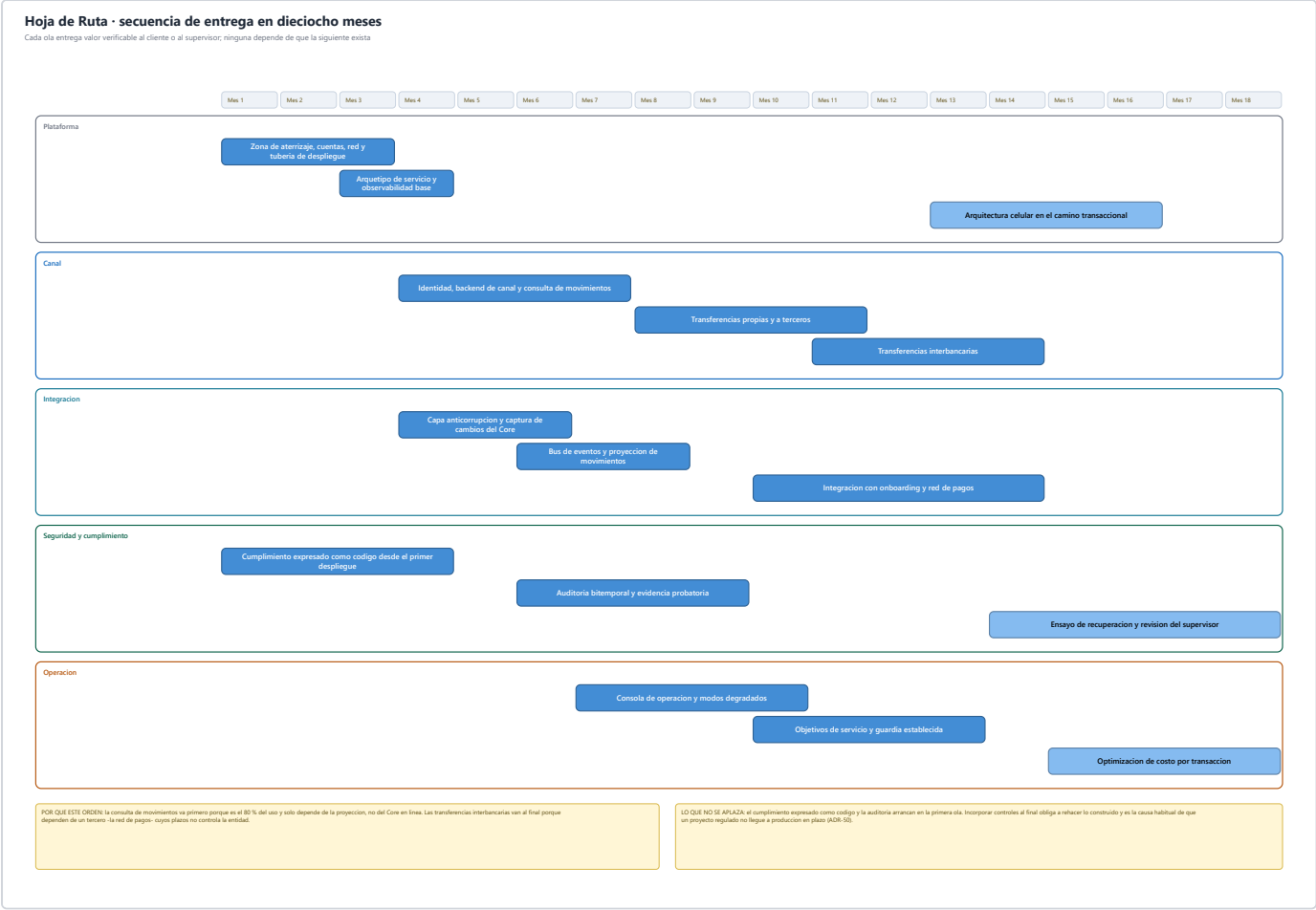


Figura 17. Hoja de ruta · secuencia de entrega en dieciocho meses

Fuente editable: [diagramas/RM-1-hoja-de-ruta.drawio](#)

Dieciocho meses en cinco frentes. Dos criterios gobiernan el orden:

Por qué la consulta de movimientos va primero. Es el 80 % del uso y solo depende de la proyección, no del Core en línea. Entrega valor verificable al cliente en el primer semestre y valida de extremo a extremo la captura de cambios, que es la integración más delicada.

Por qué las interbancarias van al final. Dependen de un tercero —la red de pagos— cuyos plazos de homologación no controla la entidad. Situarlas antes ataría el resto del plan a una dependencia externa.

Lo que no se aplaza. El cumplimiento expresado como código y la auditoría arrancan en la primera ola. Incorporar controles al final obliga a rehacer lo construido y es la causa habitual de que un proyecto regulado no llegue a producción en plazo (ADR-50).

Cada ola **entrega algo verificable** —al cliente o al supervisor— y ninguna depende de que la siguiente exista. Un plan cuyas fases solo tienen sentido al completarse todas no es una hoja de ruta: es un único proyecto largo disfrazado.

13 bis. Figura 18 · Patrones para caché y clientes frecuentes

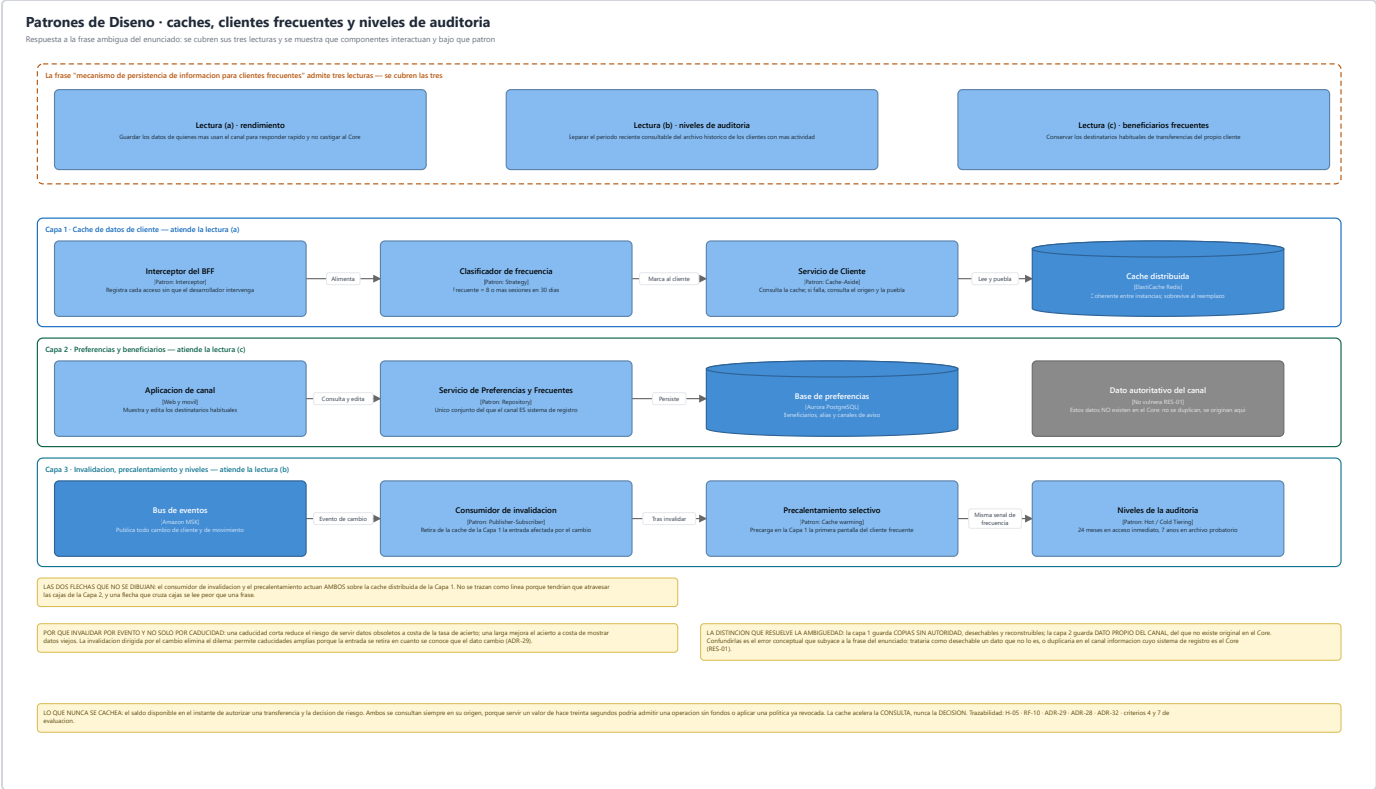


Figura 18. Patrones de diseño · cachés, clientes frecuentes y niveles de auditoría

Fuente editable: [diagramas/PAT-1-patrones-cache-frecuentes.drawio](#)

La frase del enunciado —“*cuenta con un mecanismo de persistencia de información para clientes frecuentes*”— admite **tres lecturas** (H-05), y el diagrama las cubre las tres en lugar de elegir una:

Lectura	Qué significaría	Cómo se cubre
(a) Rendimiento	Guardar los datos de quienes más usan el canal	Capa 1: <i>Cache-Aside</i> sobre caché distribuida, con clasificador de frecuencia
(b) Niveles de auditoría	Separar el periodo reciente del archivo histórico	Capa 3: <i>Hot / Cold Tiering</i> , 24 meses consultables y 7 años archivados
(c) Beneficiarios frecuentes	Conservar los destinatarios habituales del cliente	Capa 2: <i>Repository</i> sobre base propia del canal

La distinción que resuelve la ambigüedad. La capa 1 guarda **copias sin autoridad**, desechables y reconstruibles desde el Core. La capa 2 guarda **dato propio del canal**, del que no existe original en el Core. Confundirlas es el error conceptual que subyace a la frase: trataría como desechable un dato que no lo es, o duplicaría en el canal información cuyo sistema de registro es el Core (RES-01).

Por qué invalidar por evento y no solo por caducidad. Una caducidad corta reduce el riesgo de servir datos obsoletos a costa de la tasa de acierto; una larga mejora el acierto a costa de mostrar datos viejos. La invalidación dirigida por el cambio elimina el dilema: permite caducidades amplias porque la entrada se retira en cuanto se conoce que el dato cambió (ADR-29).

Lo que nunca se cachea. El saldo disponible en el instante de autorizar una transferencia y la decisión de riesgo. Servir un valor de hace treinta segundos podría admitir una operación sin fondos o aplicar una política ya revocada. **La caché acelera la consulta, nunca la decisión.**

14. Protocolos: consolidado de esta fase

Los diagramas de secuencia rotulan el protocolo y su protección en cada mensaje. Esta tabla recoge los que **no aparecían** en las fases anteriores:

Tramo	Protocolo	Protección	Dónde aparece
Aplicación móvil → proveedor de verificación	HTTPS	TLS 1.3 con SDK certificado; sin paso por el banco	Figura 7
Proveedor de verificación → onboarding	Aviso entrante firmado	Firma del cuerpo, marca temporal e identificador de evento	Figura 7
Onboarding → producto de identidad	SCIM 2.0	TLS y autenticación mutua	Figura 7
Navegador → producto de identidad	OpenID Connect con PKCE	TLS 1.3 y validación de firma	Figura 8
Backend de canal → producto de identidad	OAuth 2.0 / RFC 8693	Autenticación mutua	Figura 8
Red de pagos → canal	Aviso entrante firmado	Firma verificada antes de procesar	Figura 9
Core → adaptador	Captura de cambios	Enlace privado y cifrado en tránsito	Figura 10
Proveedor → canal (acuse)	Aviso entrante firmado	Firma verificada; entrada no confiable	Figura 10

Criterio común a los tres avisos entrantes: un mensaje que llega de fuera es una **entrada no confiable**, aunque provenga de un socio contratado. Se verifica firma, marca temporal e identificador antes de procesarlo. Aceptarlo por venir de una dirección conocida sería confiar en la red, que es exactamente lo que el diseño rechaza (ADR-22, ADR-48).

15. Trazabilidad

Elemento de la Fase 6	Requisito, hallazgo o decisión
Biometría que no atraviesa el banco	H-26 · ADR-18 · LOPDP
Relación entre nivel de identidad y de autenticación	H-03 · ADR-19 · NIST SP 800-63
Saga con compensación explícita	H-07 · ADR-33
Idempotencia como filtro previo	ADR-34 · ASR-06
Disparador de la notificación en el Core	H-06 · ADR-36
Dos proveedores con ruta independiente	RC-03 · H-19 · ADR-36
Tres zonas de disponibilidad	ADR-40 · ASR-01
Región secundaria con piloto encendido	ADR-42 · ASR-02
Zonas de seguridad y ausencia de salida a Internet	ADR-48 · criterio 13
Proyección declarada no autoritativa	H-18 · ADR-28
Retención diferenciada por tipo de dato	ADR-32 · ADR-37
Observabilidad separada de la auditoría	ADR-31 · ADR-44
BIAN como contraste y no como punto de partida	H-15 · ADR-05 · criterio 3
Hoja de ruta por olas verificables	Recomendación muy valorada
Patrones de caché y clientes frecuentes	H-05 · RF-10 · ADR-29 · instrucción literal

16. Qué falta

Con esta fase quedan completos los dieciocho diagramas. Las fases restantes no producen dibujos:

- **Fase 7:** capítulos transversales —seguridad, marco normativo, alta disponibilidad, monitoreo, costos y gobierno— estructurados sobre los pilares del marco de buena arquitectura y su lente sectorial financiera.
- **Fase 8:** ensamblado del documento —portada, índice, resumen ejecutivo, glosario, control de versiones, anexos editables y autoevaluación contra los quince criterios de calificación.

Capítulo 11 · Seguridad, normativa, disponibilidad, monitoreo, rendimiento, costos y gobierno

1. Por qué esta fase existe

De los quince criterios de calificación, **nueve no se responden con un diagrama**: requisitos cubiertos, costos, cumplimiento normativo, alta disponibilidad, monitoreo, excelencia operativa, acceso a datos, autenticación y auditoría exigen argumentación escrita. Un entregable compuesto solo de dibujos, por excelentes que sean, deja más de la mitad de la calificación sin responder.

Esta fase no repite lo ya decidido: **consolida** las decisiones dispersas en 52 ADR y las organiza según el marco con el que el propio proveedor de nube verifica una arquitectura, añadiendo su lente sectorial financiera.

Pilar del marco de buena arquitectura	Capítulo	Criterio que responde
Seguridad	A y B	10, 13
Fiabilidad	C	14
Excelencia operativa	D y E	15
Eficiencia del rendimiento	F	— (sostiene ASR-05, 07, 19)
Optimización de costos	G	9
Sostenibilidad	H	—
Lente sectorial financiera	Transversal a B, C y E	12, 13

Los capítulos I y J cierran con el **gobierno de la arquitectura** y la **matriz de trazabilidad** que responde al criterio 1.

2. Capítulo A · Seguridad

2.1 Cómo está organizado el capítulo

Se sigue la descomposición clásica en cinco dominios, porque permite comprobar que ninguno quedó sin tratar.

Dominio	Qué se decidió	Dónde
Gestión de identidad y acceso	Código de autorización con PKCE; credencial custodiada en servidor; intercambio de credencial por destino; nivel de autenticación decidido por política	ADR-14, 15, 19, 20
Protección de datos	Cifrado en tránsito y en reposo con claves propias; biometría que no atraviesa el banco; enmascarado en registros; retención por clasificación	ADR-18, 32, 49
Protección de la infraestructura	Cinco zonas; sin salida a Internet desde la aplicación; autenticación mutua obligatoria; enlace privado con el Core	ADR-48
Detección	Registro íntegro y encadenado; correlación de señales; alerta por síntoma	ADR-31, 44, 46
Respuesta	Modos degradados declarados; acceso administrativo excepcional; conmutación ensayada	ADR-43, 42, 48

2.2 Las cuatro decisiones de seguridad que sostienen el resto

La credencial no llega al navegador. El backend de canal web la custodia y el navegador recibe solo una cookie inaccesible desde guiones, restringida al mismo sitio. Un compromiso del código que se ejecuta en la página no expone la credencial, porque allí no hay ninguna (ADR-10).

Ningún servicio reutiliza la credencial que recibió. Cada salto obtiene una de audiencia específica mediante intercambio de credencial (RFC 8693). Una credencial capturada en un tramo no sirve en otro, lo que convierte un compromiso lateral en un problema acotado (ADR-20).

No hay red interna de confianza. Todo tramo va cifrado y con autenticación mutua de ambos extremos, incluidos los internos. La distinción entre red segura y red insegura es precisamente la premisa que convierte un compromiso perimetral en un compromiso total (ADR-22, ADR-48).

El banco no custodia el dato biométrico. La imagen va de la aplicación al proveedor de verificación; el banco recibe el veredicto y el nivel de aseguramiento alcanzado. Una contraseña comprometida se cambia; un rostro, no (ADR-18).

2.3 Lo que deliberadamente NO se hace

Práctica descartada	Por qué
Guardar la credencial en el almacenamiento del navegador	Quedaría al alcance de cualquier código inyectado en la página
Flujo de credenciales directas (usuario y clave enviados al canal)	Expresamente desaconsejado por la práctica de seguridad vigente de OAuth 2.0 (RFC 9700)
Abrir la autenticación en una vista web embebida en la aplicación móvil	La aplicación podría leer lo que el usuario teclea; RFC 8252 exige el navegador del sistema
Segundo factor por mensaje corto como único método fuerte	Vulnerable a duplicación de tarjeta y a desvío; se admite como factor secundario, no como único
Cifrar solo en el perímetro	Un servicio comprometido podría suplantar a cualquier otro
Detección de fraude basada únicamente en reglas fijas	Se combina con señales de dispositivo y comportamiento; las reglas fijas se eluden en cuanto se conocen

Declarar lo descartado importa tanto como lo adoptado: permite distinguir una omisión de una decisión.

3. Capítulo B · Marco normativo y su traducción a controles

3.1 Nota de rigor

El marco depende de la jurisdicción, que el enunciado no precisa (H-01). Se asume **Ecuador**. Los instrumentos se citan **por su denominación y su contenido**; los números concretos de resolución deben verificarse contra la codificación vigente en el momento de la implantación, porque la normativa sectorial se actualiza con frecuencia. Citar una referencia que no corresponda sería un defecto más grave que citarla por su nombre.

3.2 De la obligación al control verificable

La aportación de este capítulo no es enumerar normas, que es lo que suele hacerse: es **traducir cada obligación a un control arquitectónico con su forma de verificación**. Una norma sin control es una declaración de intenciones.

Obligación	Control arquitectónico	Cómo se verifica
Autenticación robusta en canales electrónicos	Autenticación reforzada exigida por operación según política centralizada (ADR-16, 19)	Registro de qué política regía en cada operación; prueba de que el canal rechaza operar por debajo del nivel exigido
Notificación de los movimientos al cliente	Disparador en el Core vía captura de cambios; dos proveedores con ruta independiente (ADR-36)	Conciliación periódica entre movimientos registrados y avisos emitidos; evidencia de entrega conservada
Registro de la actividad del cliente y su acreditación	Auditoría bitemporal, inmutable y encadenada; 7 años (ADR-31, 32)	Reconstrucción de la actividad de un cliente en una fecha; verificación de la cadena de resúmenes
Continuidad del negocio	Tres zonas, región secundaria encendida, modos degradados (ADR-40, 42, 43)	Ensayo periódico de conmutación con resultado registrado
Debida diligencia y cribado	Verificación de identidad con detección de ataques de presentación; cribado previo a mover fondos (ADR-18, 35)	Prueba de que ninguna operación alcanza el Core sin cribado previo
Protección de datos personales	Clasificación, minimización, retención por plazo, cifrado con claves propias (ADR-32, 49)	Comprobación automática de que ningún recurso carece de clasificación ni de plazo
Transferencia internacional de datos	Base de legitimación documentada, cifrado con claves de la entidad, evaluación jurídica previa (ADR-03)	Registro de la evaluación; verificación de que la clave no sale del control de la entidad

Obligación	Control arquitectónico	Cómo se verifica
Validez de la contratación electrónica	Evidencia del consentimiento y de las condiciones aceptadas, con sello temporal (ADR-31)	Recuperación de la evidencia de un consentimiento concreto

3.3 Las tres capas del marco

Local (Ecuador): Código Orgánico Monetario y Financiero; normativa de la Superintendencia de Bancos sobre riesgo operativo y seguridad en canales electrónicos; Ley Orgánica de Protección de Datos Personales; Ley de Comercio Electrónico, Firmas Electrónicas y Mensajes de Datos; normativa de prevención de lavado de activos y de la Unidad de Análisis Financiero y Económico; normativa del Banco Central sobre el Sistema Nacional de Pagos.

Internacional transversal: ISO/IEC 27001 y 27002; ISO 22301; NIST SP 800-63; ISO/IEC 30107; OWASP ASVS y API Security Top 10; PCI DSS (hoy fuera de alcance, con tokenización prevista si se incorporan tarjetas); marco de buena arquitectura con su lente sectorial financiera.

Equivalencias regionales: se mantienen en ADR-47 para que el análisis conserve validez si la jurisdicción asumida resulta ser otra o si la entidad opera en varios países. Es la razón de que este capítulo no dependa de que el supuesto de país sea correcto.

3.4 Cumplimiento expresado como código

Los controles no se comprueban en una auditoría anual: se **verifican en cada despliegue**. Políticas que rechazan la puesta en producción de un recurso sin cifrado, sin clasificación de datos, sin etiquetado de coste o con comunicación sin autenticar (ADR-50).

El argumento es operativo, no formal: un control que solo se revisa una vez al año está incumplido la mayor parte del tiempo sin que nadie lo sepa.

4. Capítulo C · Fiabilidad: alta disponibilidad, tolerancia a fallos y recuperación

4.1 El cálculo que condiciona todo lo demás

El canal depende de sistemas cuya disponibilidad **no controla**:

Dependencia	Disponibilidad declarada	Indisponibilidad mensual equivalente
Core Bancario	99,5 %	~3,6 h
Producto de Identidad	99,9 %	~43 min
Sistema Complementario de Cliente	99,0 %	~7,3 h

Si cada petición del canal dependiera en serie de las tres, el techo sería $0,995 \times 0,999 \times 0,990 \approx 98,4 \%$, es decir unas **11,5 horas de indisponibilidad al mes**. El objetivo de 99,95 % sería inalcanzable por aritmética, no por ingeniería.

Precisión del objetivo. Por eso el compromiso se declara **por camino**, refinando la medida de ASR-01:

Camino	Objetivo	Por qué puede comprometerse
Consulta (movimientos, posición, datos básicos)	99,95 % mensual	No alcanza al Core: se sirve de la proyección y de la caché (ADR-28)
Orden de transferencia	99,5 % mensual	Depende del Core en línea para reservar fondos: su techo es el del Core
Aviso de movimiento	99,9 % mensual	Dos proveedores con ruta independiente; reintentos durante 24 h

Declarar un único número global habría sido más cómodo y menos honesto. El 80 % del uso está en el camino de consulta, que sí sostiene 99,95 %.

4.2 Tolerancia a fallos: qué ocurre cuando cada cosa falla

Fallo	Respuesta del sistema	Lo que percibe el cliente
Pérdida de una zona de disponibilidad	Las otras dos absorben la carga; capacidad recuperada en ≤ 5 min	Nada

Fallo	Respuesta del sistema	Lo que percibe el cliente
Core no disponible	La consulta sigue sirviéndose de la proyección con su marca temporal; las transferencias se rechazan con mensaje explícito	Puede consultar; no puede transferir, y se le dice por qué
Sistema complementario degradado	Se muestra el detalle básico y se oculta el ampliado	Menos detalle, sin error
Producto de identidad caído	Las sesiones vigentes continúan; no se admiten autenticaciones nuevas	Quien ya entró sigue; quien entra, no puede
Un proveedor de avisos caído	Conmutación al alternativo en menos de 30 s	Nada
Fuera de horario de la red de pagos	Se admite la orden y se comunica la fecha valor del siguiente ciclo	Sabe cuándo se liquidará
Retraso del bus de eventos	La proyección envejece; la interfaz muestra la marca temporal del dato	Ve que el dato no es del instante

Por qué no se encolan las transferencias cuando el Core no responde. Aceptar una orden monetaria sin poder comprobar fondos crea una obligación que la entidad podría no poder cumplir. Rechazar explícitamente es peor experiencia y mejor diseño (ADR-43).

4.3 Recuperación ante desastres

Objetivos: **punto de recuperación inferior a 5 minutos** y **tiempo de recuperación inferior a 60 minutos**.

Región secundaria con **piloto encendido**: ejecuta permanentemente el plano de control y una instancia mínima de cada servicio. No hay que construir nada el día del fallo, solo escalar lo que ya funciona.

Activo-activo se descartó de forma consciente: dos regiones aceptando escrituras exigirían resolver conflictos sobre saldos, que es el dato que no admite ambigüedad, y el sobre coste permanente no se justifica frente a un objetivo de una hora.

La prueba forma parte del diseño. La conmutación se ensaya con periodicidad establecida y su resultado se registra. Un plan que nunca se ha ejecutado es una hipótesis, no un control.

5. Capítulo D · Excelencia operativa

5.1 Auto-recuperación: qué se recupera solo

Situación	Mecanismo	Intervención humana
Instancia que deja de responder a la comprobación de salud	Se retira del balanceo y se reemplaza	Ninguna
Nodo defectuoso	Se sustituye y la carga se redistribuye	Ninguna
Cola de eventos con retraso creciente	Escalado por retraso de cola, no por procesador	Ninguna
Circuito abierto hacia una dependencia	Cierre progresivo tras comprobación	Ninguna
Mensaje que falla repetidamente	Cola de no entregados con alerta	Si : decisión de reproceso
Rotura de la cadena de auditoría	Alerta inmediata	Si : investigación obligatoria

El criterio de corte es explícito: **se automatiza lo repetitivo y determinista; se deja al humano lo que exige una decisión con consecuencia**. Reprocesar un pago detenido no es una decisión técnica.

5.2 Despliegue

Despliegue progresivo con reversión automática ante deterioro de los indicadores, sin interrupción del servicio (ASR-12). El cambio se propaga primero a una celda y solo continúa si sus indicadores se mantienen (ADR-41, ADR-45).

Ninguna modificación de producción se hace desde la consola: todo cambio pasa por la tubería de entrega, que es también donde se verifican los controles de cumplimiento.

5.3 Herramientas de explotación

La **Consola de Operación** no es un extra: un sistema auditable necesita herramientas para reprocesar mensajes detenidos, consultar evidencia y responder requerimientos. Un diseño sin ellas es correcto sobre el papel e inviable en

6. Capítulo E · Monitoreo y gestión del servicio

6.1 Indicadores, objetivos y margen de error

Indicador	Objetivo	Margen de error mensual	Respuesta al agotarlo
Disponibilidad del camino de consulta	99,95 %	~22 min	Congelación de cambios no correctivos
Consulta de movimientos (p95)	≤ 500 ms	5 % de peticiones fuera	Revisión de la proyección y de la caché
Transferencia entre cuentas propias (p95)	≤ 2 s	5 % fuera	Revisión de la saga y del adaptador de Core
Aviso entregado (p95)	≤ 2 min	5 % fuera	Revisión de proveedores y de la cola
Inicio de sesión (p95)	≤ 1,5 s	5 % fuera	Revisión del borde y del producto de identidad
Frescura de la proyección (p95)	≤ 60 s	5 % fuera	Revisión del bus y del consumidor

El **margen de error** no es un tecnicismo: es lo que convierte un objetivo en una decisión de gestión. Mientras queda margen, se prioriza entregar; cuando se agota, se prioriza estabilizar. Sin él, la discusión entre producto e ingeniería no tiene árbitro.

6.2 Alertar por síntoma

Se alerta de **lo que el cliente sufre**, no de lo que un componente hace. La memoria de un nodo que sube casi nunca significa algo para el cliente; el consumo acelerado del margen de error, sí.

6.3 Observabilidad no es auditoría

	Observabilidad	Auditoría
Propósito	Diagnosticar	Acreditar
Retención	Semanas	7 años
Muestreo	Admisible	Nunca
Integridad	Deseable	Demostrable (cadena de resúmenes)
Contenido personal	Enmascarado	Necesario y protegido

Mezclarlos llevaría a perder evidencia por aplicar una política de retención pensada para diagnóstico.

7. Capítulo F · Eficiencia del rendimiento

7.1 Presupuesto de latencia repartido

El compromiso es de extremo a extremo, de modo que cada tramo recibe una porción del total. Para el escenario más exigente en volumen —consulta de movimientos, objetivo p95 ≤ 500 ms:

Tramo	Asignación	Palanca que lo sostiene
Red de acceso del cliente hasta el punto de presencia	120 ms	Terminación de la conexión segura en el borde, TLS 1.3, HTTP/3
Punto de presencia → región	90 ms	Red troncal del proveedor, no Internet pública
Puerta de enlace (firma y cuotas)	15 ms	Validación contra claves en memoria, sin llamada externa
Backend de canal (composición)	25 ms	Invocación en paralelo; caché de respuesta
Servicio de Movimientos	20 ms	Sin salto al Core
Proyección	45 ms	Índice por cliente y rango de fechas
Serialización, compresión y retorno	35 ms	Campos limitados por canal
Total asignado	350 ms	
Reserva	150 ms (30 %)	Variabilidad de la red móvil y colas de percentil alto

La reserva es deliberada: en el percentil 95 lo que domina no es el procesamiento sino la **cola y la variabilidad de la red de acceso**. Un presupuesto que asigne el 100 % del objetivo se incumple en cuanto aparece la primera cola.

7.2 Medir antes de optimizar

En un sistema distribuido, la intuición sobre dónde se consume el tiempo suele ser errónea: con frecuencia domina el establecimiento de conexiones o la distancia física, no el cálculo. Por eso la instrumentación es **requisito previo** de cualquier optimización, no un complemento posterior.

8. Capítulo G · Manejo de costos

8.1 Objetivo y método

Objetivo declarado: **≤ 0,06 USD por usuario digital activo al mes**, equivalente a unos **108.000 USD mensuales** para la base de 1,8 millones de usuarios activos supuesta en la Fase 1.

Sobre estas cifras: son una **estimación de orden de magnitud** con el método declarado, no una cotización. Su valor no está en la precisión del número sino en que existe un objetivo, un reparto y una forma de medir la desviación. Un diseño que no declara su coste esperado no permite discutir si es viable.

8.2 Reparto estimado

Concepto	Peso estimado	Comentario
Cómputo (Amazon EKS)	28 %	Base reservada + elasticidad para el pico
Bases de datos (Aurora)	22 %	Escritor y lectores en tres zonas
Red y borde (CloudFront, enlace privado, transferencia)	13 %	La transferencia entre zonas es partida relevante y se suele olvidar
Almacenamiento y auditoría (S3, OpenSearch)	12 %	Por niveles: el archivo de 7 años no se paga a precio de acceso inmediato
Mensajería (Amazon MSK)	9 %	Tres agentes
Caché (ElastiCache)	6 %	Réplica por zona
Seguridad (WAF, KMS, CloudHSM)	5 %	El módulo certificado tiene coste fijo relevante
Observabilidad	5 %	Con muestreo adaptativo
Región secundaria (piloto encendido)	incluida, ~11 % del total	Es el precio de un objetivo de recuperación de una hora

8.3 La palanca que más ahorra no es la que parece

Negociar el precio del cómputo produce ahorros porcentuales. **Evitar la ampliación de la capacidad del Core** —un sistema con licenciamiento propio y elasticidad nula— evita un gasto de otro orden de magnitud.

La separación entre consulta y comando (ADR-28) es, además de una decisión de rendimiento, **la principal decisión de coste del proyecto**: sin ella, los **20 millones de llamadas diarias** —en su inmensa mayoría de consulta, con un pico de ~1.500 peticiones por segundo— golpearían al Core, que está dimensionado para un orden de magnitud inferior. Las 196.000 transferencias diarias sí lo alcanzan, y son dos órdenes de magnitud menos.

8.4 Control

Etiquetado obligatorio de todo recurso con servicio, entorno y capacidad de negocio, **verificado en el despliegue**; presupuestos con alerta por desviación; revisión mensual del coste por capacidad frente al objetivo.

Sin imputación, la optimización degenera en recortes indiscriminados: no se puede decidir qué merece su coste si no se sabe a qué corresponde.

9. Capítulo H · Sostenibilidad

Pilar breve pero no ausente, porque forma parte del marco de verificación y porque sus palancas coinciden con las de coste:

- Procesadores de arquitectura eficiente, con mejor relación trabajo/energía.
- Escalado por demanda real, de modo que no se mantenga capacidad ociosa.
- Almacenamiento por niveles, que evita mantener siete años de auditoría en medios de acceso inmediato.
- Muestreo adaptativo de telemetría, que conserva íntegro lo relevante y descarta lo repetitivo.

No se declara ningún objetivo cuantitativo de huella porque no se dispone de la base de comparación; declarar uno sin método de medición sería un compromiso no verificable.

10. Capítulo I · Gobierno de la arquitectura

10.1 Gobierno de las interfaces

Regla	Contenido
Contrato primero	La interfaz se define antes de implementarse y se publica en un catálogo
Versionado explícito	Cambios compatibles sin nueva versión; incompatibles con versión nueva y periodo de convivencia declarado
Nadie consume una base de datos ajena	La única forma de obtener el dato de otro servicio es su interfaz o un evento
La puerta de enlace no contiene lógica de negocio	Lo que la haría insustituible y convertiría el punto de entrada en un monolito encubierto

10.2 Gobierno de las decisiones

Las decisiones se registran como **ADR**, con opciones evaluadas, al menos dos justificaciones de principio, consecuencias aceptadas y forma de verificación. Una decisión sin alternativas registradas no es una decisión: es una preferencia.

10.3 Funciones de aptitud

Comprobaciones automáticas que impiden que la arquitectura se degrade sin que nadie lo note:

- Ningún servicio accede a la base de datos de otro.
- Ningún tramo acepta comunicación sin cifrar ni sin autenticación mutua donde se exige.
- Todo recurso desplegado tiene etiquetado de coste y clasificación de datos.
- Ninguna operación monetaria alcanza el Core sin cribado previo.
- La cadena de resúmenes de auditoría es verificable de extremo a extremo.

La erosión de una arquitectura nunca ocurre por una gran decisión equivocada, sino por muchas pequeñas excepciones que nadie contabiliza.

11. Capítulo J · Matriz de trazabilidad

Responde al **criterio 1**: cada requisito del enunciado, con la decisión que lo cubre y la forma de comprobarlo.

Requisito	Decisión que lo cubre	Verificación
RF-01 Consulta de movimientos	ADR-28 (proyección), ADR-29 (caché)	$p95 \leq 500$ ms; el Core no aparece en la traza
RF-02 Transferencias entre cuentas propias	ADR-33, ADR-34, ADR-35	$p95 \leq 2$ s; clave repetida no duplica el cargo
RF-03 Transferencias interbancarias	ADR-33 (saga), ADR-35 (adaptador)	Compensación ensayada; fecha valor comunicada
RF-04 Datos básicos del cliente	ADR-38 (Servicio de Cliente)	Respuesta sin dependencia del sistema complementario
RF-05 Enriquecimiento bajo demanda	ADR-39 (composición diferida)	Caída del complementario no impide la pantalla
RF-06 Notificación de movimientos	ADR-36 (disparador en el Core), ADR-37 (evidencia)	Conciliación movimientos/avisos; $p95 \leq 2$ min

Requisito	Decisión que lo cubre	Verificación
RF-07 Onboarding con reconocimiento facial	ADR-17 (integración), ADR-18 (verificación)	La biometría no aparece en ningún almacén del banco
RF-08 Autenticación posterior	ADR-16, ADR-19	Nivel exigido registrado por operación
RF-09 Auditoría de todas las acciones	ADR-31, ADR-32	Reconstrucción de la actividad de un cliente en una fecha
RF-10 Persistencia para clientes frecuentes	ADR-29 (tres capas)	Tasa de acierto de la caché; preferencias recuperables
RF-11 Aplicación de página única	ADR-07 (Angular)	Matriz de compatibilidad declarada y probada
RF-12 Aplicación móvil multiplataforma	ADR-08 (Flutter)	Una sola superficie de certificación
RNF-01/02 Alta disponibilidad y tolerancia a fallos	ADR-40, 41, 43	Pérdida de zona sin interrupción perceptible
RNF-03 Recuperación ante desastres	ADR-42	Ensayo de conmutación con resultado registrado
RNF-04 Seguridad	ADR-14, 19, 20, 22, 48, 49	Ningún tramo sin cifrar ni sin autenticar
RNF-05 Monitoreo	ADR-44, 46	Identificador de traza presente en todos los saltos
RNF-06 Excelencia operativa	ADR-45, 50	Cambio en producción solo por la tubería
RNF-07 Auto-recuperación	ADR-45	Instancia defectuosa sustituida sin intervención
RNF-08 Baja latencia	ADR-52	Presupuesto de latencia por tramo, medido
RNF-09 Desacoplamiento y extensibilidad	ADR-04, 05, 24, 26	Capacidad nueva sin modificar las existentes
RNF-10 Cumplimiento normativo	ADR-47, 50	Control verificado en cada despliegue
RNF-11 Control de costos	ADR-51	Coste por usuario activo medido mensualmente
RC-01 El producto de identidad ya existe	ADR-15	Integración por estándar; producto sustituible
RC-02 Capa de integración con puerta de enlace	ADR-21	Punto único de entrada, sin lógica de negocio
RC-03 Mínimo dos sistemas de notificación	ADR-36	Dos proveedores con ruta independiente
RC-04 Mínimo tres servicios, ampliables	ADR-38	Catálogo de siete, con los tres exigidos y justificación individual
RC-05 Modelo C4 hasta componentes	Fases 3, 4 y 5	Tres niveles, con el nivel 3 por contenedor (criterio 2)

12. Capítulo K · Riesgos residuales aceptados

Un diseño que no declara lo que acepta no está terminado.

Riesgo residual	Por qué se acepta	Qué lo acota
Hasta 5 minutos de escrituras perdidas ante desastre regional	Evitarlo exigiría escritura sincrónica entre regiones, con penalización de latencia permanente	Saga y clave de idempotencia dejan toda operación en estado consultable
La transferencia no puede superar el 99,5 % del Core	El Core no se modifica; es una restricción del enunciado	Modo degradado explícito y comunicación clara al cliente
Dependencia de un único proveedor de verificación biométrica	Sustituirlo por dos multiplicaría el coste de certificación	Abstracción tras interfaz propia; contrato con capacidad de sustitución
Consistencia eventual en la consulta de movimientos	Es la contrapartida de no castigar al Core	Objetivo declarado de frescura ($p95 \leq 60$ s) y marca temporal visible en la interfaz
Transferencia internacional de datos personales	No hay región del proveedor en el país	Base de legitimación documentada, cifrado con claves de la entidad, evaluación jurídica previa
El producto de identidad es punto único de fallo	El enunciado establece que existe y solo se configura	Sesiones vigentes sobreviven a su caída; se exige redundancia al proveedor

13. Qué queda

La **Fase 8** ensambla el entregable: portada, índice, resumen ejecutivo, glosario, control de versiones, anexos editables y **autoevaluación contra los quince criterios** (H-14), además del control de integridad final.

Capítulo 12 · Autoevaluación, glosario y anexos

2. Autoevaluación contra los quince criterios de calificación

Se declara, criterio por criterio, **dónde está la evidencia**. Un entregable que no dice dónde responde a cada criterio obliga al evaluador a buscarla, y lo que no se encuentra no se puntúa.

#	Criterio	Dónde está	Evidencia concreta
1	Requisitos cubiertos y justificados	VII §11 (Fase 7)	Matriz de 27 requisitos → decisión → forma de verificación
2	Calidad y profundidad de los C4	IV, cap. 4–6	Tres niveles; nivel 3 por contenedor (4 diagramas), no uno global
3	Segmentación de responsabilidades y desacoplamiento	ADR-04, 05, 24, 38	7 servicios de dominio justificados uno a uno; 3 no creados, declarados
4	Uso de patrones de arquitectura	Fase 5 §8 · Figura 18	Catálogo de 17 patrones con el problema concreto que resuelve cada uno
5	Integración con servicios externos	ADR-22, 23, 27, 35, 36	Capa anticorrupción, catálogo de protocolos por tramo, resiliencia por dependencia
6	Arquitectura front-end y móvil	ADR-07 a 13	Angular y Flutter con alternativas evaluadas; custodia de credencial por canal
7	Arquitectura de acceso a datos	ADR-28 a 32 · Figura 14	Separación consulta/comando, persistencia por servicio, mapa de propiedad del dato
8	Conocimientos de nube	ADR-01 a 03, 06 · Figura 11	Región, zonas, servicios gestionados, enlace privado, residencia de datos
9	Manejo de costos	ADR-51 · Fase 7 cap. G	Objetivo por usuario activo, reparto estimado, seis palancas, control por etiquetado
10	Arquitectura de autenticación	ADR-14 a 20 · Figura 8	Código de autorización con PKCE, custodia en servidor, elevación por operación
11	Integración con Onboarding	ADR-17, 18 · Figura 7	El canal consume el veredicto; la biometría no atraviesa el banco
12	Diseño y solución de auditoría	ADR-31, 32 · Figura 5	Bitemporal, encadenada, inmutable, 7 años, reconstruible
13	Regulaciones y estándares de seguridad	ADR-47 a 50 · Fase 7 cap. A y B	Tres capas normativas; cada obligación traducida a control verificable
14	HA y tolerancia a fallos	ADR-40 a 43 · Figura 13	Disponibilidad declarada por camino ; catálogo de modos degradados
15	Monitoreo	ADR-44, 46 · Figura 15	Indicadores con objetivo, margen de error y respuesta al agotarlo

2.1 Las recomendaciones "MUY valoradas"

Recomendación del enunciado	Cómo se cumple
Mínimo dos justificaciones por decisión	52 ADR con 143 justificaciones de principio ; ninguna decisión queda por debajo de dos
Alternativas evaluadas	Tabla de opciones con argumentos a favor y en contra en las 52 decisiones
Diagramas en herramienta editable	18 figuras , cada una con su fuente <code>.drawio</code> abrible en diagrams.net
Documento organizado y fácil de leer	Portada, índice, numeración de figuras, resumen ejecutivo, glosario, control de versiones y matriz de trazabilidad

3. Los catorce riesgos de evaluación, uno a uno

El análisis inicial identificó catorce errores que hundían la calificación aunque el diseño sea bueno (H-14). Se recorren todos.

#	Riesgo	Dónde se evita	Verificado
1	Usar el flujo de credenciales directas para el acceso	ADR-14: código de autorización con PKCE; se cita RFC 9700, que lo desaconseja	Automático
2	Enviar biometría al servidor o exigirla en cada acceso	ADR-18: la imagen no atraviesa el banco. ADR-16: tras la vinculación se usa el factor del dispositivo	Automático
3	Un único diagrama de componentes	Fase 5: cuatro diagramas, uno por contenedor	Automático
4	Mezclar niveles de abstracción en C4	Fase 3 §1: ninguna tecnología interna en el contexto. Fase 4: sí aparece, porque ese nivel la exige	Revisión dirigida
5	Notificaciones disparadas solo desde la aplicación	ADR-36 · Figura 10: el disparador es el movimiento registrado en el núcleo	Automático
6	Transacción distribuida con la red interbancaria	ADR-33 · Figura 9: saga con compensación; ningún paso mantiene transacción abierta	Automático
7	Auditoría síncrona en el camino crítico	ADR-31 · Figura 5: captura asíncrona; la completitud la garantiza la bandeja de salida	Automático
8	Decisiones sin dos justificaciones ni alternativas	52 ADR, 143 justificaciones, 0 incidencias de formato	Automático
9	No cuantificar nada	Objetivos de recuperación, objetivos de servicio y coste por usuario, todos con cifra	Automático
10	Ignorar el "mínimo 2" de avisos o el "mínimo 3" de servicios	RC-03: dos proveedores con ruta independiente . RC-04: catálogo de siete servicios	Automático
11	Guardar credenciales en el almacenamiento del navegador	ADR-10: custodia en servidor; el navegador solo recibe una cookie inaccesible desde guiones	Automático
12	Dar la nube por supuesta sin justificarla	ADR-01 y 02: decisión razonada, con la alternativa local evaluada y descartada	Automático
13	Proyección de lectura sin declararla no autoritativa	H-18 : declarada en siete documentos y dos figuras, con origen, invalidación y frescura comprometida	Automático
14	Ignorar la residencia de datos al elegir región	ADR-03: no hay región en el país; se documenta base de legitimación, cifrado con claves propias y evaluación jurídica previa	Automático

Control de calidad del documento. Cada decisión cumple el formato exigido —opciones evaluadas, dos justificaciones como mínimo, consecuencias y verificación—; toda figura citada en el texto existe y está numerada; todo enlace interno resuelve; todo tramo de comunicación que cruza una frontera declara su protocolo y su protección; y las cifras de capacidad, latencia, disponibilidad y recuperación son las mismas en todos los capítulos. Son comprobaciones que el lector puede contrastar por muestreo.

4. Glosario de siglas y términos

4.1 Arquitectura y método

Término	Significado	Por qué aparece aquí
ADR	<i>Architecture Decision Record</i> , registro de decisión de arquitectura	Formato de las 52 decisiones: contexto, opciones, decisión, justificación, consecuencias y verificación
ASR	<i>Architecturally Significant Requirement</i> , requisito arquitectónicamente relevante	Los 19 escenarios de calidad medibles que gobiernan el diseño
C4	Modelo de cuatro niveles: contexto, contenedores, componentes y código	Notación exigida por el enunciado
Contenedor (C4)	Unidad desplegable y ejecutable: una aplicación, un servicio, una base de datos	No es un contenedor de Docker
Componente (C4)	Agrupación de código con responsabilidad propia dentro de un contenedor	No es un despliegue independiente
BIAN	<i>Banking Industry Architecture Network</i> , modelo de referencia de capacidades bancarias	Vocabulario común para nombrar capacidades; no es una arquitectura técnica
Service Domain	Dominio de servicio: unidad de capacidad de negocio en BIAN	Unidad del mapa de la Figura 16

Término	Significado	Por qué aparece aquí
Función de aptitud	Comprobación automática que impide que la arquitectura se degrade	Ej.: ningún servicio accede a la base de otro

4.2 Patrones de diseño aplicados

Patrón	Qué hace	Dónde
Saga / Process Manager	Coordina pasos sobre sistemas que no admiten transacción distribuida, con compensación explícita	Transferencias
Transactional Outbox	Escribe el dato y su evento en la misma transacción, y publica después	Transferencias, Auditoría
CDC (<i>Change Data Capture</i>)	Captura de cambios: publica las modificaciones de una base sin consultarla periódicamente	Núcleo → canal
CQRS	Separación entre el camino de consulta y el de comando	Consulta de movimientos
Materialized View / Proyección	Copia preparada para consultar, alimentada por eventos	Movimientos
Idempotent Receiver	Una misma clave no vuelve a ejecutar la operación: devuelve la respuesta original	Transferencias, Avisos
Cache-Aside	Se consulta la caché; si falla, se consulta el origen y se puebla	Datos de cliente
Repository	Abstrae el acceso a la persistencia	Preferencias, Operaciones
Anti-Corruption Layer	Capa anticorrupción: traduce el modelo externo para que no contamine el interno	Adaptador de núcleo
Strangler Fig	Sustitución progresiva de un sistema rodeándolo	Estrategia de convivencia
Circuit Breaker	Corte de circuito: deja de llamar a una dependencia que falla y reintenta más tarde	Toda dependencia externa
Bulkhead	Compartimento estanco: aísla recursos para que un fallo no agote los del resto	Colas por proveedor
Dead Letter Queue	Cola de no entregados: aparta lo que falló definitivamente, con alerta	Avisos
Interceptor	Se ejecuta antes o después sin que el código de negocio lo invoque	Auditoría, trazas
Strategy / Router	Elige la implementación según el caso	Tipos de transferencia
Adapter	Traduce entre dos interfaces	Esquemas de pago, proveedores
Hash Chain	Cadena de resúmenes: cada lote incorpora el del anterior, haciendo detectable toda alteración	Auditoría
Bitemporal Record	Registro con dos fechas: cuándo ocurrió y cuándo se supo	Auditoría
Hot / Cold Tiering	Niveles de almacenamiento según antigüedad y frecuencia de acceso	Auditoría
BFF (<i>Backend for Frontend</i>)	Backend específico de un canal, que compone y ajusta la respuesta	Web y móvil
Token Handler	El servidor custodia la credencial y el navegador solo recibe una cookie	Canal web
Cell-based architecture	Arquitectura celular: celdas independientes que acotan el alcance de un fallo	Camino transaccional

4.3 Identidad, seguridad y protocolos

Sigla	Significado	Relevancia
OAuth 2.0	Marco de autorización delegada	Base del acceso al canal
OIDC	<i>OpenID Connect</i> : capa de identidad sobre OAuth 2.0	Autenticación contra el producto de identidad
PKCE	<i>Proof Key for Code Exchange</i> (RFC 7636)	Hace inútil un código de autorización interceptado
RFC 8252	Buenas prácticas de OAuth en aplicaciones nativas	Exige el navegador del sistema, no una vista embebida
RFC 8693	<i>Token Exchange</i> : intercambio de credencial	Una credencial distinta por destino, sin reutilización
RFC 9700	Buenas prácticas de seguridad de OAuth 2.0	Desaconseja el flujo de credenciales directas
SCIM 2.0	Estándar de provisión de identidades	Alta de la identidad tras la vinculación
IAL / AAL	Niveles de aseguramiento de identidad y de autenticación (NIST SP 800-63)	El nivel de la vinculación condiciona el exigible en cada operación
mTLS	TLS con autenticación mutua de ambos extremos	Todo tramo interno

Sigla	Significado	Relevancia
TLS 1.3	Versión vigente del protocolo de transporte seguro	Reduce una vuelta en el saludo inicial
HSTS	Política que obliga al navegador a usar siempre conexión segura	Cabecera del borde
CSRF	Falsificación de petición entre sitios	Se mitiga con doble testigo
WAF	Cortafuegos de aplicación web	Primera barrera del borde
KMS / HSM	Servicio de gestión de claves / módulo de seguridad por hardware	Material criptográfico crítico
ISO/IEC 30107-3	Detección de ataques de presentación en biometría	Certificación exigida al proveedor de verificación
OWASP ASVS	Estándar de verificación de seguridad de aplicaciones	Criterio de las pruebas de seguridad
gRPC	Llamada a procedimiento remoto sobre HTTP/2 con contrato tipado	Único tramo interno de alto volumen
ISO 20022	Estándar de mensajería financiera	Transferencias interbancarias
SASL	Marco de autenticación para protocolos de mensajería	Acceso al bus de eventos

4.4 Operación, datos y nube

Sigla	Significado
RTO / RPO	Objetivo de tiempo de recuperación / objetivo de punto de recuperación
SLI / SLO / SLA	Indicador / objetivo / acuerdo de nivel de servicio
Margen de error (<i>error budget</i>)	Margen de incumplimiento admisible antes de priorizar estabilidad sobre entregas
p95 / p99	Percentiles 95 y 99: el valor que no superan el 95 % o el 99 % de las peticiones
Zona de disponibilidad	Emplazamiento aislado dentro de una región de nube
VPC	Red privada virtual dentro de la nube
EKS	Servicio gestionado de orquestación de contenedores
Karpenter / KEDA	Aprovisionamiento de nodos por demanda / escalado por evento
MSK	Servicio gestionado de mensajería compatible con Apache Kafka
Aurora	Motor relacional gestionado compatible con PostgreSQL
DynamoDB	Base de datos de clave-valor gestionada
ElastiCache	Caché gestionada compatible con Redis
OpenSearch	Motor de búsqueda e indexación gestionado
S3 / Object Lock	Almacenamiento de objetos / bloqueo que impide borrar incluso a un administrador
CloudFront / Global Accelerator	Red de distribución de contenido / enrutado por la red troncal del proveedor
Direct Connect	Enlace privado dedicado entre el centro de datos y la nube
IaC	Infraestructura declarada como código
OpenTelemetry	Estándar abierto de instrumentación para trazas, métricas y registros

4.5 Normativa

Sigla	Significado
COMF	Código Orgánico Monetario y Financiero (Ecuador)
LOPD	Ley Orgánica de Protección de Datos Personales (Ecuador)
UAFFE	Unidad de Análisis Financiero y Económico (Ecuador)
PLAFT	Prevención de lavado de activos y financiamiento del terrorismo
SPI	Sistema de Pagos Interbancario del Banco Central del Ecuador
ISO/IEC 27001 y 27002	Sistema de gestión de seguridad de la información y catálogo de controles
ISO 22301	Gestión de la continuidad del negocio
PCI DSS	Estándar de seguridad de datos de la industria de medios de pago con tarjeta

Sigla	Significado
GDPR / RGPD	Reglamento General de Protección de Datos (Unión Europea)
DORA	Reglamento de resiliencia operativa digital (Unión Europea)

5. Control de versiones

Versión	Fecha	Autor	Descripción
1.0	27-09-2026	Henry Cadena Herrera	Versión inicial. Emisión completa del documento.

6. Anexos

6.1 Fuentes editables de las figuras

Las dieciocho figuras se entregan además en formato editable `.drawio`, abrible en diagrams.net sin necesidad de instalar nada.

Figura	Fichero
1 · Contexto	C4-1-contexto
2 · Contenedores	C4-2-contenedores
3 · Componentes de Transferencias	C4-3a-componentes-transferencias
4 · Componentes del backend de canal	C4-3b-componentes-bff
5 · Componentes de Auditoría	C4-3c-componentes-auditoria
6 · Componentes de Notificaciones	C4-3d-componentes-notificaciones
7 · Secuencia de vinculación	SEQ-1-vinculacion
8 · Secuencia de autenticación	SEQ-2-autenticacion
9 · Secuencia de transferencia	SEQ-3-transferencia
10 · Secuencia de notificación	SEQ-4-notificacion
11 · Despliegue en nube	DEP-1-despliegue-aws
12 · Zonas de seguridad	SEC-1-zonas-seguridad
13 · Recuperación ante desastres	DR-1-recuperacion
14 · Mapa de datos	DAT-1-mapa-de-datos
15 · Observabilidad	OBS-1-observabilidad
16 · Capacidades BIAN	BIAN-1-capacidades
17 · Hoja de ruta	RM-1-hoja-de-ruta
18 · Patrones de caché y frecuentes	PAT-1-patrones-cache-frecuentes

6.2 Supuestos declarados

Este diseño se apoya en supuestos que el enunciado no fija. Se declaran para que puedan discutirse y, si procede, corregirse sin rehacer el razonamiento.

Supuesto	Valor asumido	Efecto si cambia
Jurisdicción	Ecuador	Cambia el marco local del capítulo normativo; las equivalencias regionales preservan el resto
Usuarios digitales activos	1,8 millones	Escala el dimensionamiento y el coste, no las decisiones
Llamadas diarias	~20 millones, pico ~1.500/s	Escala la capacidad; la separación consulta/comando sigue siendo necesaria

Supuesto	Valor asumido	Efecto si cambia
Transferencias diarias	~196.000, pico de diseño 80/s	Escala el camino transaccional
Disponibilidad del núcleo bancario	99,5 %	Es el techo del camino de transferencia
Proveedor de nube	AWS	Las decisiones son trasladables; cambian los nombres de los servicios
Retención de auditoría	7 años	Afecta al coste de archivo, no al diseño

6.3 Qué haría falta para pasar de este diseño a la implantación

1. Confirmar la jurisdicción y validar el marco normativo con el área de cumplimiento.
2. Medir la latencia real hacia la región candidata antes de confirmarla.
3. Obtener del área responsable del núcleo el límite de carga admisible y el mecanismo de captura de cambios disponible.
4. Contratar dos proveedores de aviso con **diversidad de ruta demostrable**, no solo dos contratos.
5. Certificar al proveedor de verificación de identidad contra la detección de ataques de presentación.
6. Acordar con el Banco Central los horarios de corte y el entorno de homologación de la red de pagos.

7. Cierre

Este documento contiene **52 decisiones de arquitectura** con sus alternativas evaluadas y **143 justificaciones de principio**, **18 figuras** con su fuente editable, **19 escenarios de calidad medibles** y una **matriz de trazabilidad** que enlaza cada requisito del enunciado con la decisión que lo cubre y con la forma de comprobarlo.

Las decisiones no se presentan como verdades: se presentan con lo que se descartó y por qué, con las consecuencias que se aceptan y con la manera de verificar que se cumplen. Una arquitectura que no declara lo que sacrifica no ha decidido nada.